Matriz de seguridad y evidencias

PharmaBackend · Sesión 10 · 18 de octubre de 2026

28 casos: 16 base, cuatro propios y ocho de contraseña, roles y estado. Un caso puede agrupar varias peticiones. Pasa significa coincidencia entre resultado esperado y obtenido, incluidos los rechazos previstos. Las referencias E001-E092 identifican figuras; las verificaciones automatizadas complementarias se distinguen en la matriz.

ID	Grupo	Usuario / token	Petición	Resultado esperado (código y mensaje)	Resultado obtenido	Estado	Evidencia
A-01	Autenticación	admin, vendedor, almacen, supervisor	POST /auth/login (cuatro cuentas)	200 con roles y permisos; supervisor recibe la unión	200; ADMIN, VENDEDOR y supervisor con unión de roles. Login ALMACENERO 200 en renovación.	Pasa	E001, E002, E003, E004
A-02	Autenticación	inexistente y admin con clave incorrecta	POST /auth/login (dos intentos)	401: Usuario o contraseña incorrectos en ambos	401: Usuario o contraseña incorrectos; mensaje uniforme confirmado en la ejecución y en credencialesInvalidasMismoMensaje.	Pasa	E006
A-03	Autenticación	inactivo	POST /auth/login	401 con mensaje genérico de credenciales	401: Usuario o contraseña incorrectos.	Pasa	E007
A-04	Autenticación	VENDEDOR	POST /auth/login	200; regla sin distinguir mayúsculas	200; username canónico vendedor. Ejecución confirmada y prueba loginYPerfilSinPassword con VENDEDOR.	Pasa	Confirmación de ejecución; loginYPerfilSinPassword (automatizada)
A-05	Autenticación (propio)	vendedor con espacios	POST /auth/login	200; trim del username	200; espacios exteriores eliminados del username.	Pasa	E008
T-01	Token	token vendedor sin Bearer	GET /productos	401: Debe iniciar sesión para acceder a este recurso	401: Debe iniciar sesión para acceder a este recurso.	Pasa	E009
T-02	Token	payload cambiado, firma original	GET /productos	401: El token no es válido	401: El token no es válido.	Pasa	E010, E011
T-03	Token	token previo al cambio de secreto	GET /productos	401: El token no es válido	200 con clave original y 401: El token no es válido tras cambiarla.	Pasa	E012, E013
T-04	Token	token de un minuto vencido	GET /productos	401: El token ha expirado. Inicie sesión nuevamente	200 al emitir/acceder; 401: El token ha expirado. Inicie sesión nuevamente después del vencimiento.	Pasa	E014, E015, E016
T-05	Token	token vendedor válido	Decodificar payload localmente	sub, authorities, iat y exp correctos; sin datos sensibles	sub vendedor, authorities, iat y exp; emisión corta con duración 60 s, sin password ni hash.	Pasa	E017
T-06	Token (propio)	Bearer abc.def.ghi	GET /productos	401: El token no es válido (formato malformado)	401: El token no es válido.	Pasa	E018
P-01	Permisos	vendedor	POST, PUT y DELETE /categorias	403 en las tres operaciones	403 en POST, PUT y DELETE: No tiene permisos para realizar esta operación.	Pasa	E022, E023, E024, E025, E026
P-02	Permisos	almacen	GET /clientes; POST /ventas	403 en ambas	403 en GET clientes y POST ventas: No tiene permisos para realizar esta operación.	Pasa	E027, E028, E029

ID	Grupo	Usuario / token	Petición	Resultado esperado (código y mensaje)	Resultado obtenido	Estado	Evidencia
P-03	Permisos	vendedor y almacen	GET /reportes/productos-mas-vendidos	403 por autorización de método para ambos	403 para vendedor y almacén: No tiene permisos para realizar esta operación.	Pasa	E030, E031, E032
P-04	Permisos	admin	GET de cada módulo	2xx en categorías, productos, clientes, ventas, reportes y usuarios/empleados/roles	200 en las ocho consultas de módulos y administración.	Pasa	E033, E034, E035, E036, E037, E038, E039, E040
P-05	Permisos (propio)	vendedor	POST /usuarios	403 sin crear cuenta	403: No tiene permisos para realizar esta operación.	Pasa	E041
U-01	Usuarios	admin / empleado de prueba sin cuenta	POST /usuarios: password abcdefgh; rolIds []	400 en ambos; validación password y rolIds	400 en ambas variantes; validationErrors de password y rolIds.	Pasa	E042, E043
U-02	Usuarios	admin / empleado ocupado y empleado de prueba libre	POST /usuarios; comprobar Oracle	409 empleado ocupado; luego 201, hash BCrypt y relación usuario_roles	409 para empleado ocupado; 201 para autonoma_s10 (usuario 22, empleado 21), sin password. BCrypt y relaciones comprobados además en pruebas aisladas.	Pasa	E045, E046
U-03	Usuarios (propio)	admin / empleado de prueba libre	POST /usuarios con password de más de 72 bytes UTF-8	409: La contraseña no puede superar 72 bytes	409: La contraseña no puede superar 72 bytes.	Pasa	E044
C-01	CORS	token vendedor / origen localhost:4200	OPTIONS previo a GET /productos	OPTIONS 200 y GET 200 o 401; sin error de CORS	OPTIONS 200; GET 200 con JSON y Allow-Origin http://localhost:4200; sin bloqueo CORS.	Pasa	E088, E089, E090, E091, E092
B-01	Contraseña	cuenta de prueba	PUT /auth/password: actual incorrecta	409: La contraseña actual no es correcta; hash intacto	409: La contraseña actual no es correcta. Hash intacto comprobado en passwordActualIncorrectaNoModificaHash.	Pasa	E048
B-02	Contraseña	cuenta de prueba	PUT /auth/password: nueva igual	409: La nueva contraseña debe ser distinta de la actual	409: La nueva contraseña debe ser distinta de la actual.	Pasa	E049
B-03	Contraseña	cuenta de prueba	PUT /auth/password: nueva inválida	400 por formato; 409 si supera 72 bytes UTF-8	400: validationErrors.passwordNueva en cuatro formatos; 409: La contraseña no puede superar 72 bytes.	Pasa	E050, E051, E052, E053, E054
B-04	Contraseña	cuenta de prueba y token previo	PUT /auth/password y logins viejo/nuevo; GET con token anterior	204; BCrypt; login viejo 401, nuevo 200; token anterior 200	204; login anterior 401 y nuevo 200; JWT anterior 200. Hash BCrypt comprobado en passwordNuevaBcryptYTokenPrevioPermaneceValido.	Pasa	E055, E056, E057, E058
B-05	Roles	admin y mismo token de cuenta de prueba	PUT /usuarios/{id}/roles; PUT producto; consultar unión	200, conjunto reemplazado y permisos actuales sin nuevo login	403 antes, asignación 200, edición 200 con mismo JWT; reemplazo 200 y clientes 403; restauración 200. Relación JPA cubierta por pruebas aisladas.	Pasa	E061, E062, E063, E064, E065
B-06	Roles	admin	Roles vacíos/nulos; usuario o rol inexistente	400 validaciones; 404 inexistentes	400 con roles vacíos/nulos; 404: Roles no encontrados: [999999] y Usuario no encontrado con id: 999999.	Pasa	E067, E068, E069, E070
B-07	Salvaguardas	admin / cuenta de prueba	Autoquitar ADMIN, autodesactivar; llamadas no admin	409 en autoacciones; 403 a no admin	409: No puede quitarse a sí mismo el rol ADMIN / No puede desactivarse a sí mismo. No admin: 403 en roles y estado.	Pasa	E071, E072, E073, E074, E075, E076, E077, E078
B-08	Estado	admin y token previo de cuenta de prueba	PATCH estado; acceso/login; reactivar; variantes inválidas	200 estado; 401 deshabilitado/login; reactivar 200; 404 usuario y 400 estado ausente	Desactivar/reactivar 200; token previo 401: El usuario está deshabilitado; login 401 genérico; reactivación permite token previo y login 200; inexistente 404 y estado nulo 400.	Pasa	E079, E080, E081, E082, E083, E084, E085, E086, E087

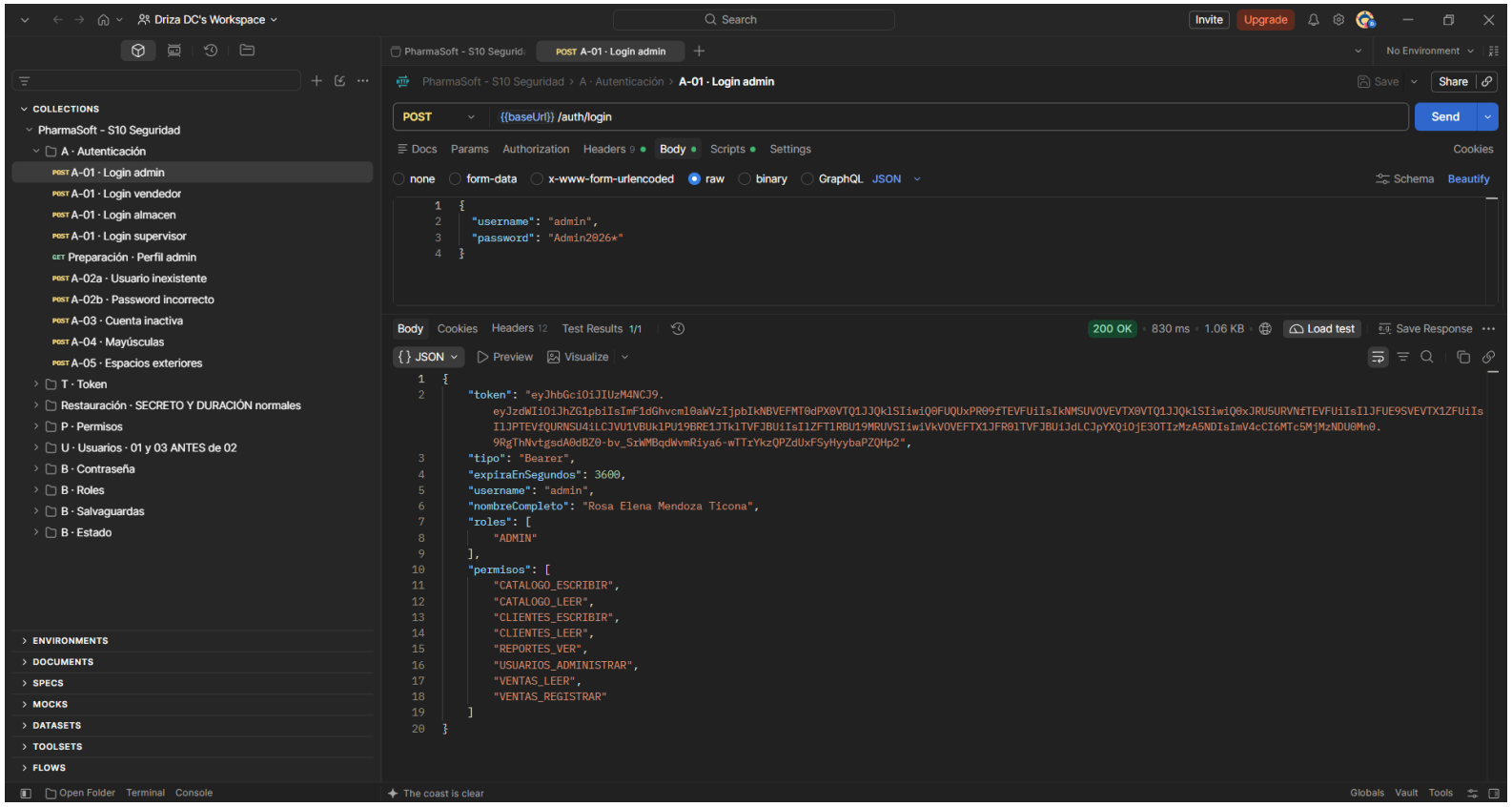
Evidencias

- Autenticación y perfil
- Integridad, firma y expiración del JWT
- Restauración de condiciones de prueba
- Permisos por rol
- Creación y validación de usuarios
- Cambio de contraseña
- Asignación y reemplazo de roles
- Salvaguardas administrativas
- Activación y desactivación de cuentas
- CORS y acceso desde la SPA

Autenticación y perfil

E001 · A-01 · Login de administrador

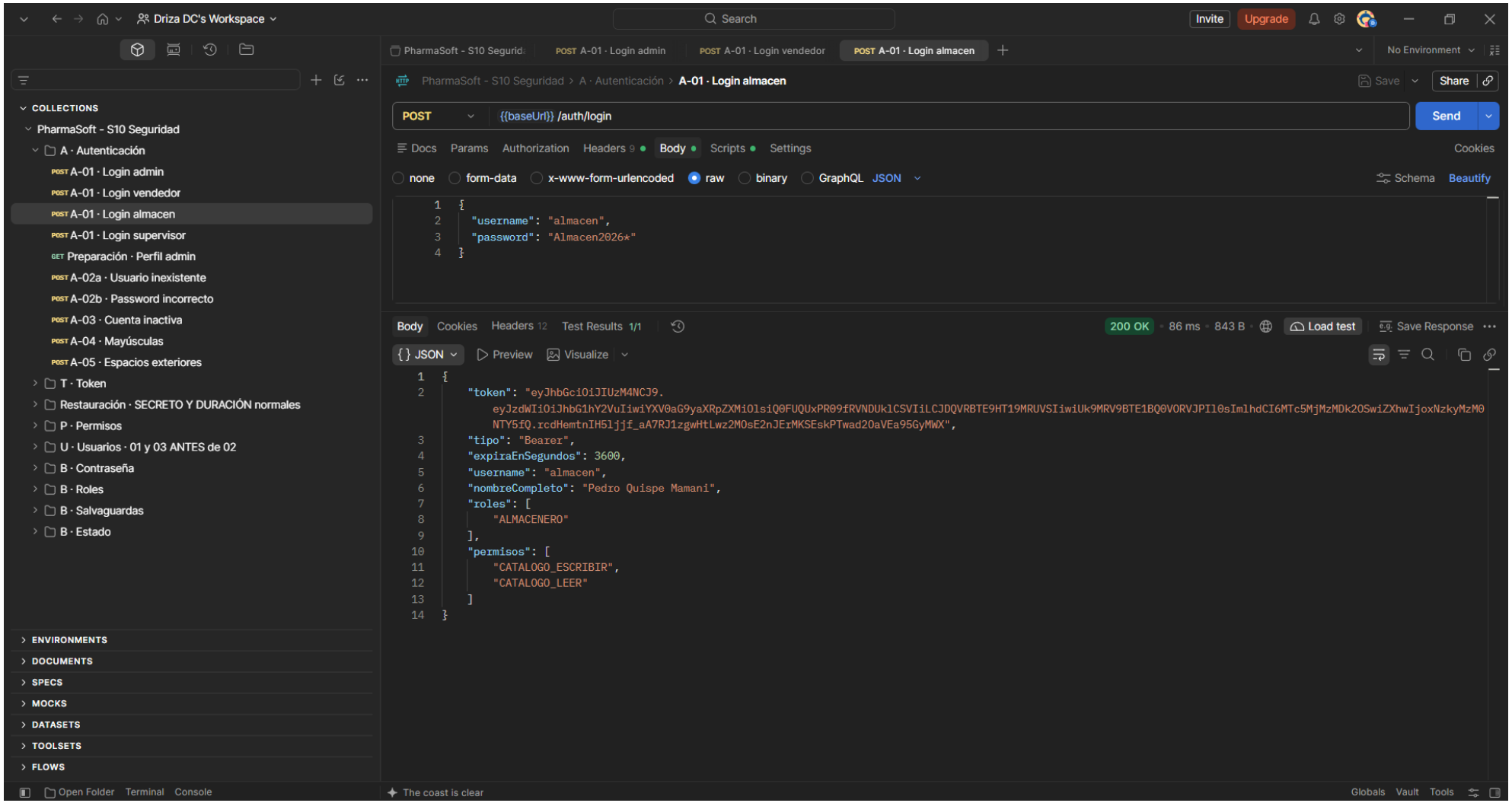
200; ADMIN y sus permisos.



Autenticación y perfil

E002 · A-01 · Login de vendedor

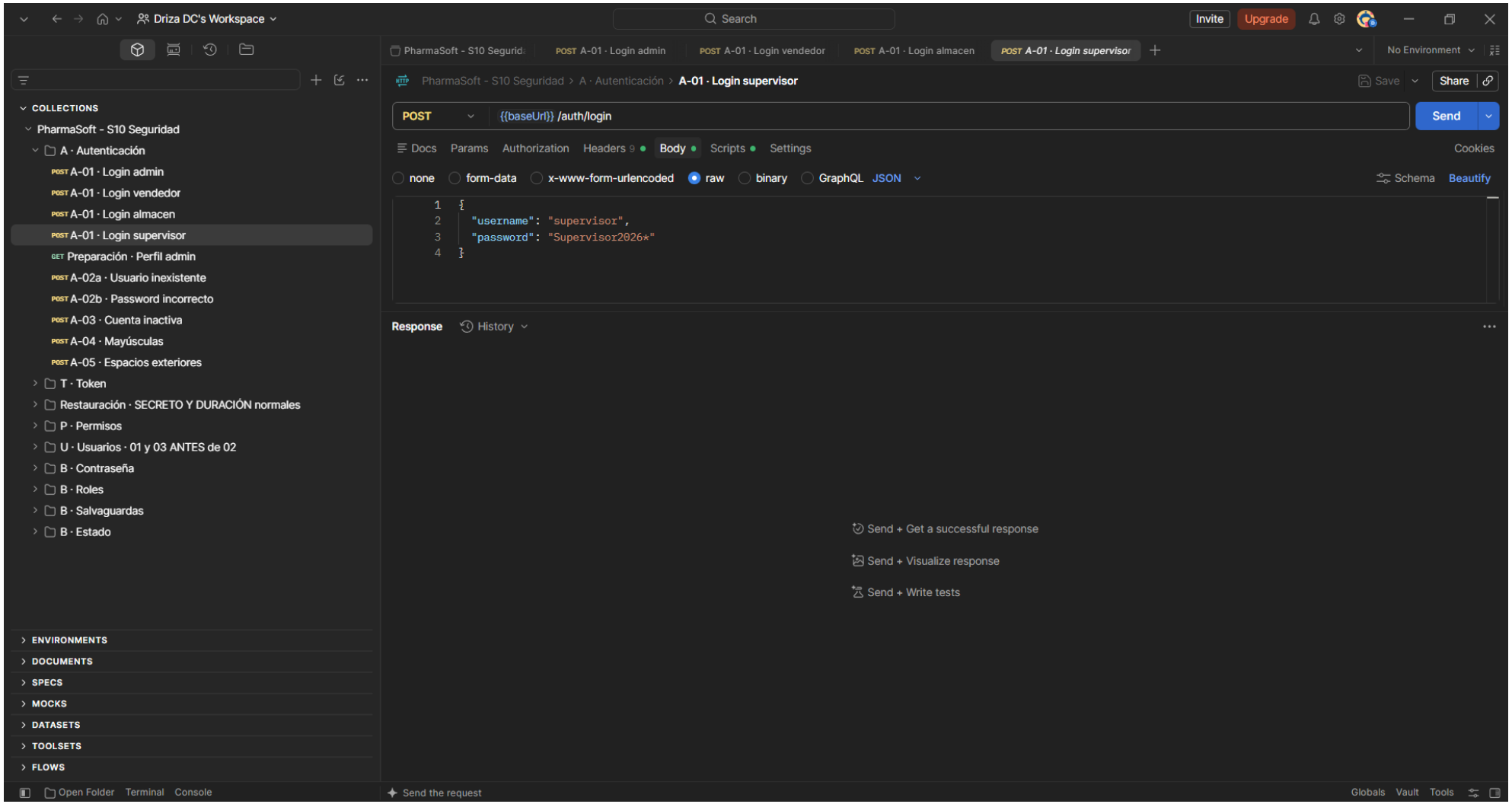
200; VENDEDOR y permisos comerciales.



Autenticación y perfil

E003 · A-01 · Preparación del login de supervisor

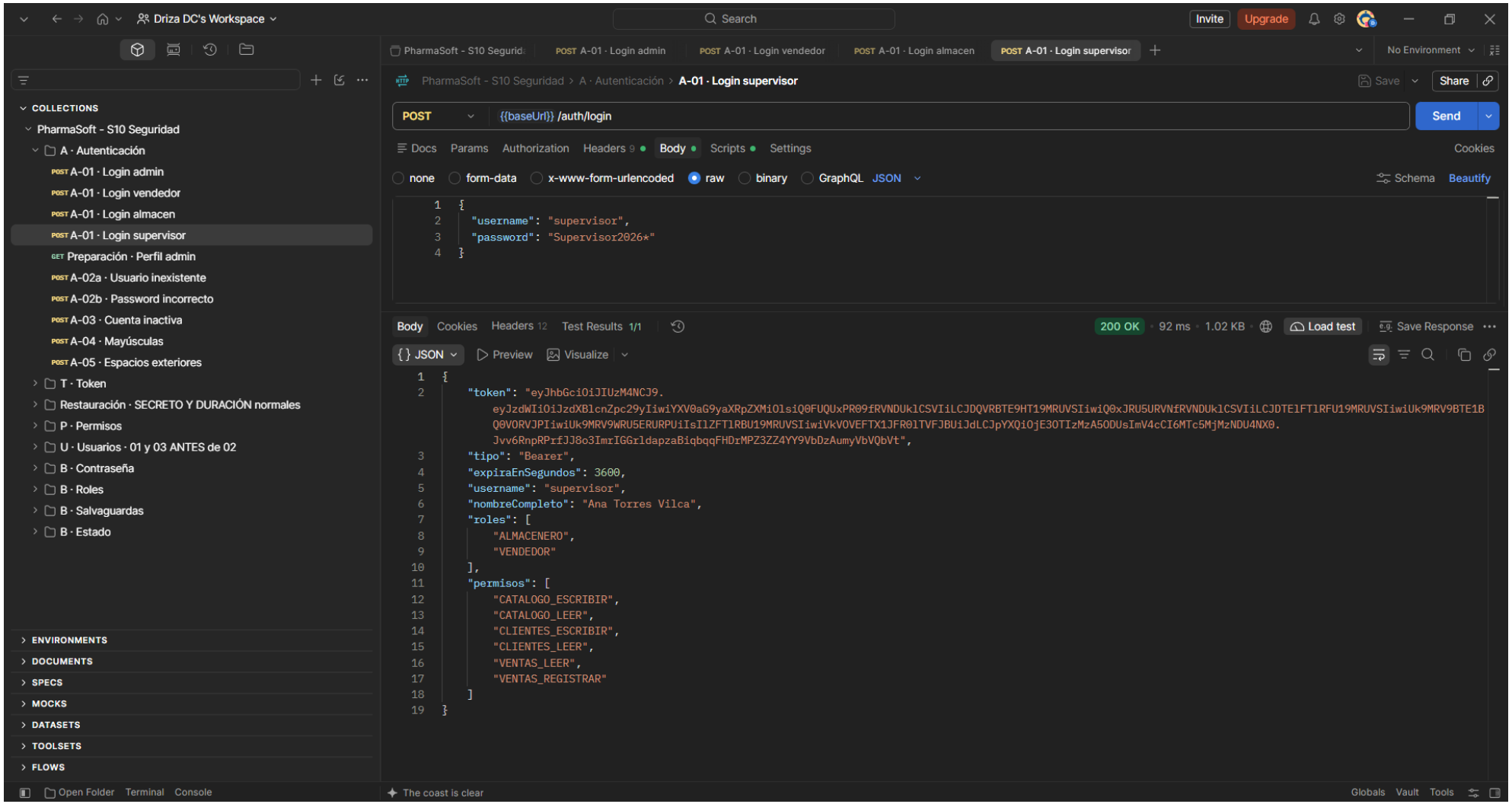
Solicitud preparada para comprobar la unión de roles.



Autenticación y perfil

E004 · A-01 · Login de supervisor

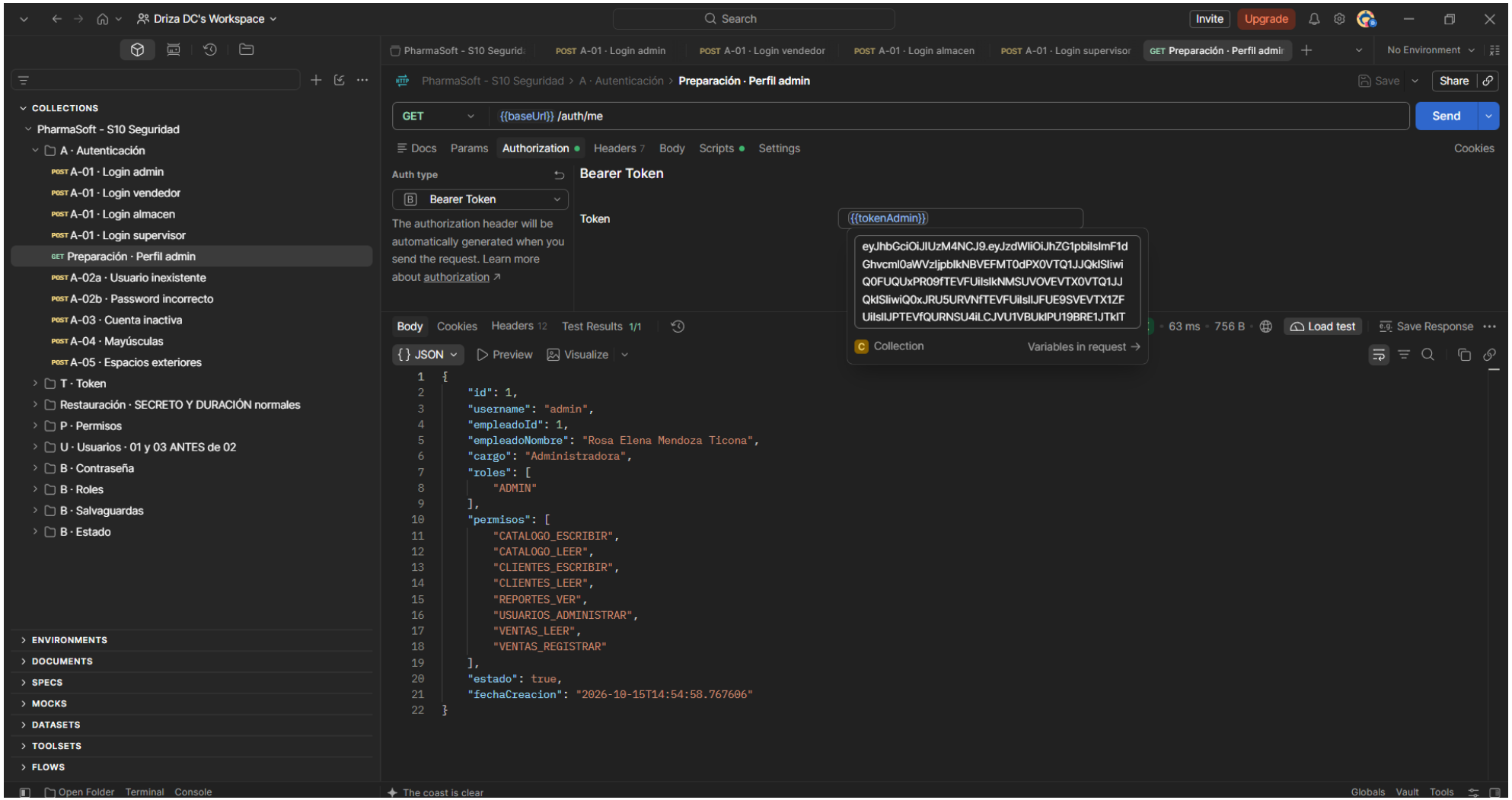
200; ALMACENERO y VENDEDOR con la unión de permisos.



Autenticación y perfil

E005 · AUX · Perfil del administrador

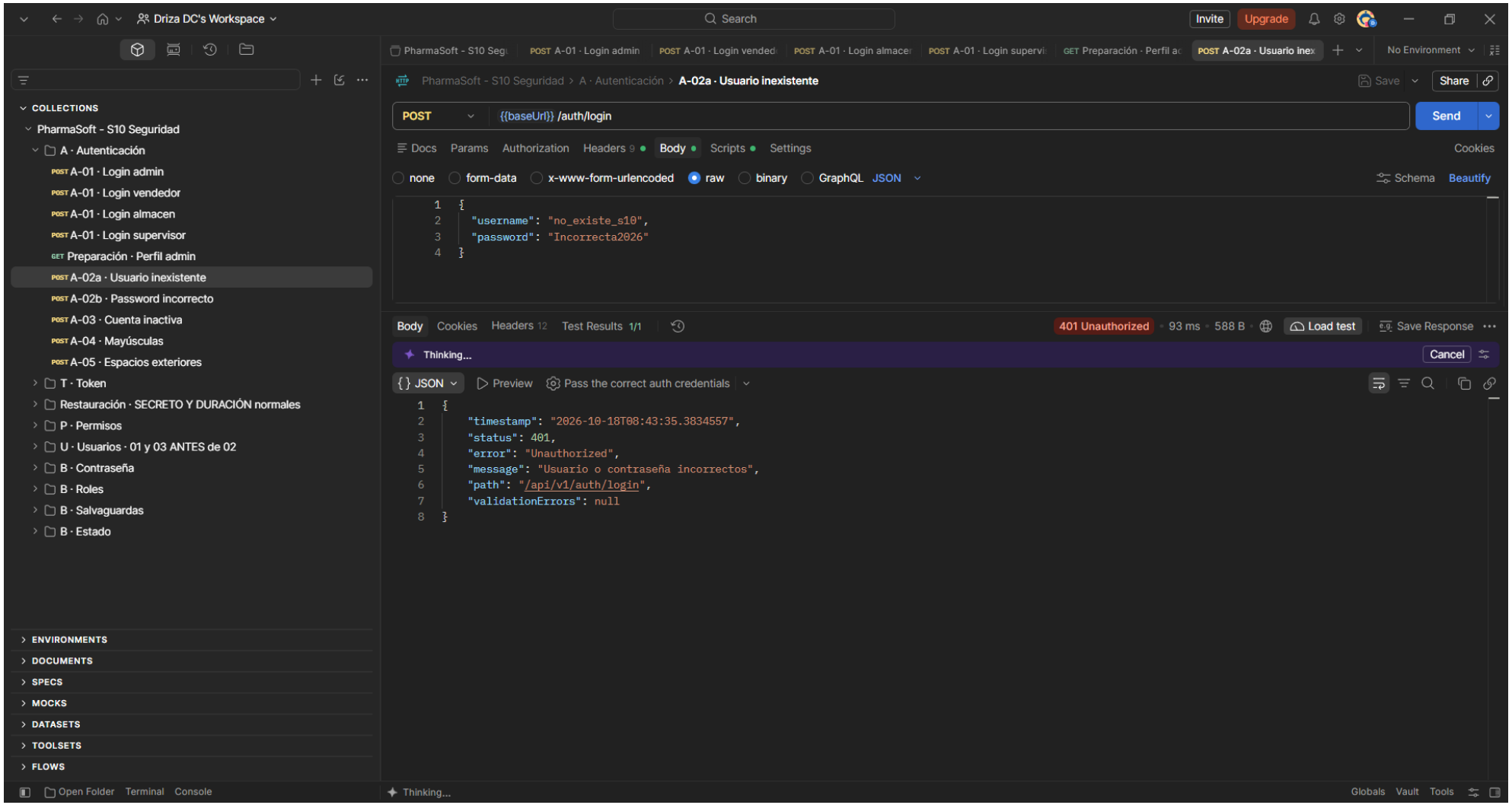
200; perfil actual y permisos administrativos.



Autenticación y perfil

E006 · A-02 · Usuario inexistente

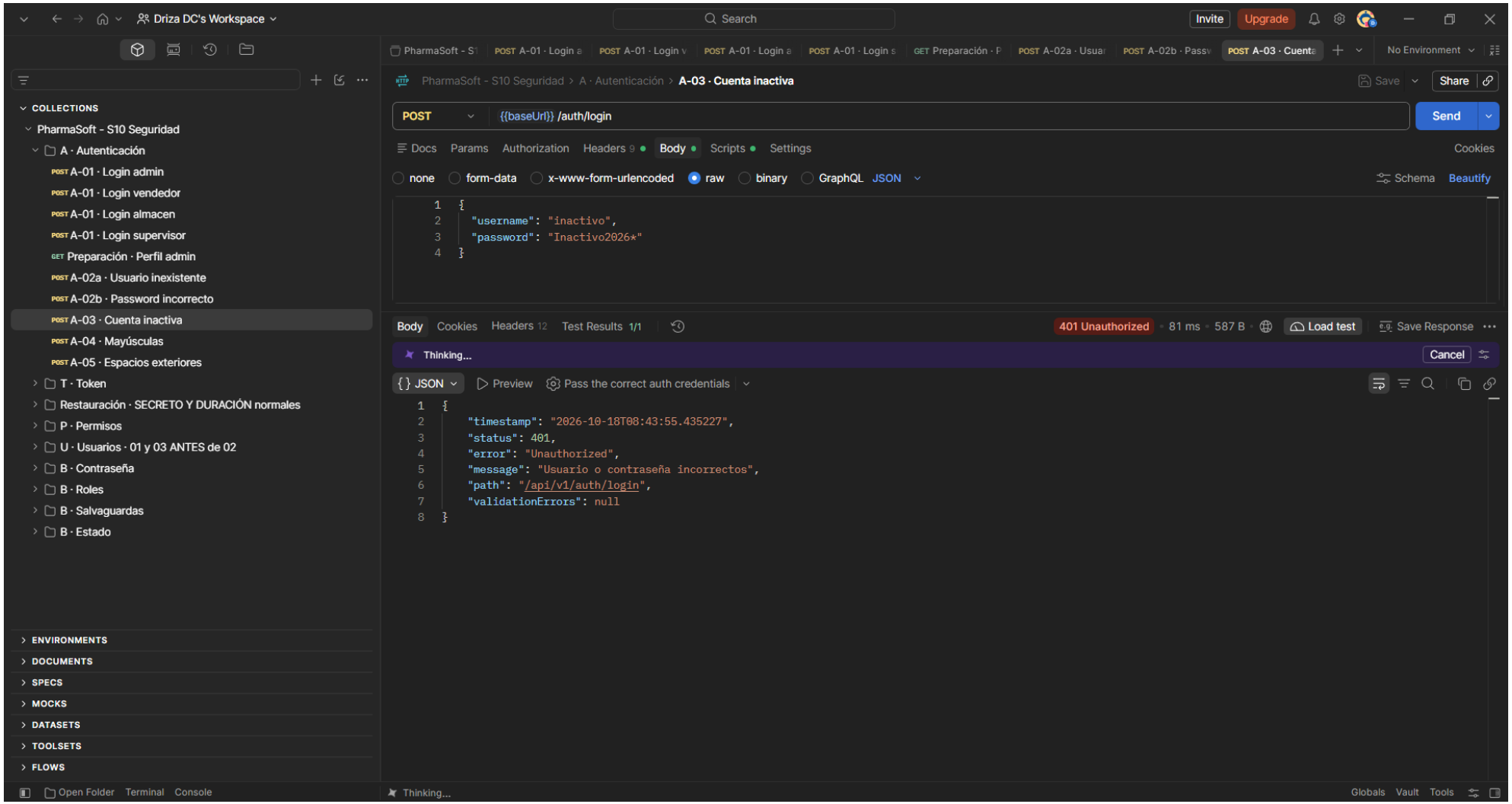
401; Usuario o contraseña incorrectos.



Autenticación y perfil

E007 · A-03 · Cuenta inactiva

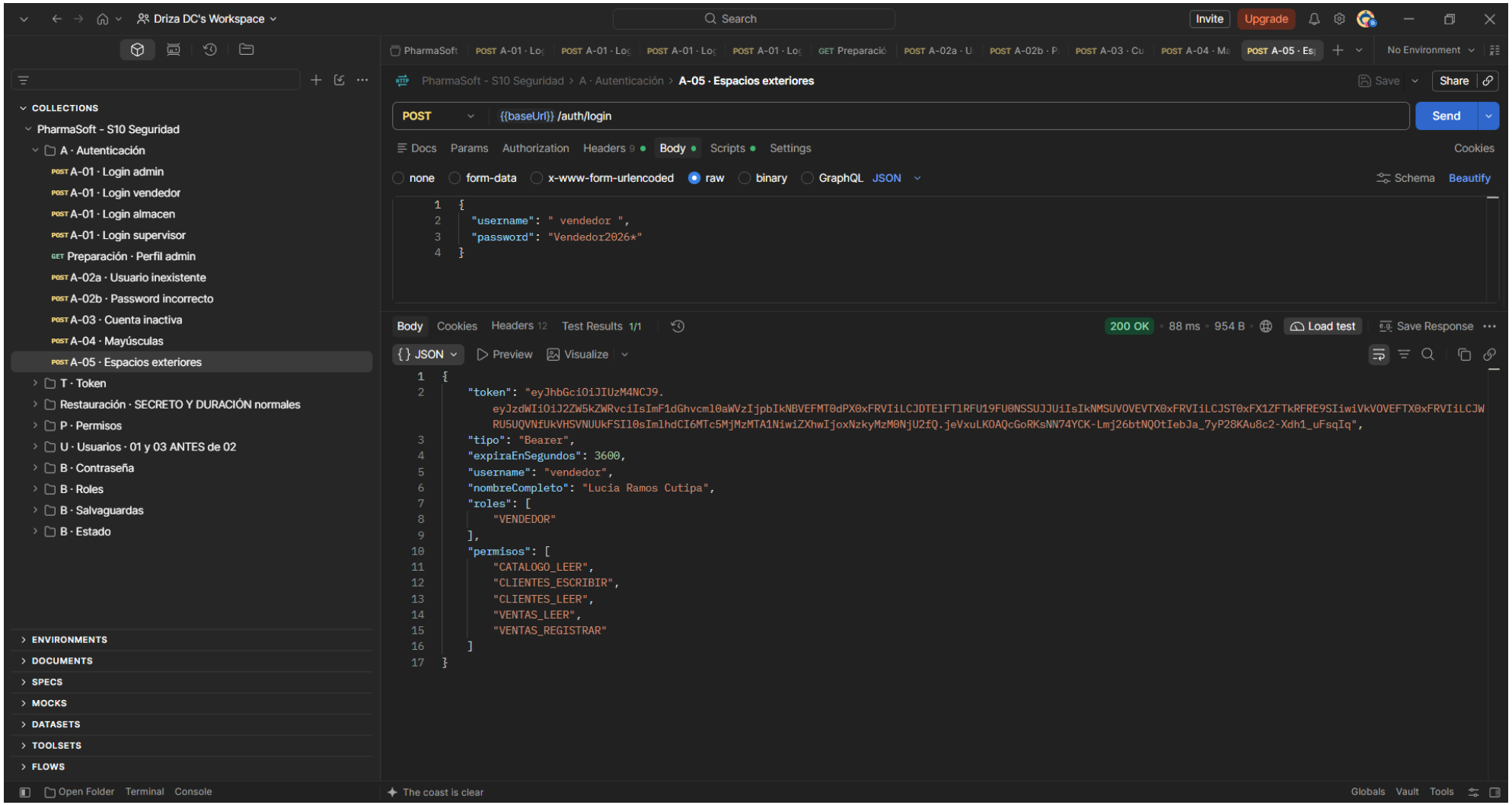
401; el mensaje no revela la existencia de la cuenta.



Autenticación y perfil

E008 · A-05 · Username con espacios exteriores

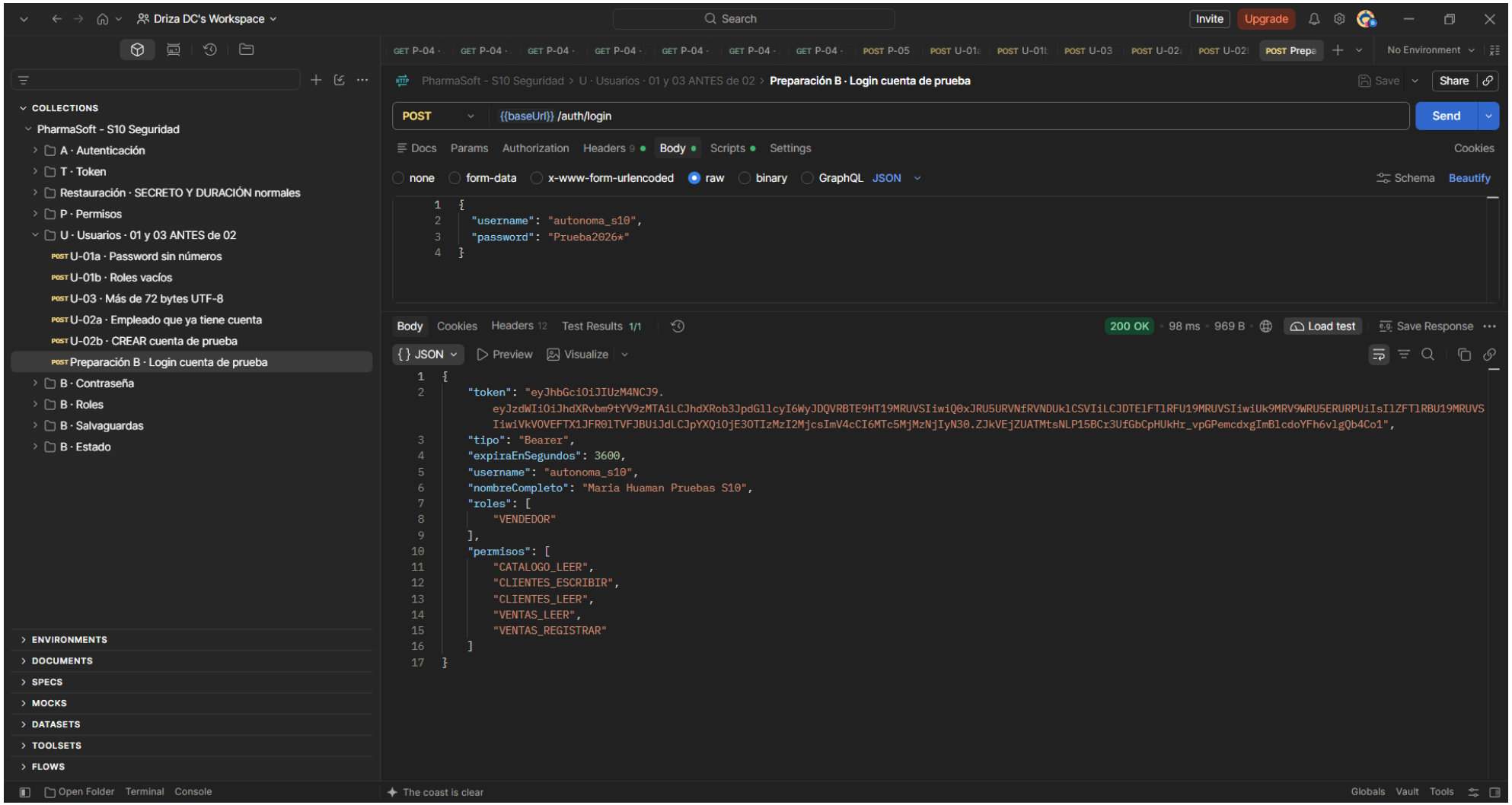
200; el login normaliza los espacios del username.



Autenticación y perfil

E047 · AUX · Login de la cuenta de prueba

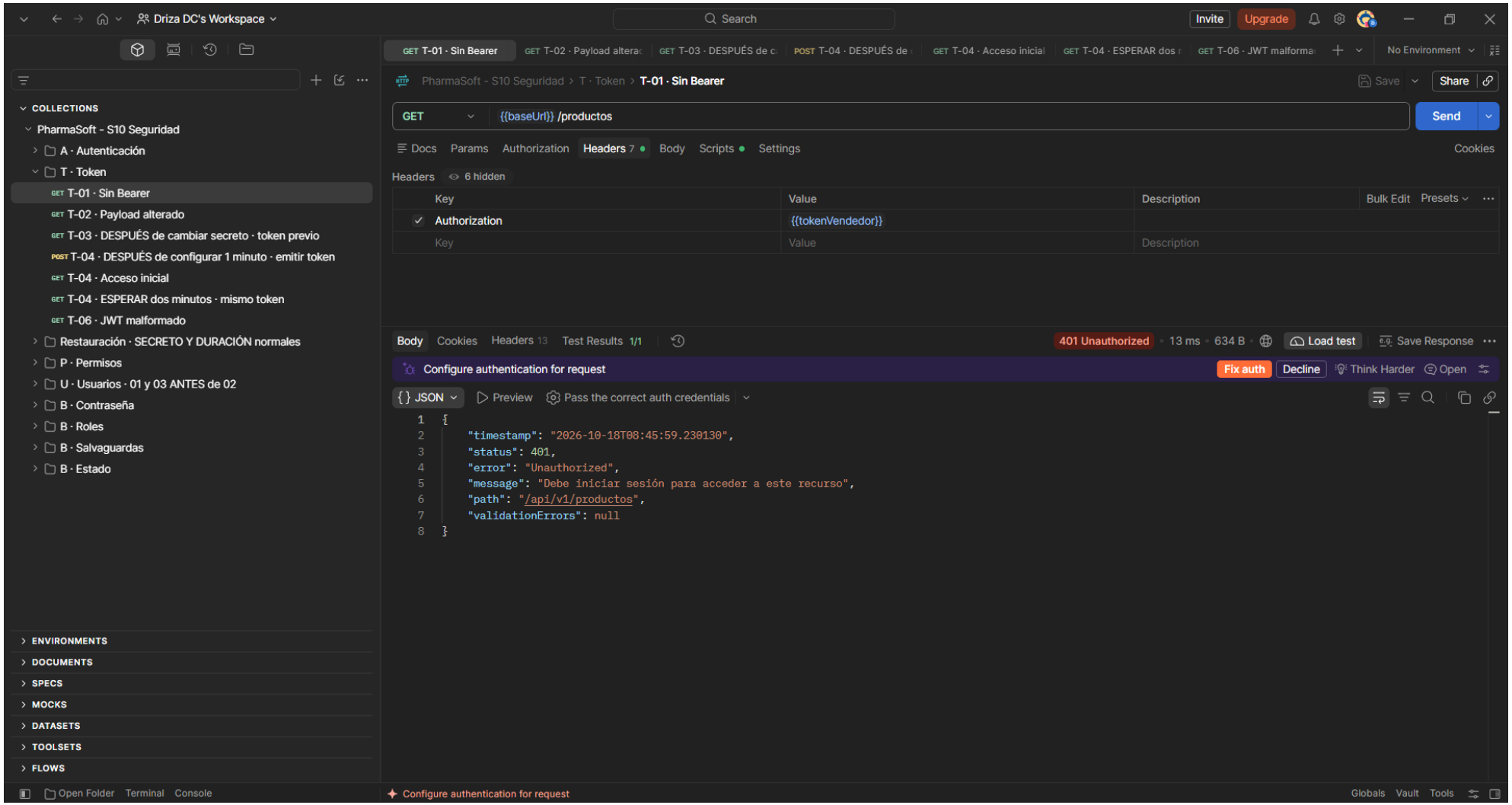
200; token de autonoma_s10 para las operaciones de la parte B.



Integridad, firma y expiración del JWT

E009 · T-01 · Token sin prefijo Bearer

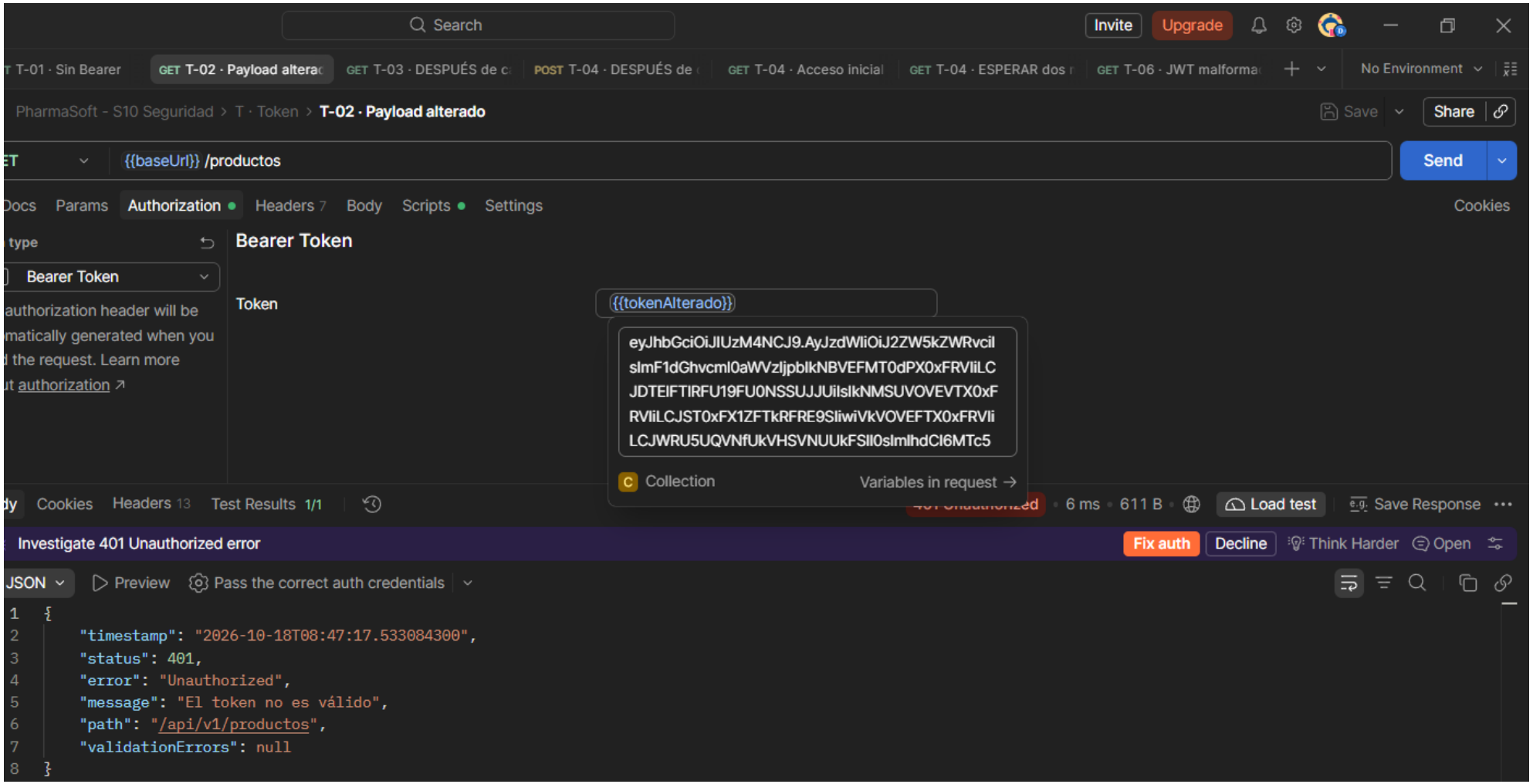
401; Debe iniciar sesión para acceder a este recurso.



Integridad, firma y expiración del JWT

E010 · T-02 · Payload alterado

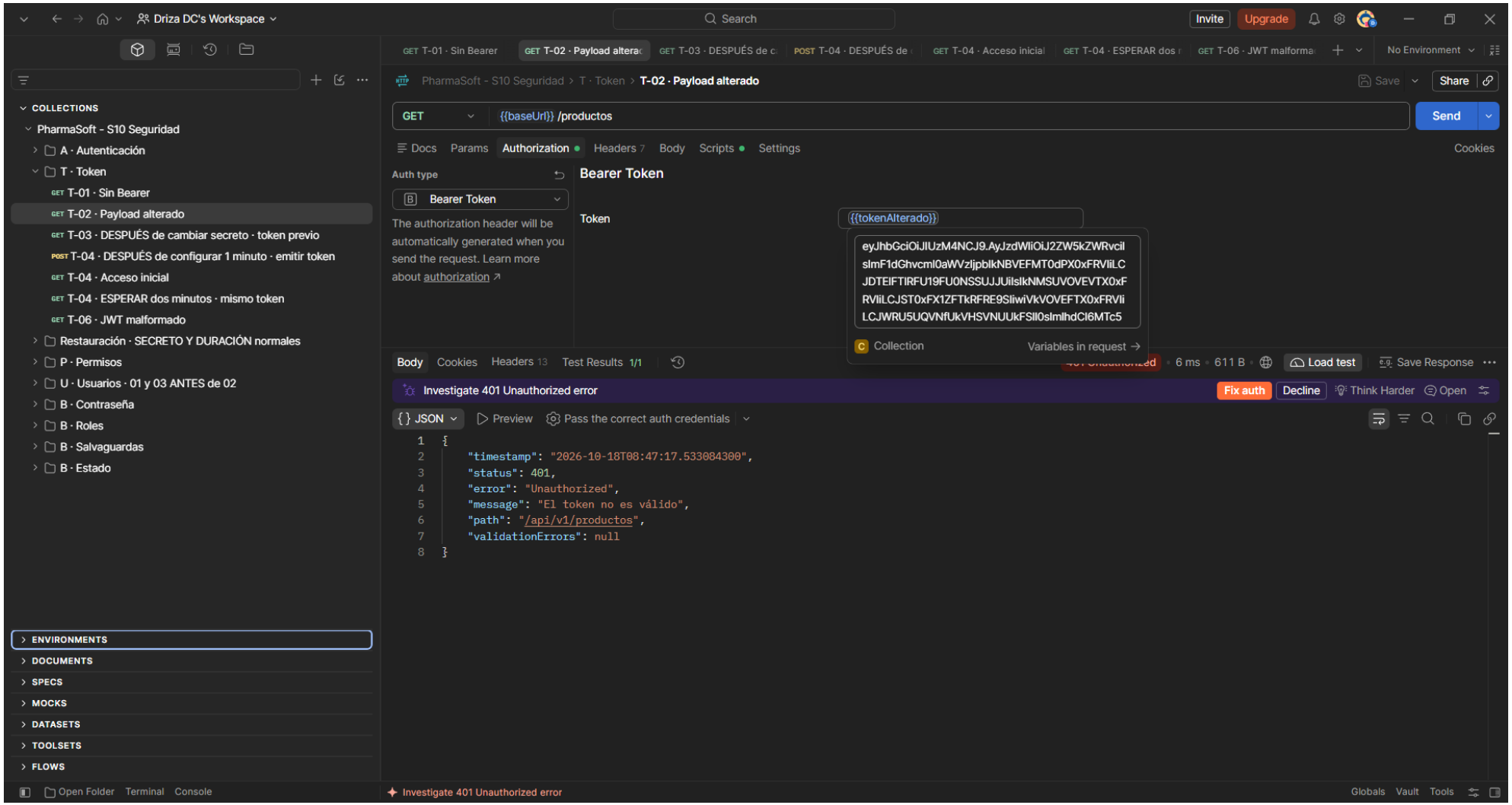
401; El token no es válido.



Integridad, firma y expiración del JWT

E011 · T-02 · Payload alterado: repetición

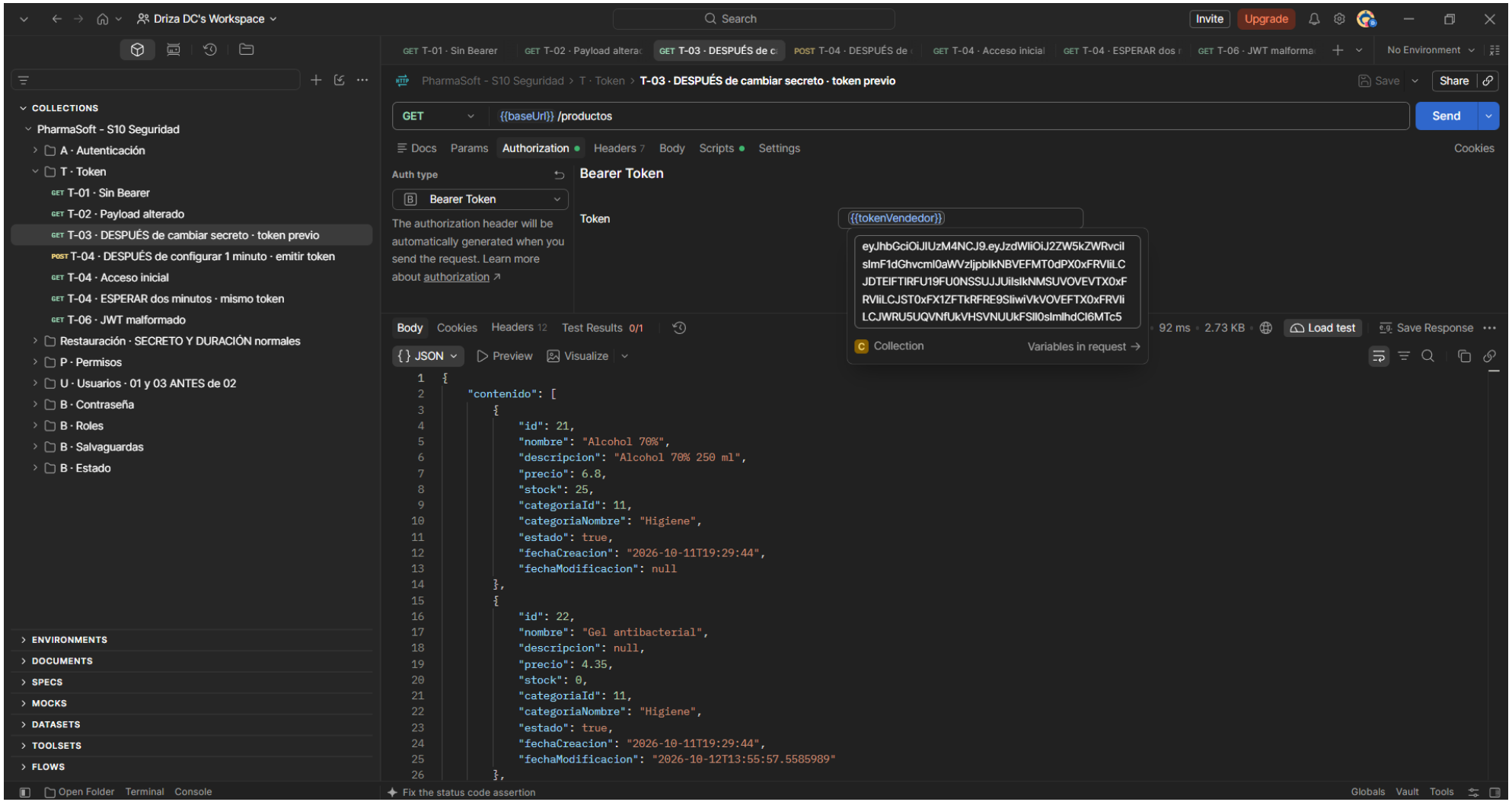
Se confirma el mismo rechazo 401 con el token alterado.



Integridad, firma y expiración del JWT

E012 · T-03 · Acceso con el secreto original

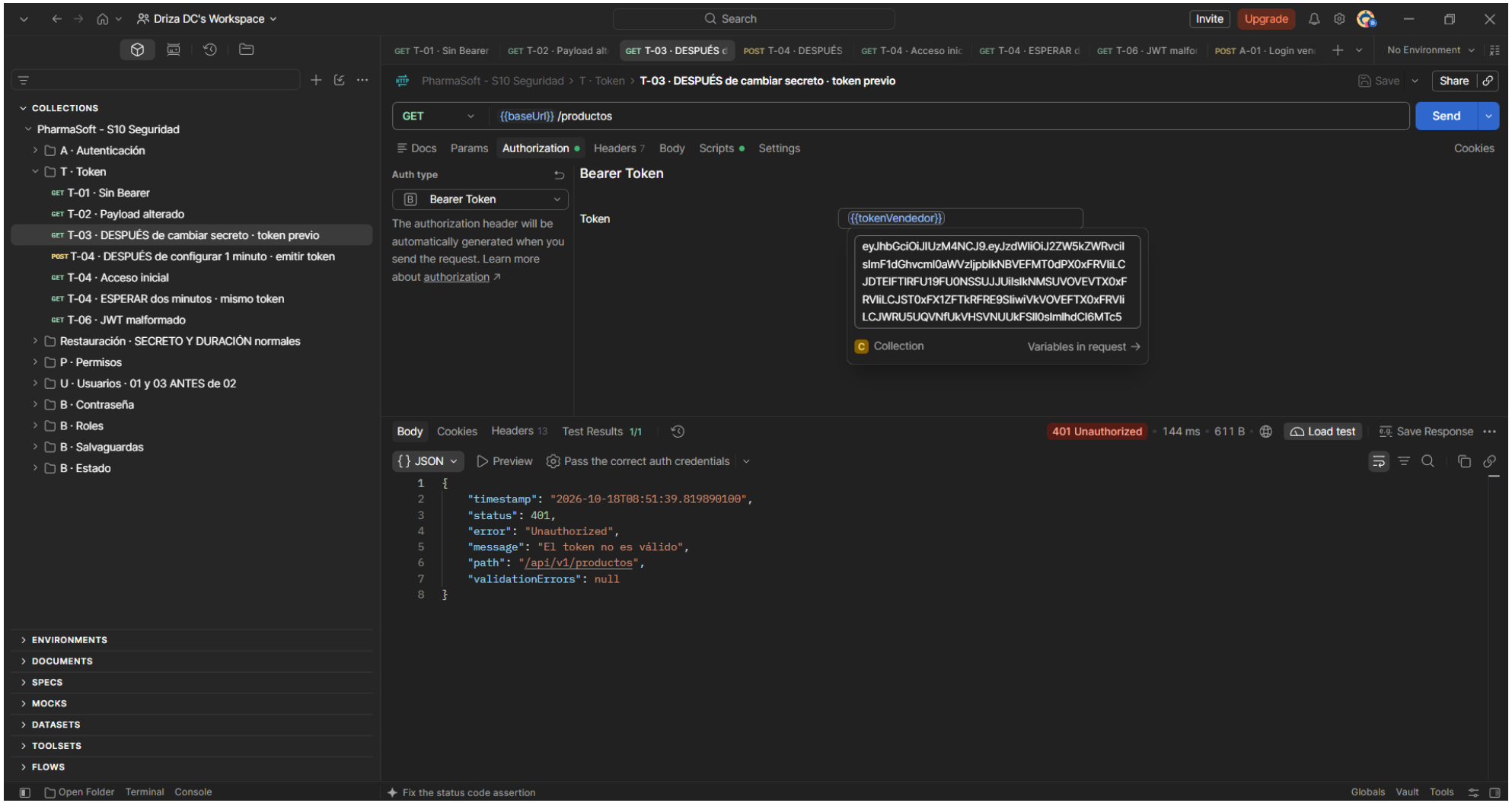
200 antes de cambiar la clave de firma.



Integridad, firma y expiración del JWT

E013 · T-03 · Token anterior con otro secreto

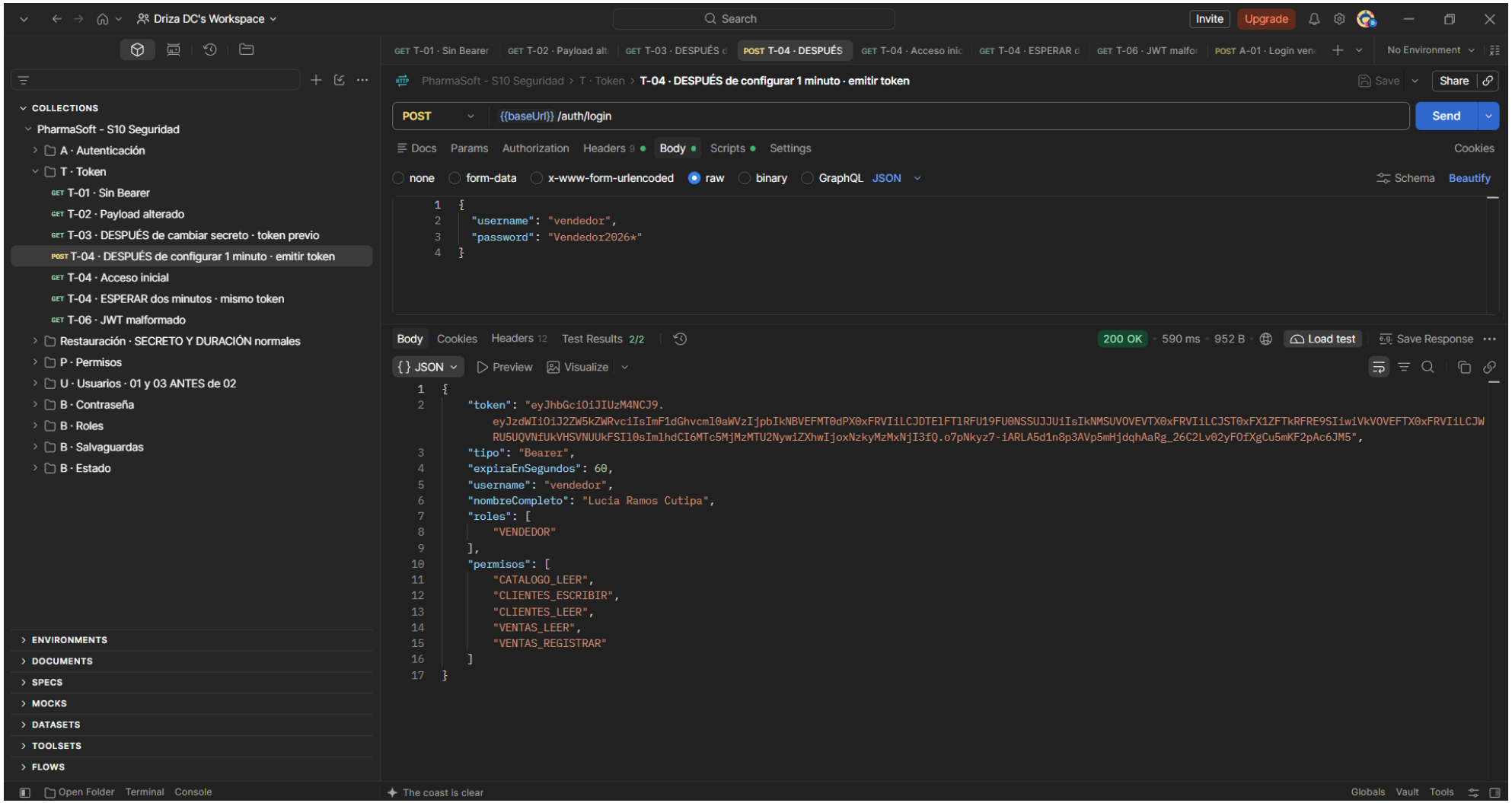
401; El token no es válido después del cambio de secreto.



Integridad, firma y expiración del JWT

E014 · T-04 · Emisión de token corto

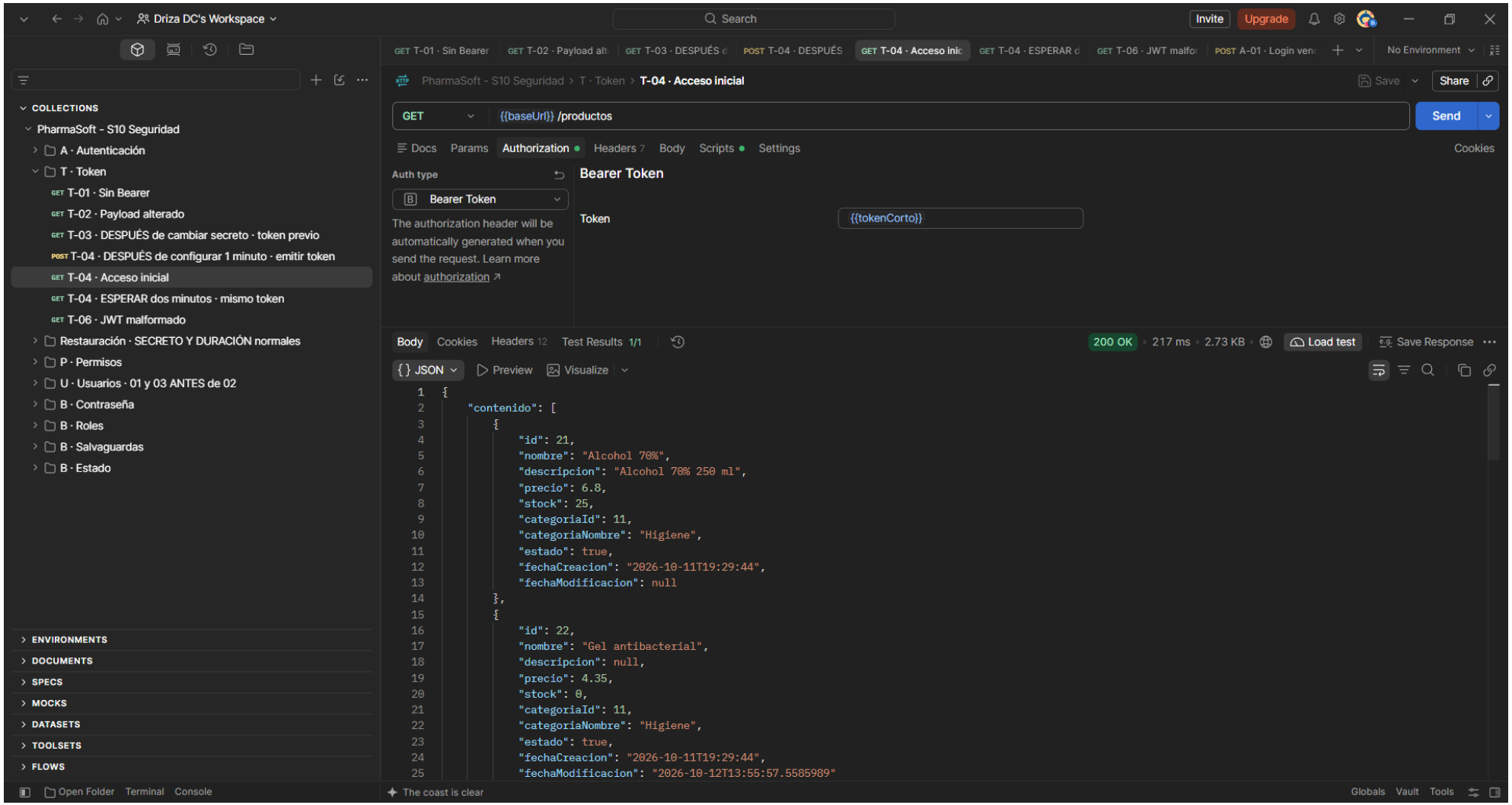
200; expiraEnSegundos igual a 60.



Integridad, firma y expiración del JWT

E015 · T-04 · Acceso antes del vencimiento

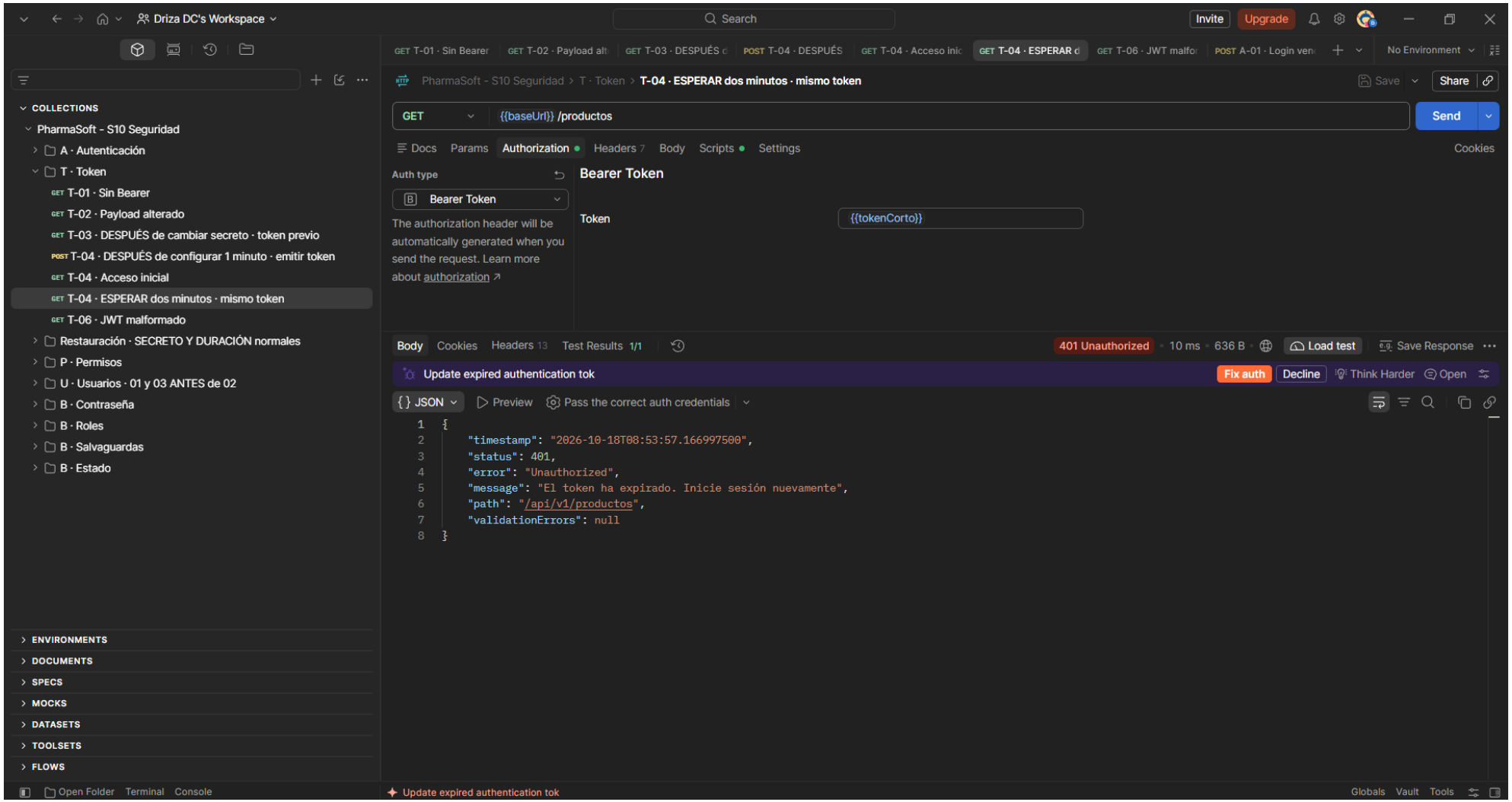
200 con el token de un minuto todavía vigente.



Integridad, firma y expiración del JWT

E016 · T-04 · Acceso después del vencimiento

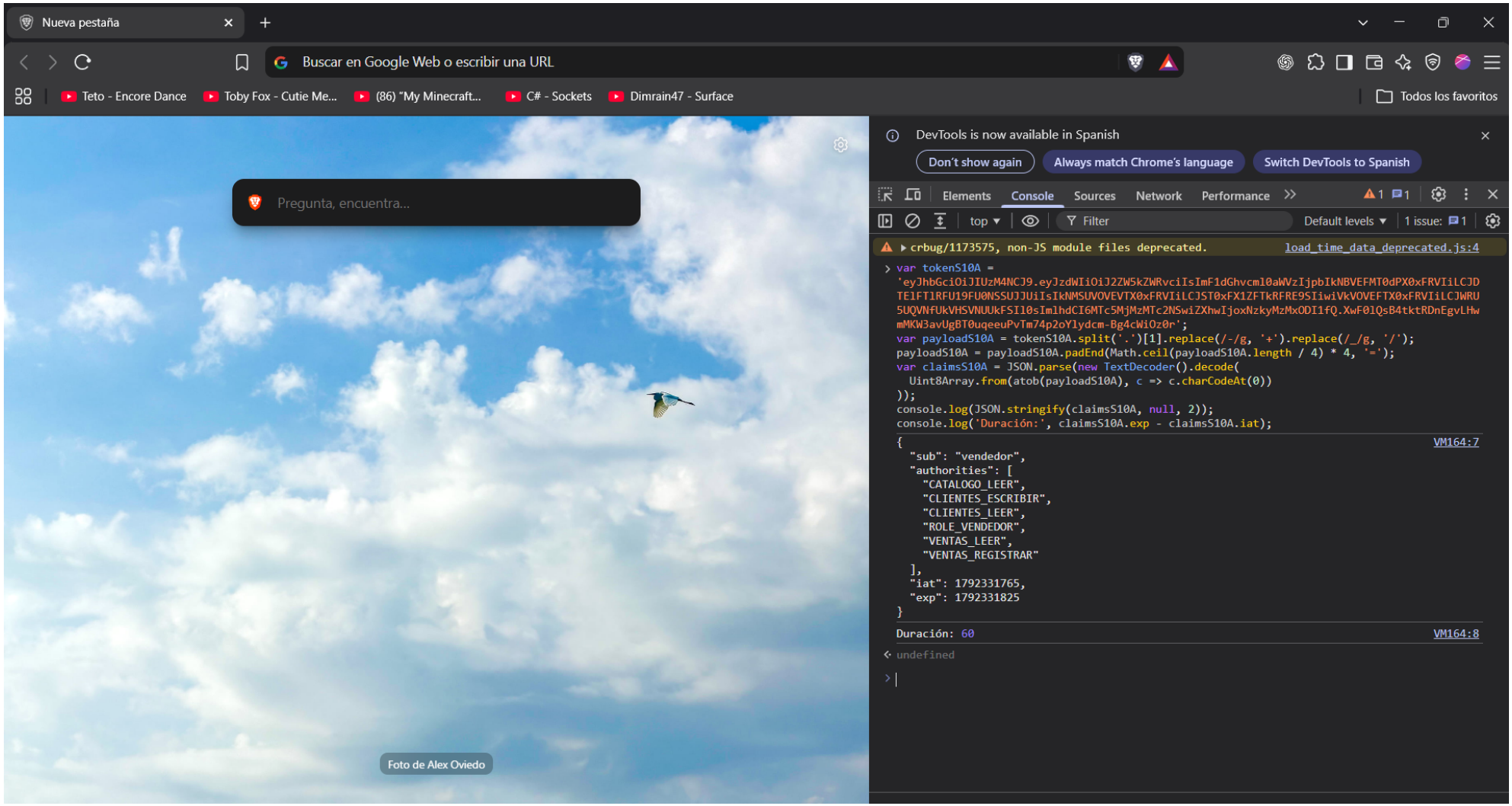
401; El token ha expirado. Inicie sesión nuevamente.



Integridad, firma y expiración del JWT

E017 · T-05 · Claims del JWT decodificados localmente

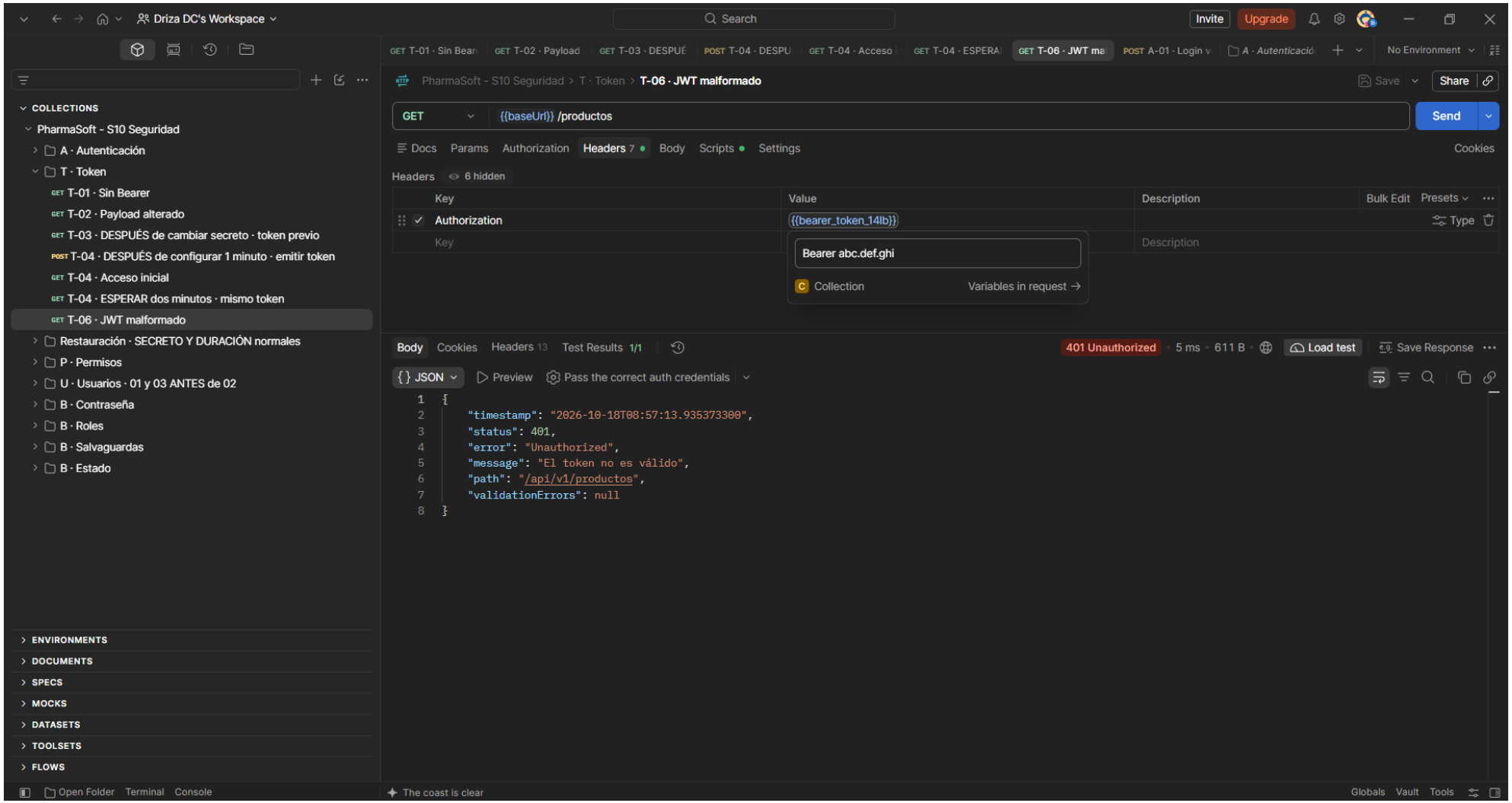
sub vendedor, authorities, iat y exp; en esta emisión corta, exp - iat = 60 segundos.



Integridad, firma y expiración del JWT

E018 · T-06 · JWT malformado

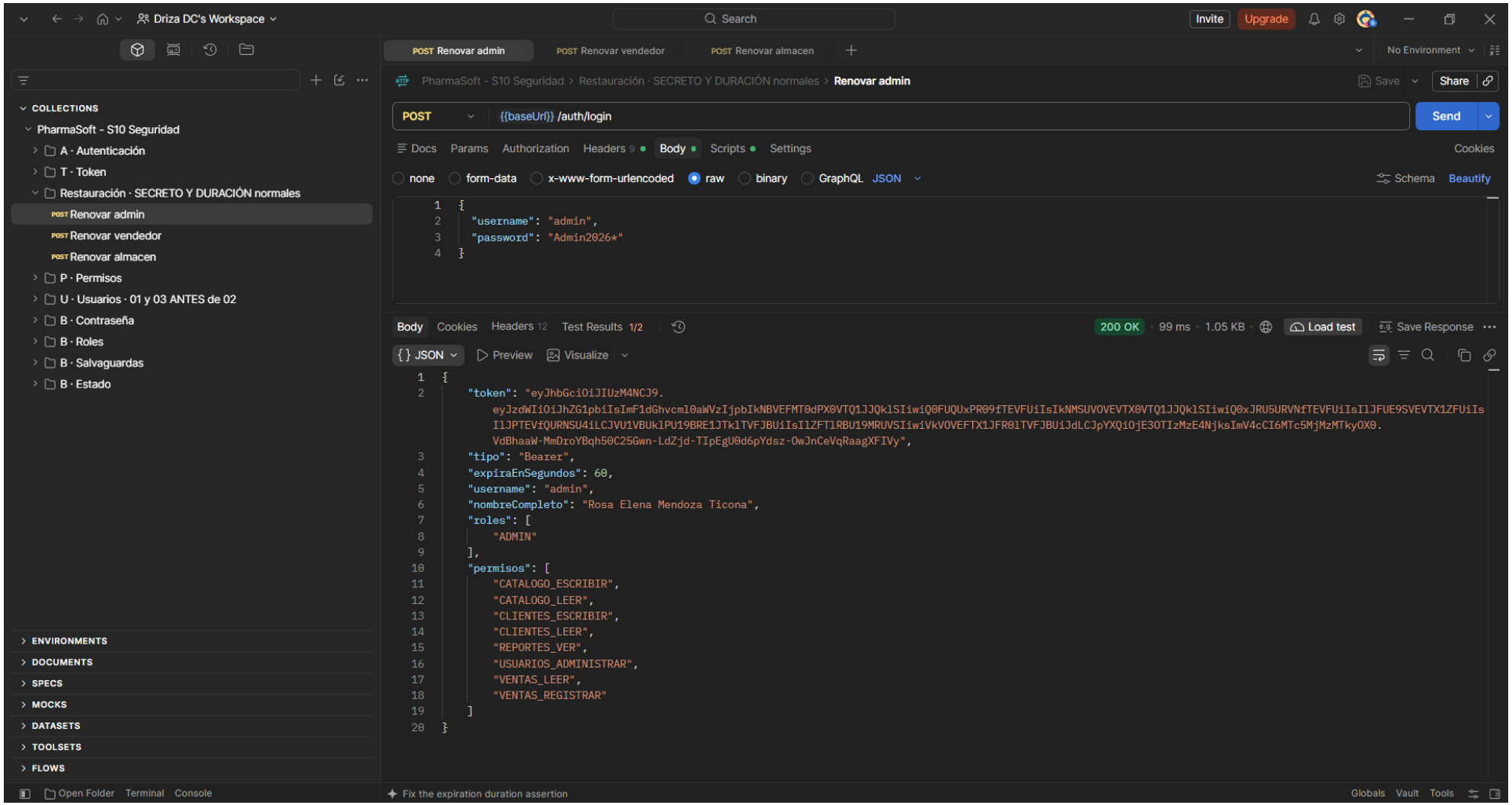
401; El token no es válido con abc.def.ghi.



Restauración de condiciones de prueba

E019 · REST · Renovación de administrador

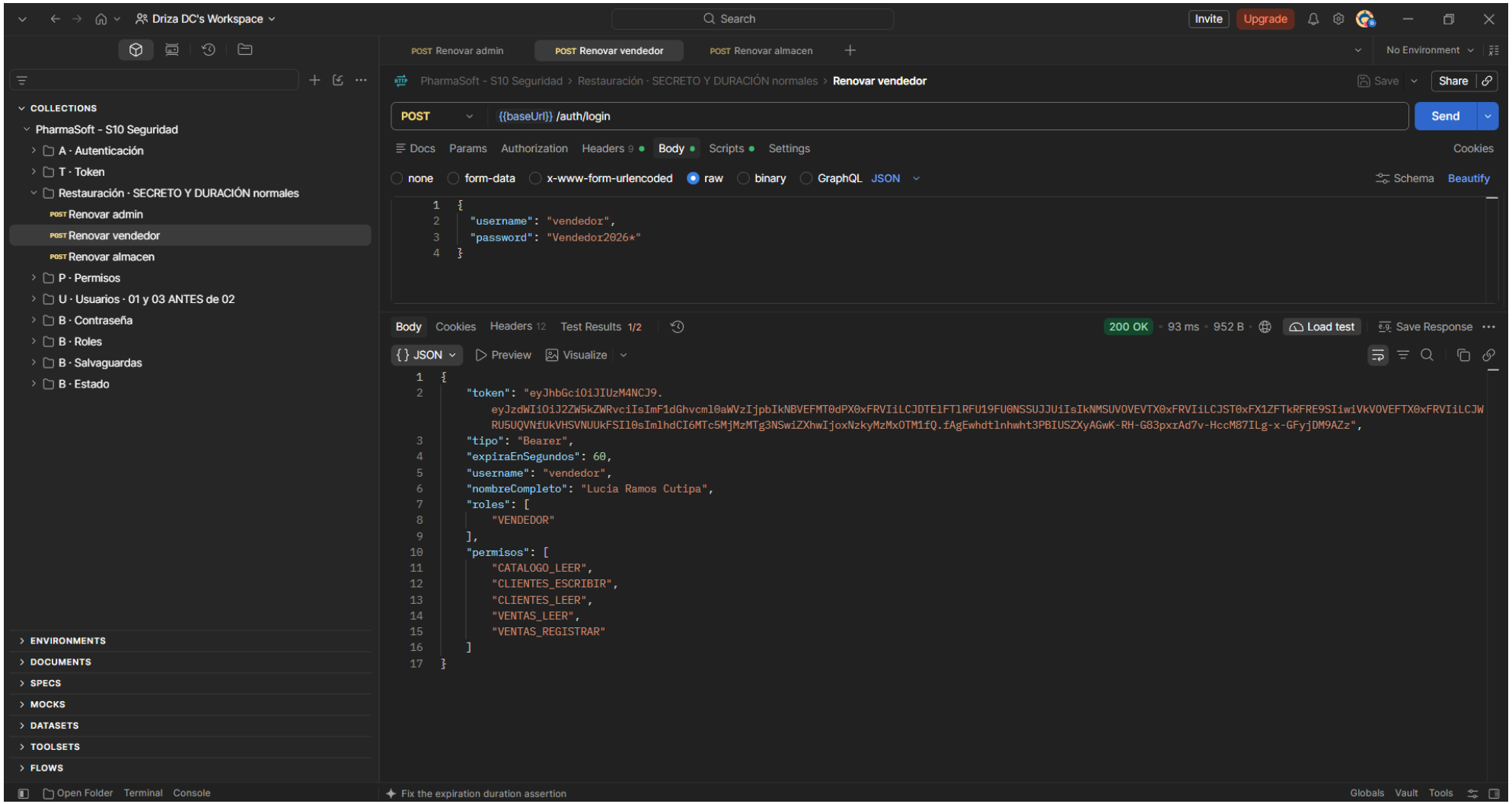
200; autenticación después de restaurar la configuración normal.



Restauración de condiciones de prueba

E020 · REST · Renovación de vendedor

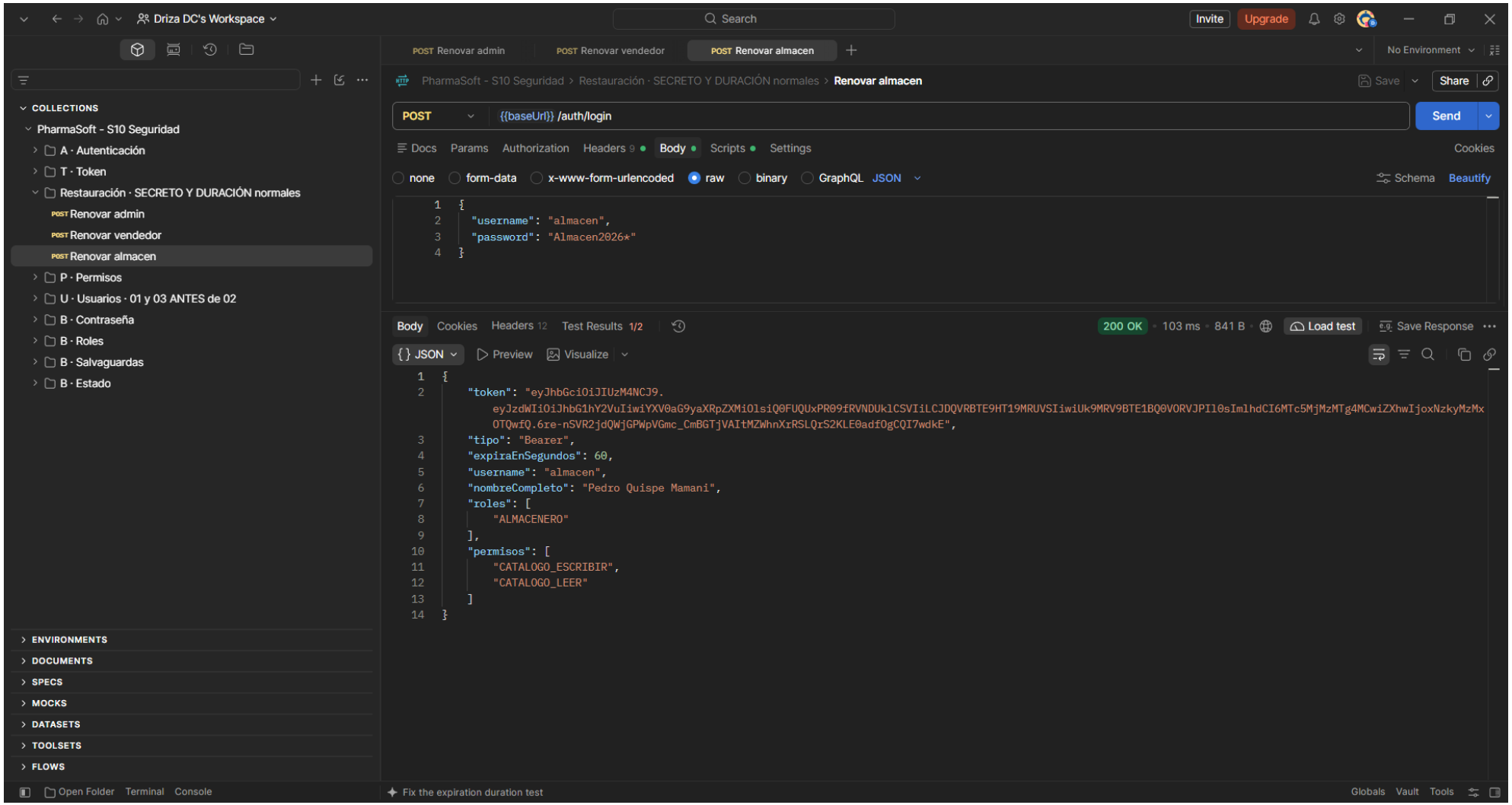
200; nueva credencial para los casos posteriores.



Restauración de condiciones de prueba

E021 · REST · Renovación de almacén

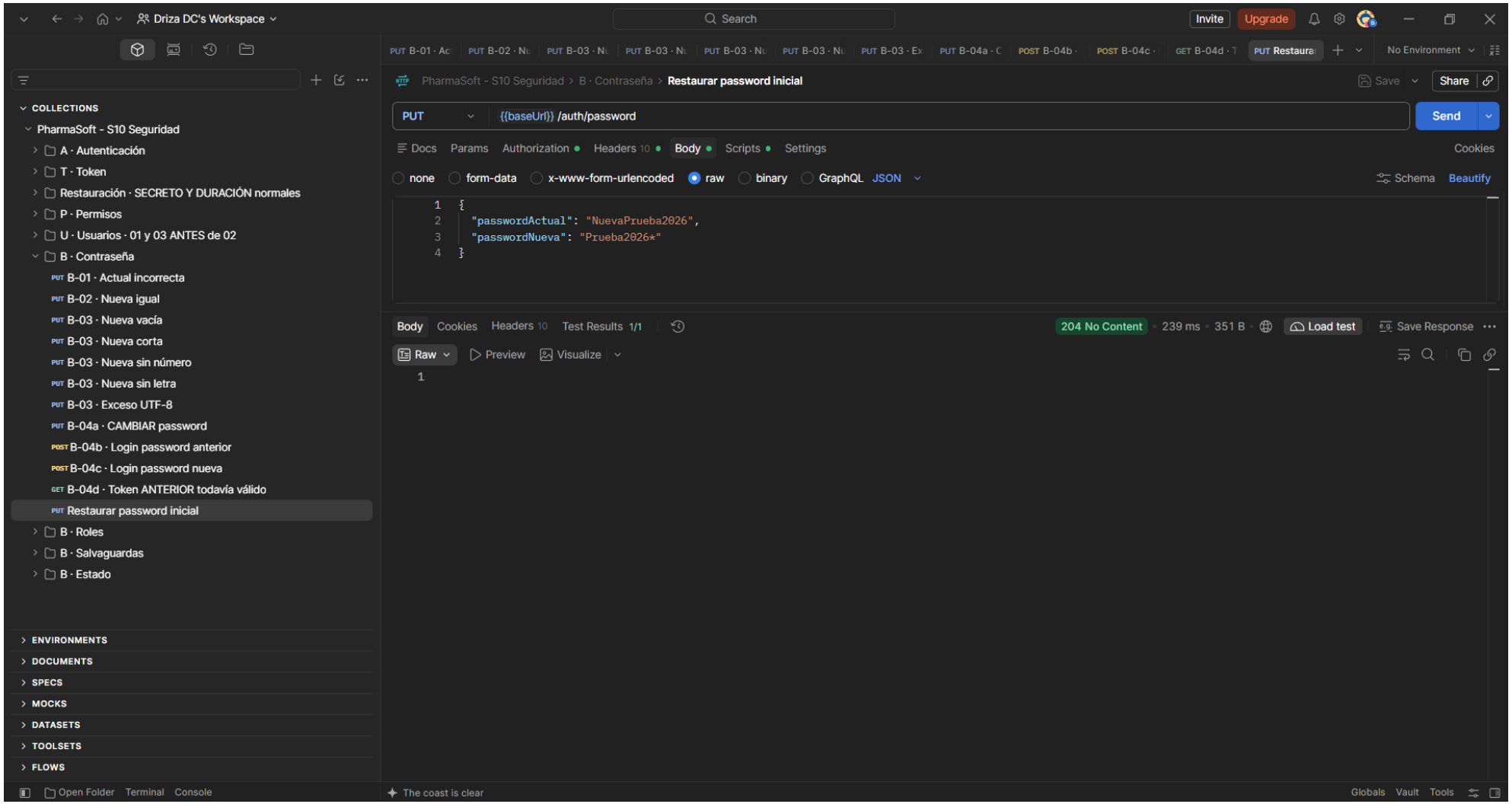
200; ALMACENERO y permisos del catálogo.



Restauración de condiciones de prueba

E059 · REST · Restauración de contraseña

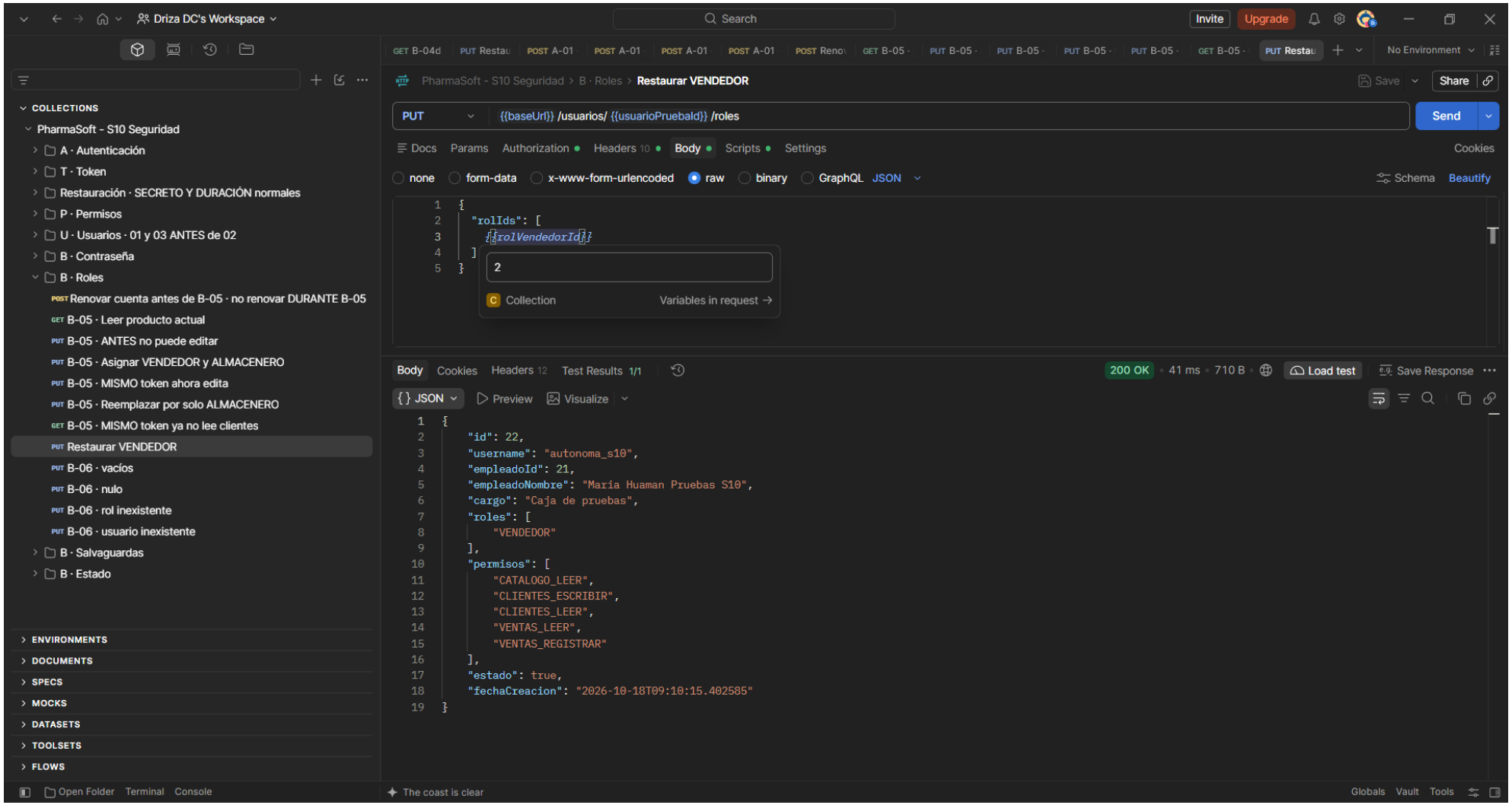
204; se restablece la contraseña inicial de la cuenta de prueba.



Restauración de condiciones de prueba

E066 · REST · Restauración de VENDEDOR

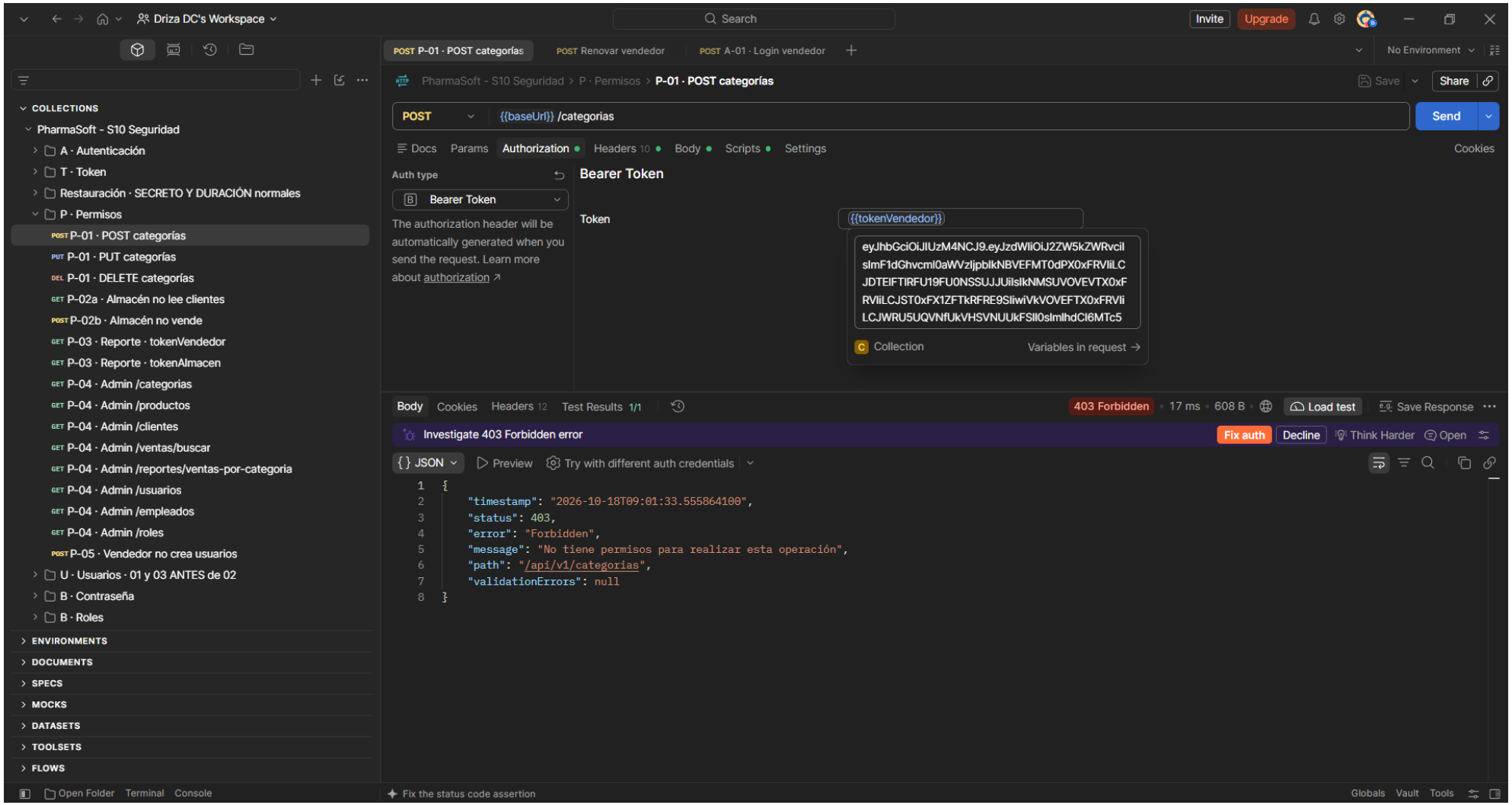
200; se restablece el rol inicial de la cuenta de prueba.



Permisos por rol

E022 · P-01 · POST categorías como vendedor

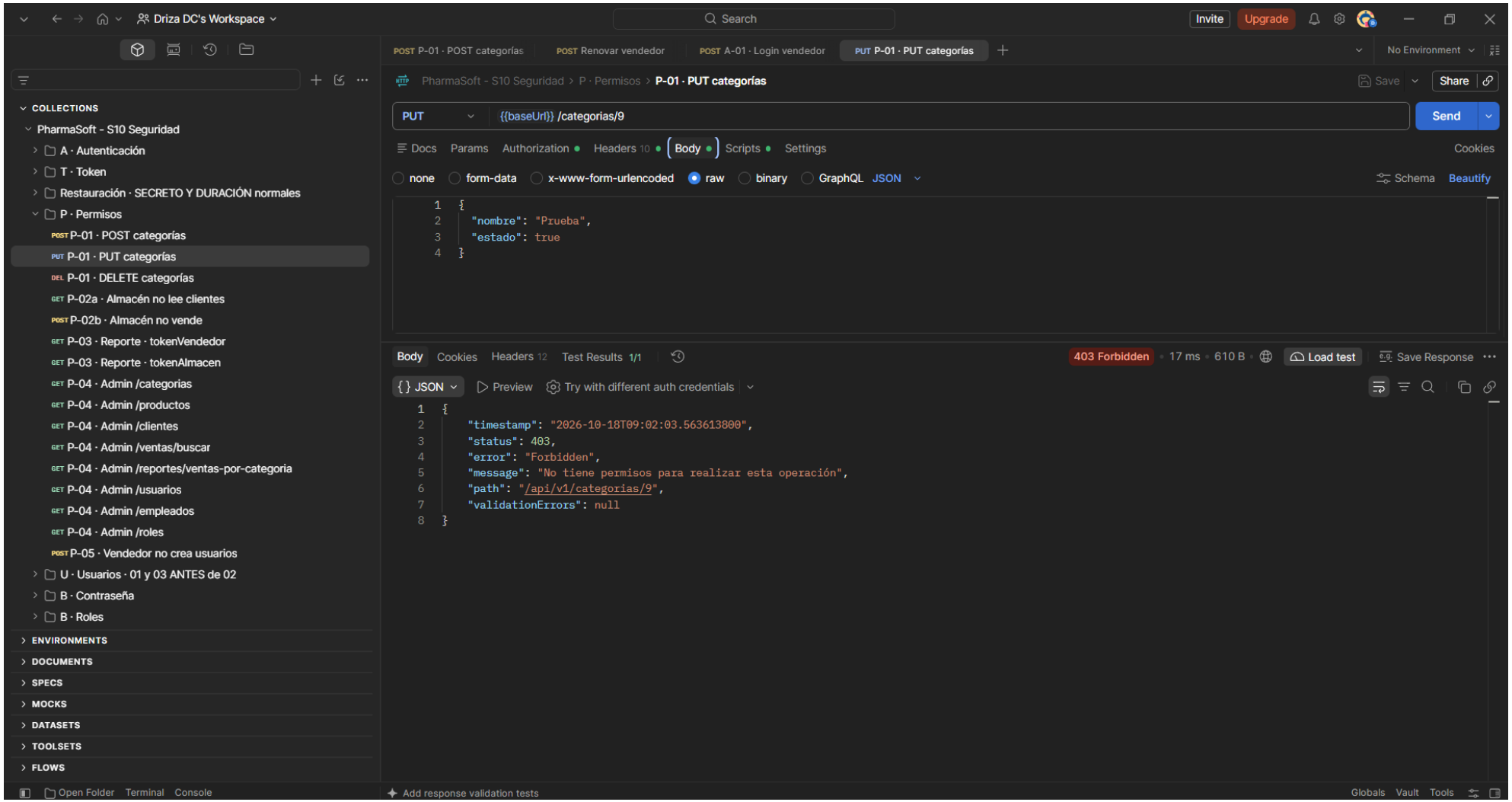
403; No tiene permisos para realizar esta operación.



Permisos por rol

E023 · P-01 · PUT categorías como vendedor

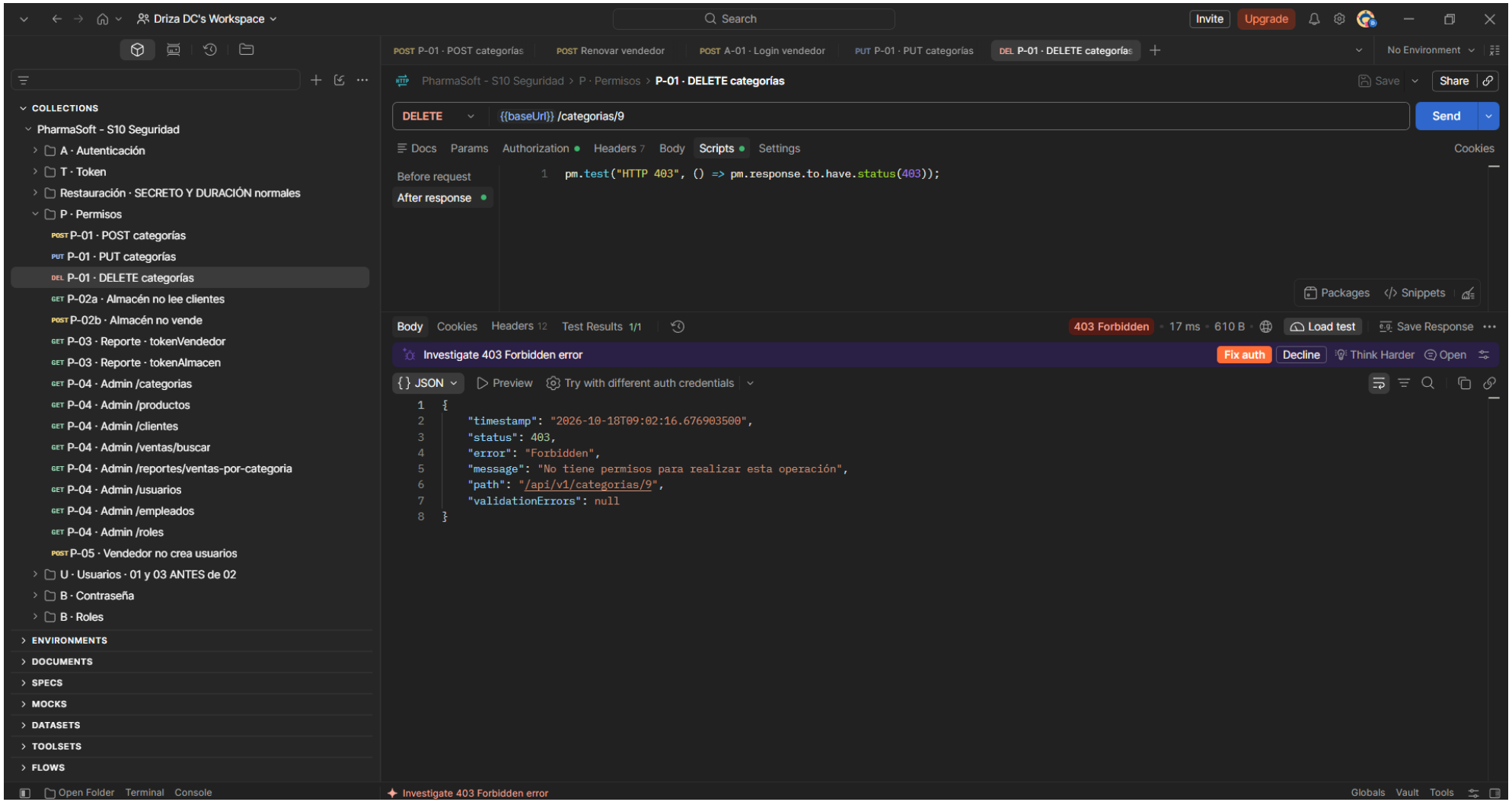
403; actualización rechazada por falta de permiso.



Permisos por rol

E024 · P-01 · DELETE categorías como vendedor

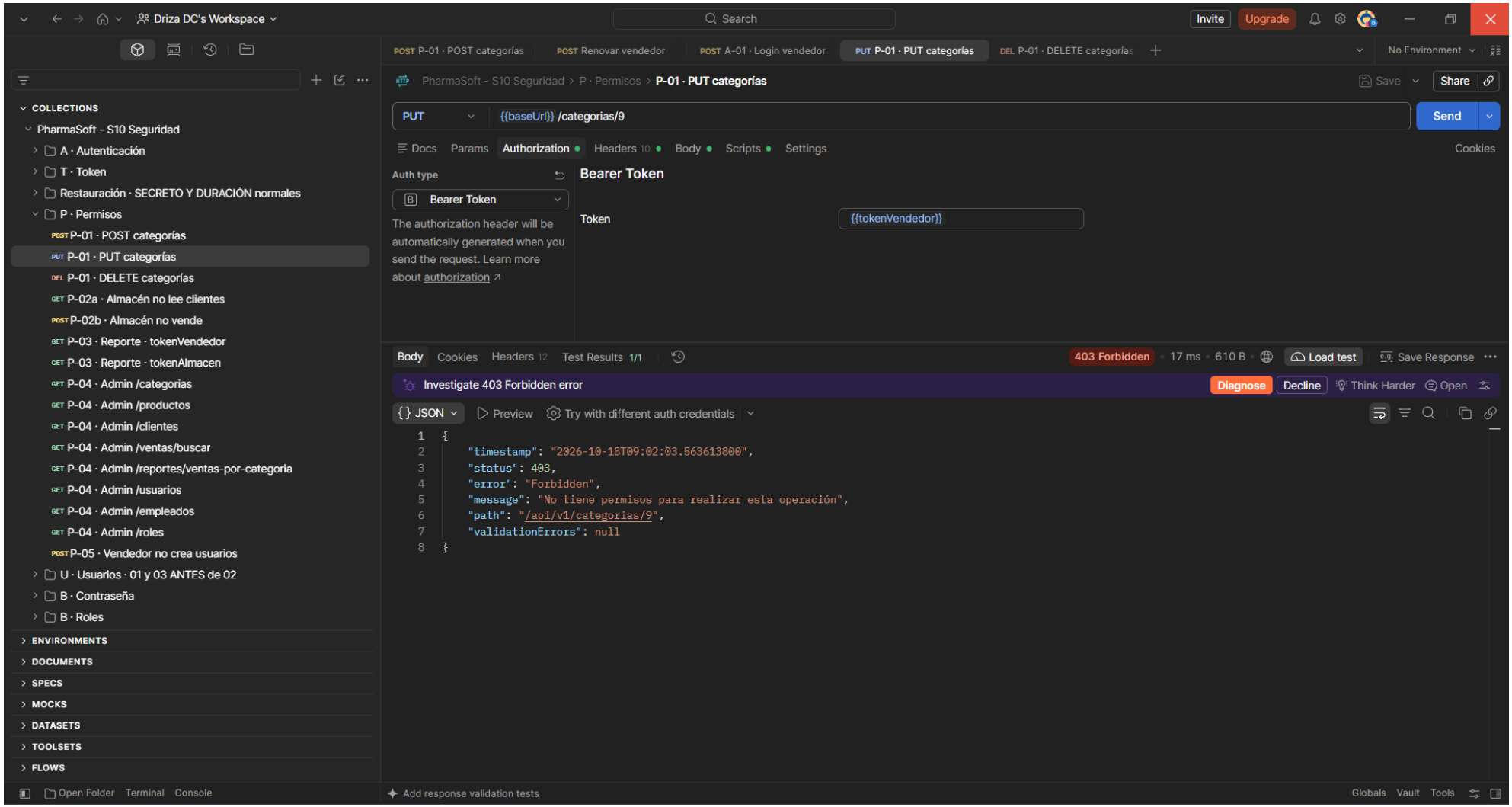
403; eliminación rechazada por falta de permiso.



Permisos por rol

E025 · P-01 · PUT categorías: comprobación adicional

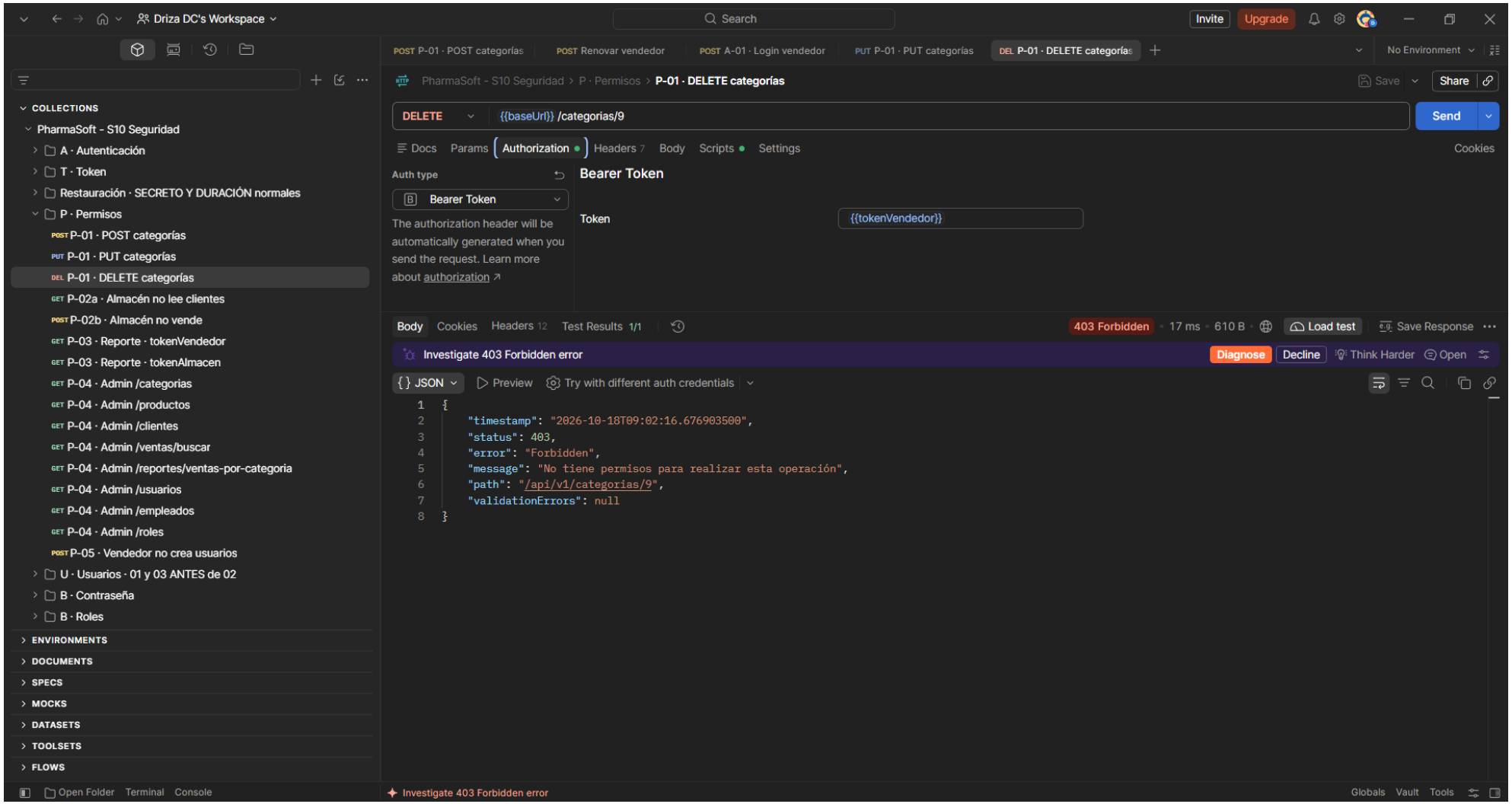
403; se mantiene el rechazo al vendedor.



Permisos por rol

E026 · P-01 · DELETE categorías: comprobación adicional

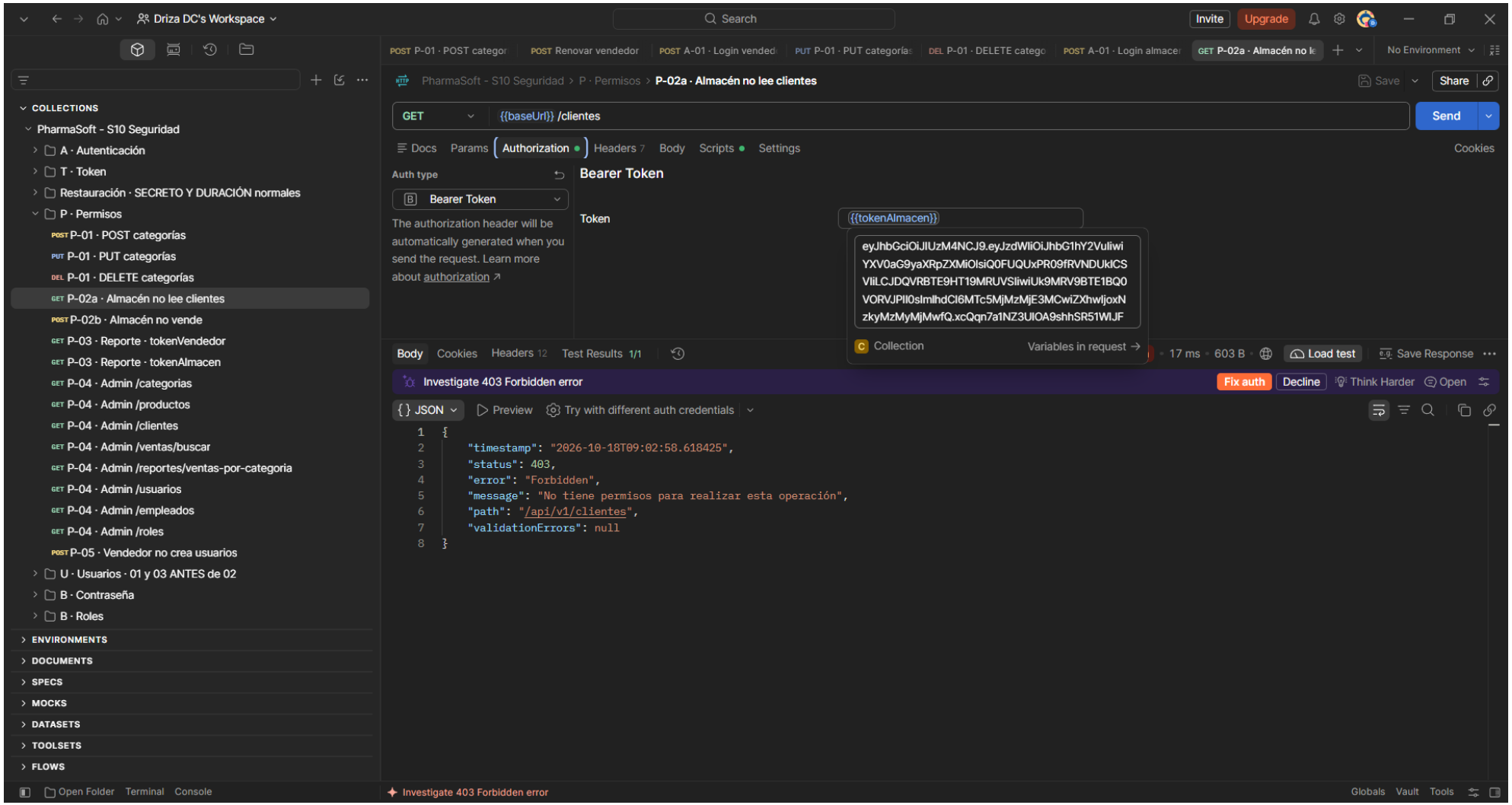
403; se confirma la protección de la operación.



Permisos por rol

E027 · P-02 · Lectura de clientes desde almacén

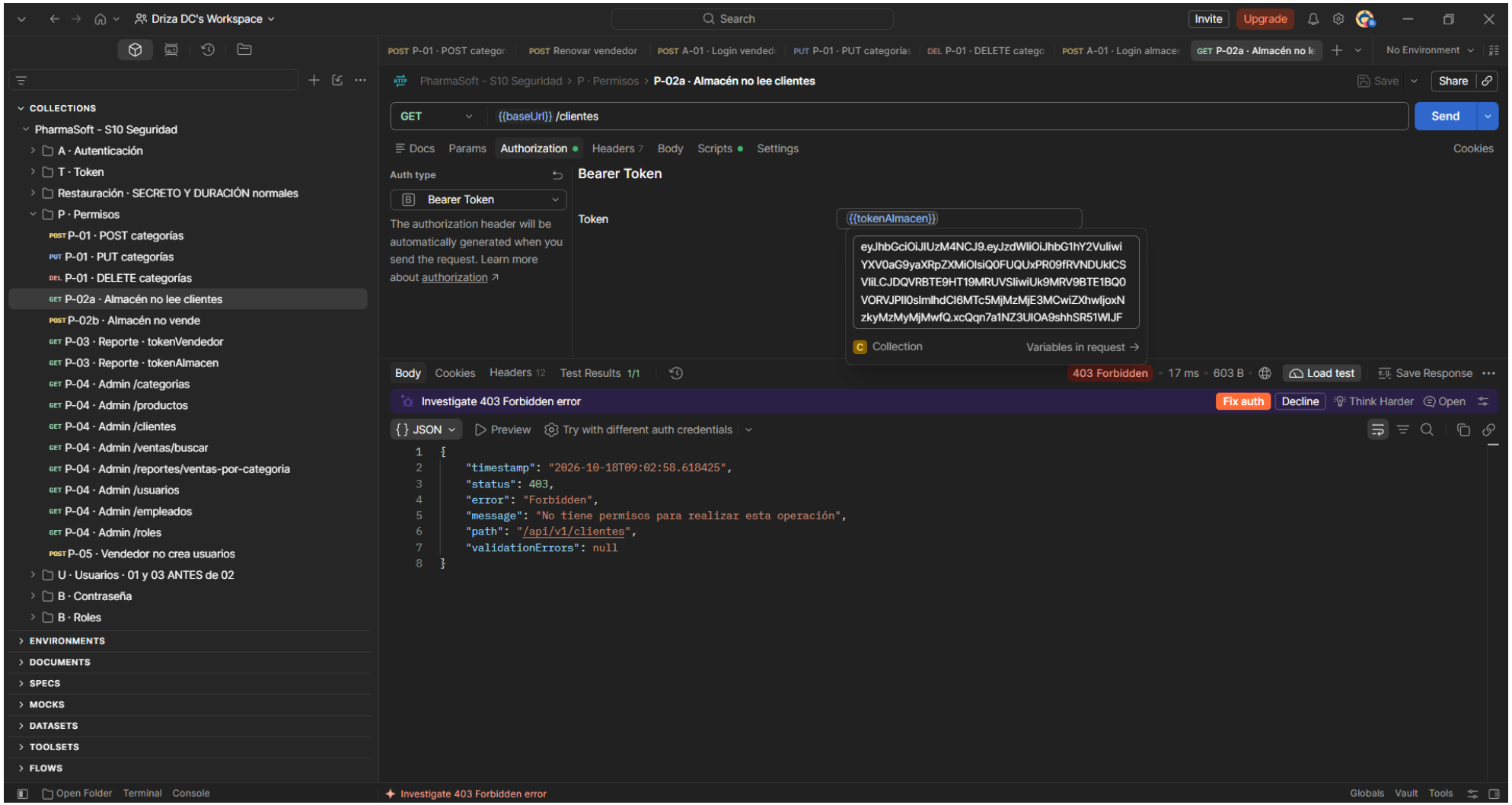
403; ALMACENERO no tiene CLIENTES_LEER.



Permisos por rol

E028 · P-02 · Clientes desde almacén: repetición

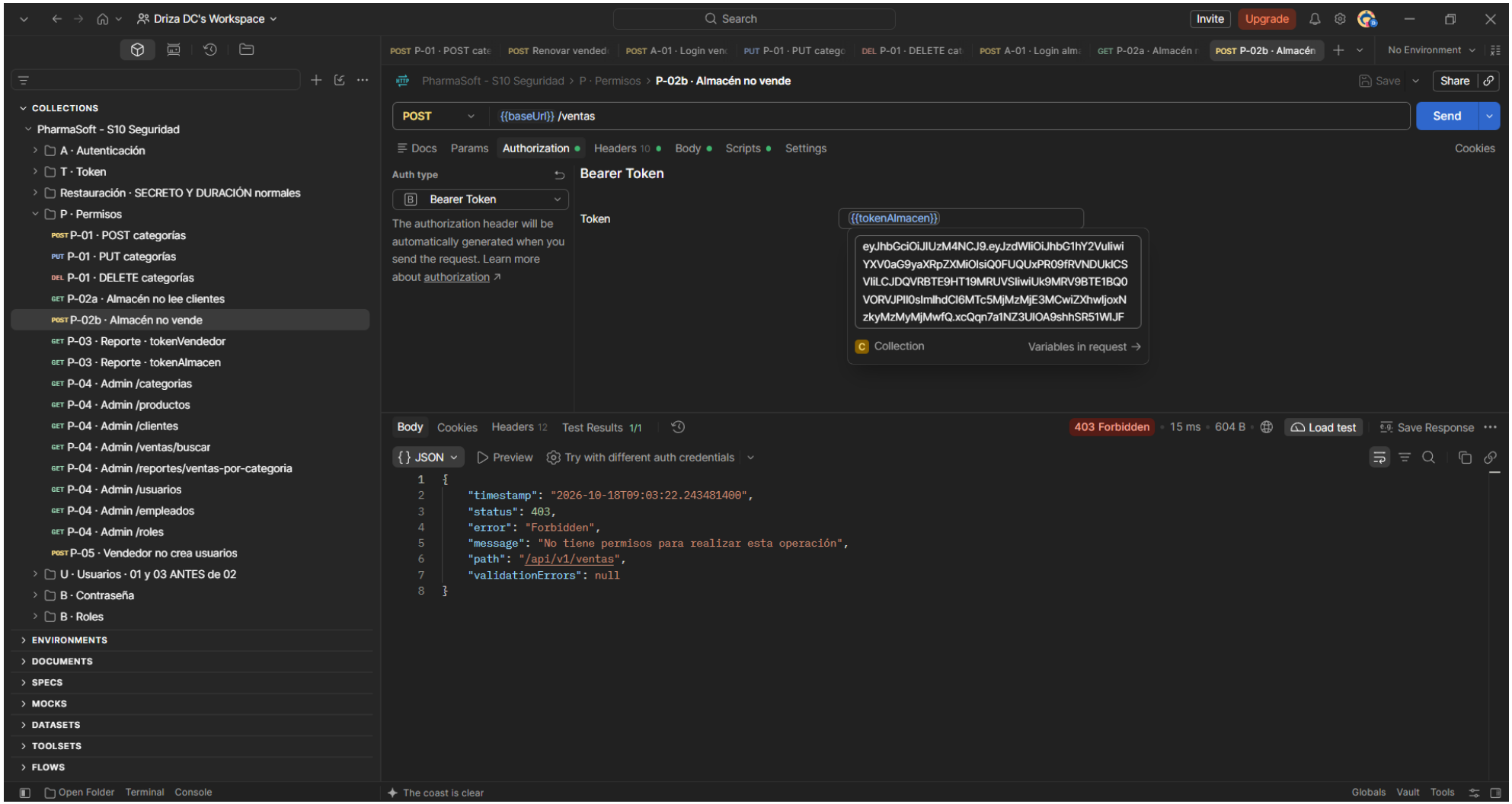
403; se confirma el límite de permisos.



Permisos por rol

E029 · P-02 · Venta desde almacén

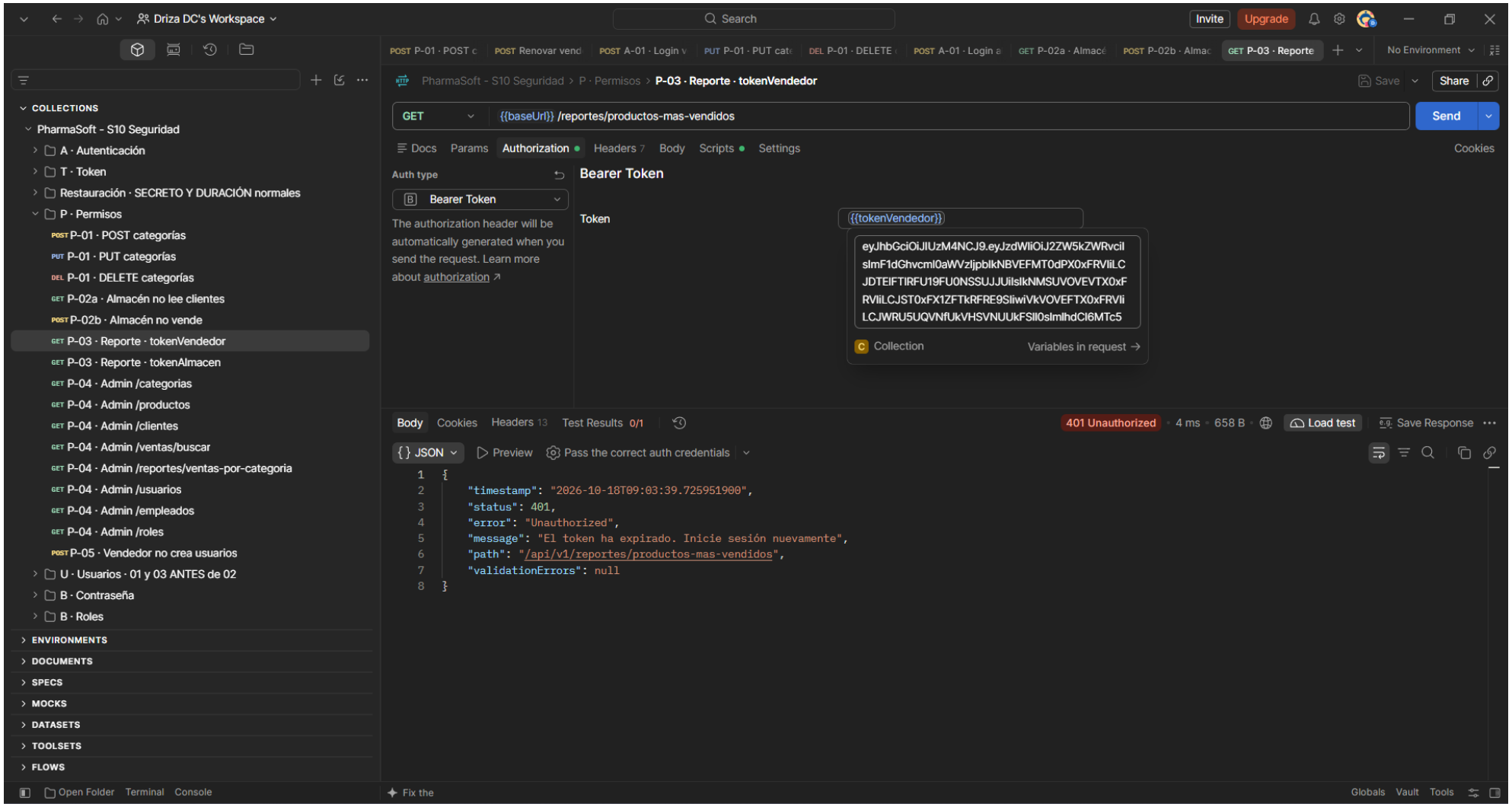
403; no se autoriza registrar ventas.



Permisos por rol

E030 · P-03 · Reporte con cuenta de almacén

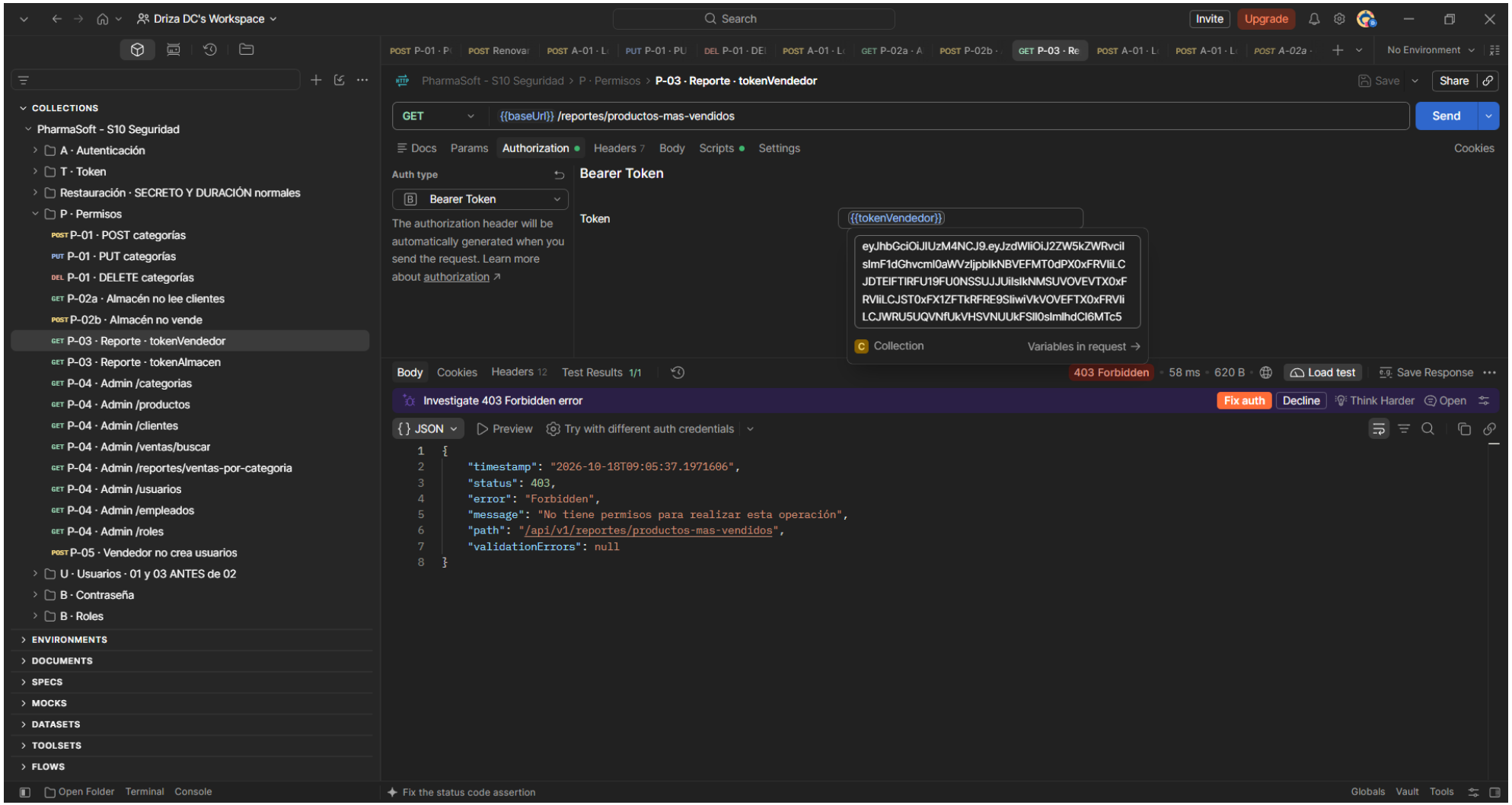
403; el reporte exige REPORTES_VER.



Permisos por rol

E031 · P-03 · Reporte con vendedor

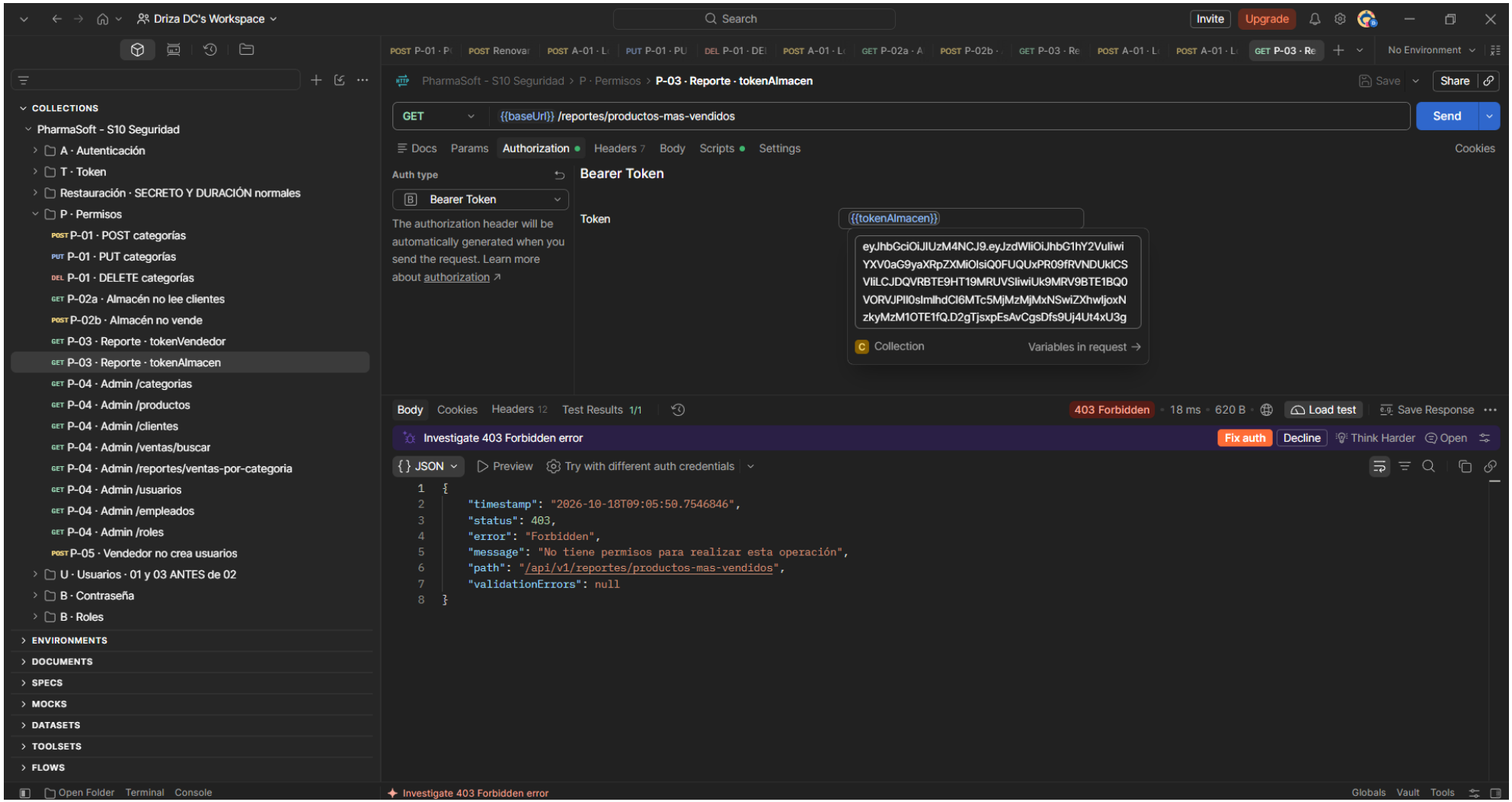
403; rechazo de autorización del reporte.



Permisos por rol

E032 · P-03 · Reporte con almacén: repetición

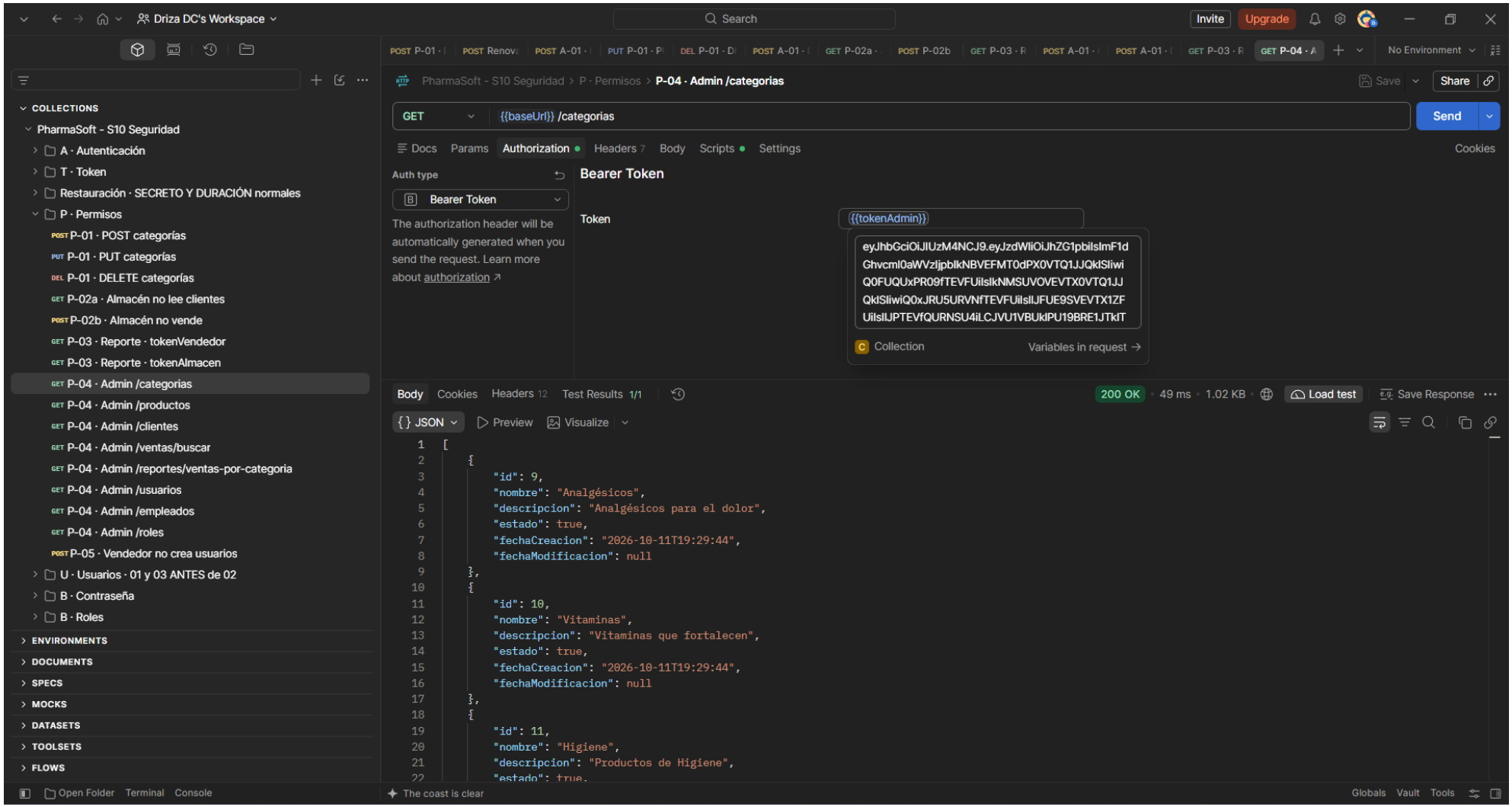
403; la cuenta autenticada carece de REPORTES_VER.



Permisos por rol

E033 · P-04 · Administrador consulta categorías

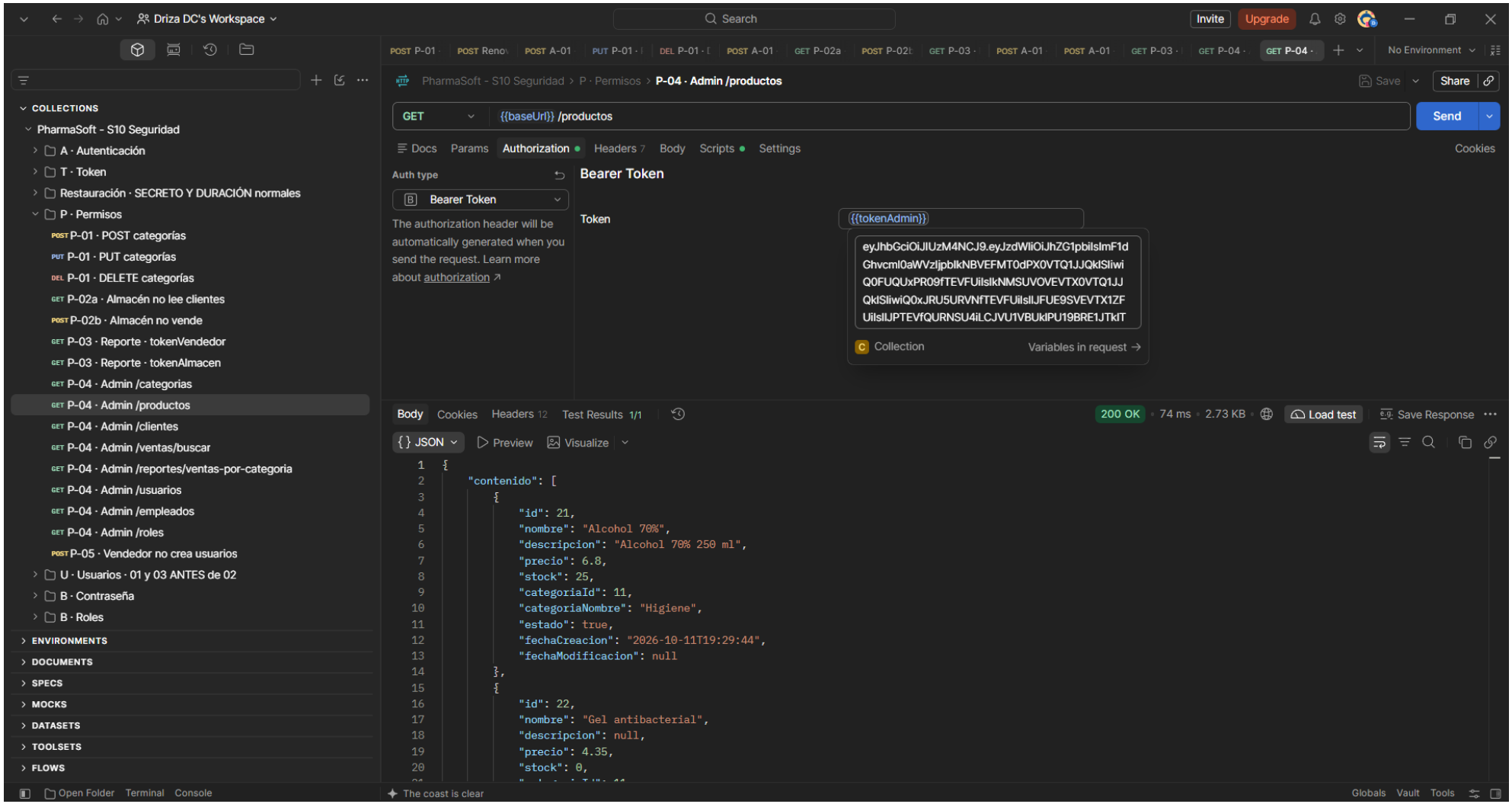
200; listado paginado del módulo.



Permisos por rol

E034 · P-04 · Administrador consulta productos

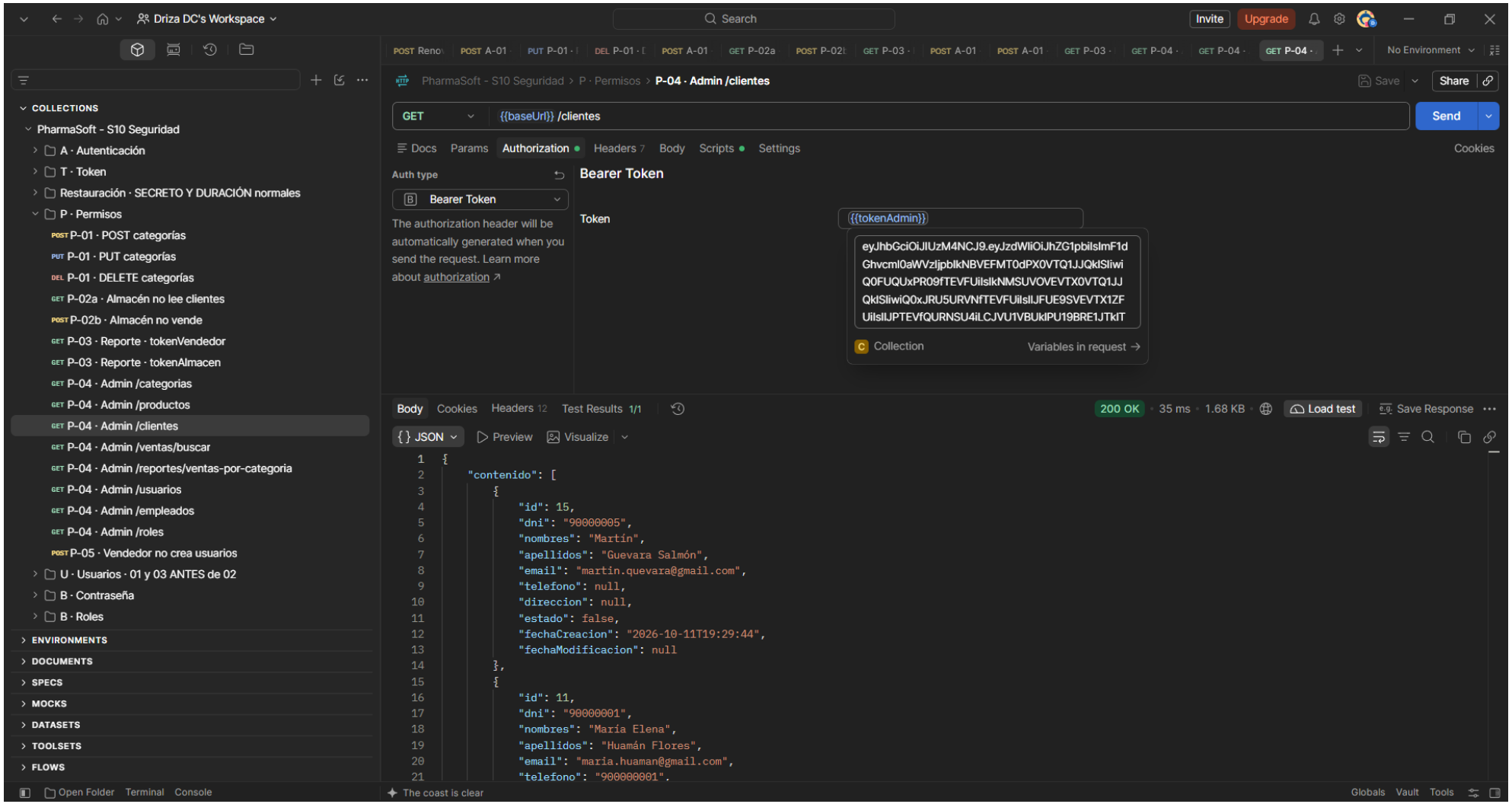
200; listado del catálogo.



Permisos por rol

E035 · P-04 · Administrador consulta clientes

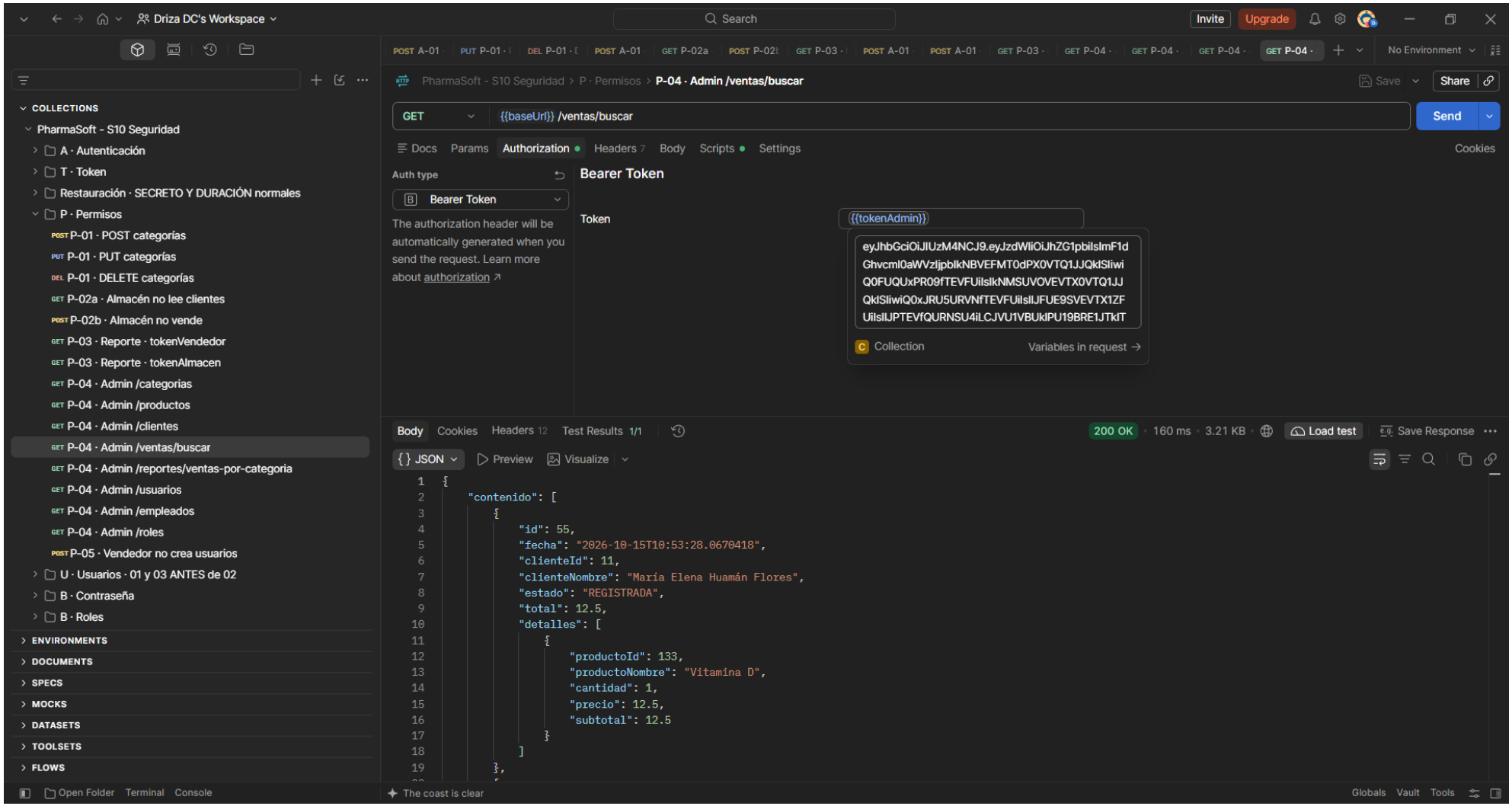
200; acceso al módulo de clientes.



Permisos por rol

E036 · P-04 · Administrador consulta ventas

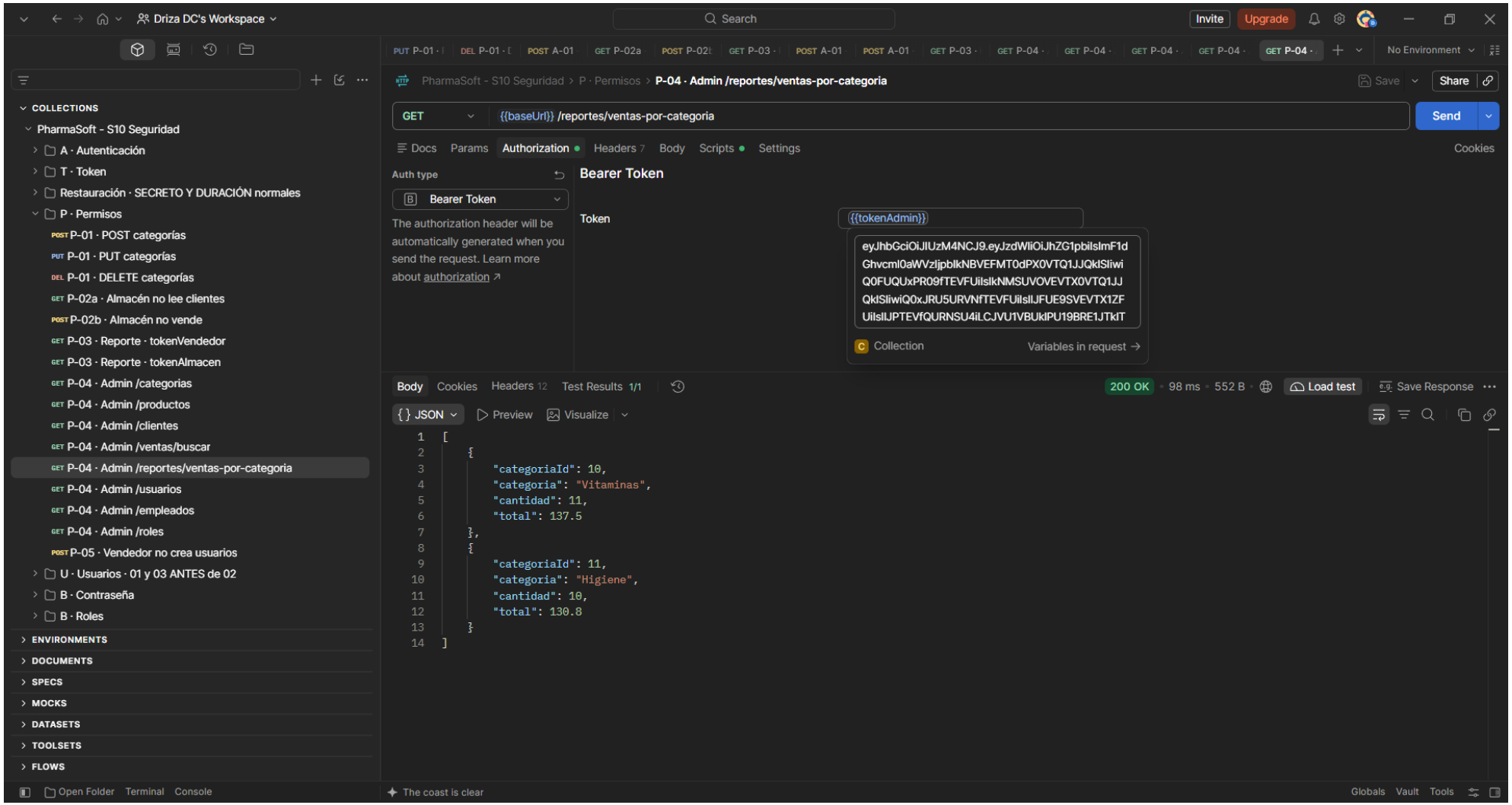
200; acceso al historial de ventas.



Permisos por rol

E037 · P-04 · Administrador consulta reportes

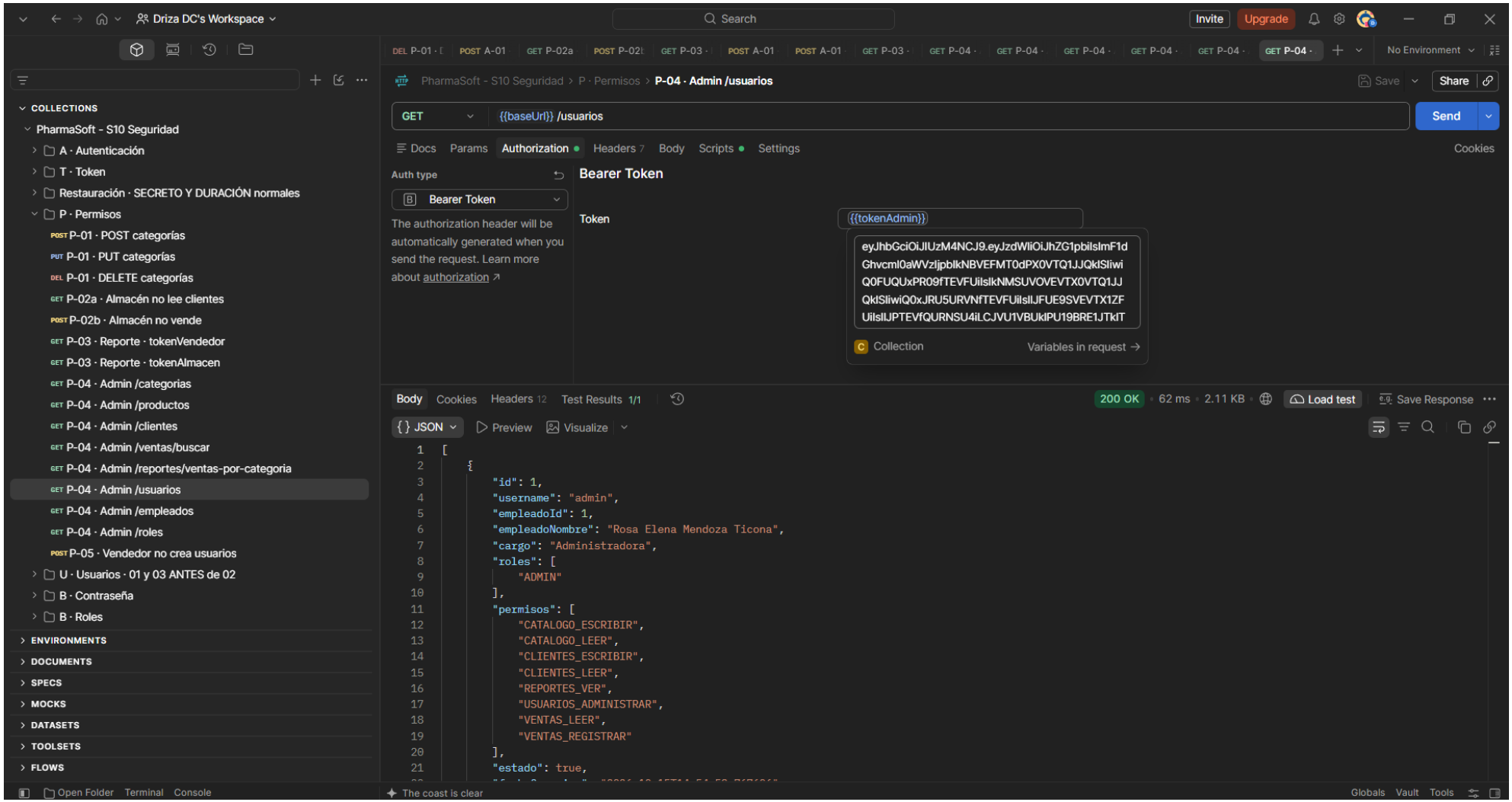
200; reporte de ventas por categoría.



Permisos por rol

E038 · P-04 · Administrador consulta usuarios

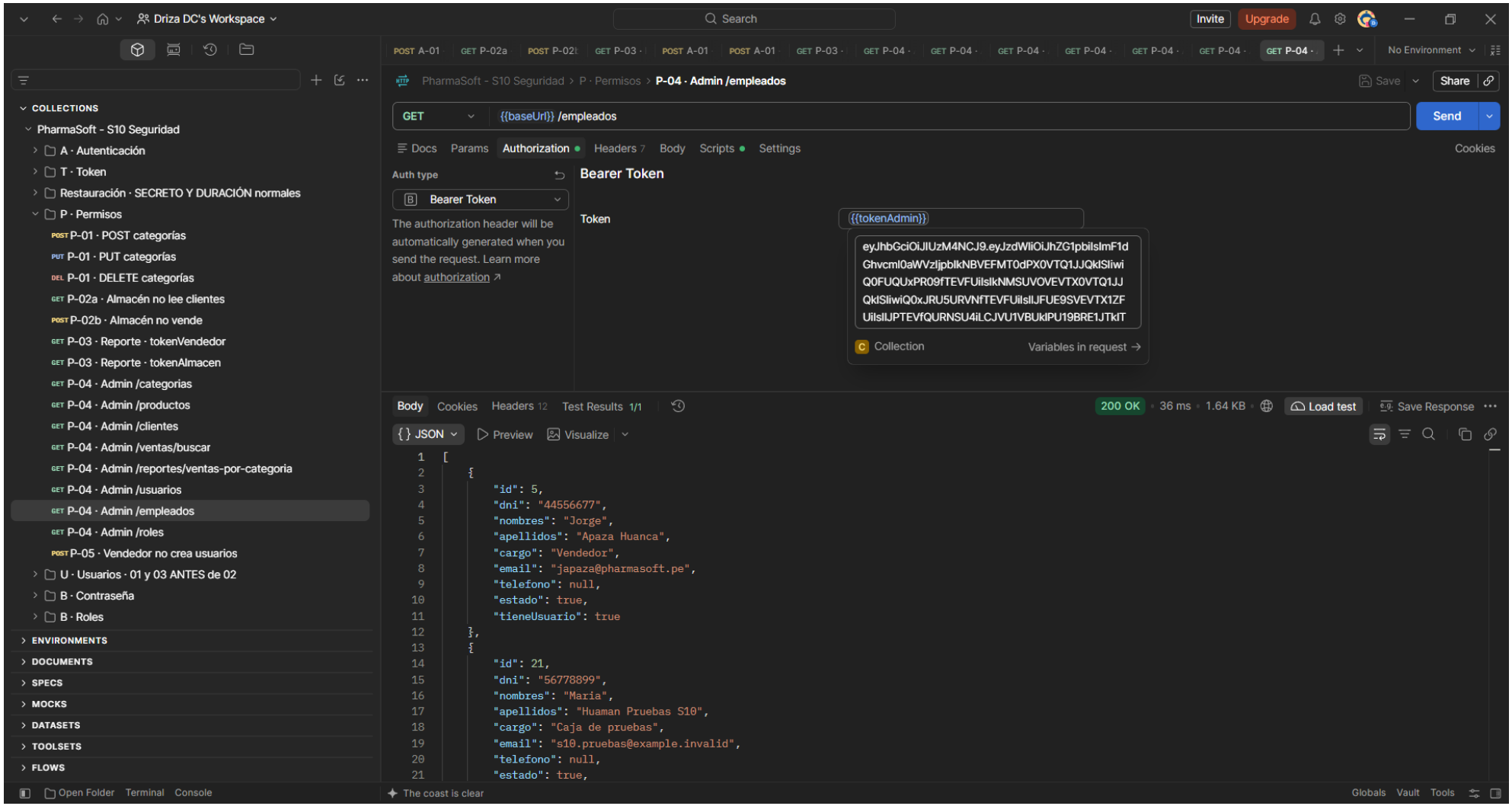
200; perfiles sin campo password.



Permisos por rol

E039 · P-04 · Administrador consulta empleados

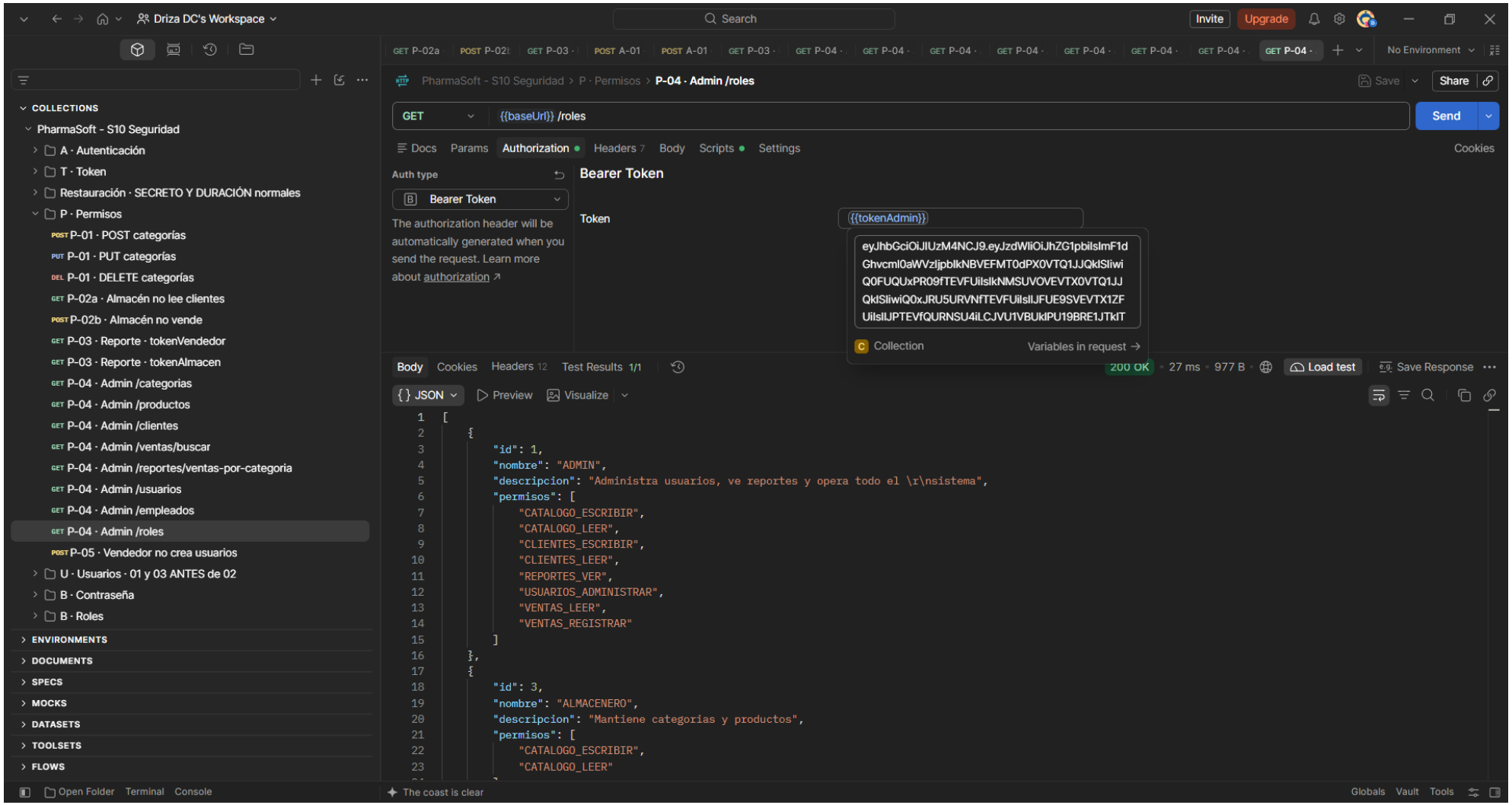
200; datos y disponibilidad de cuentas.



Permisos por rol

E040 · P-04 · Administrador consulta roles

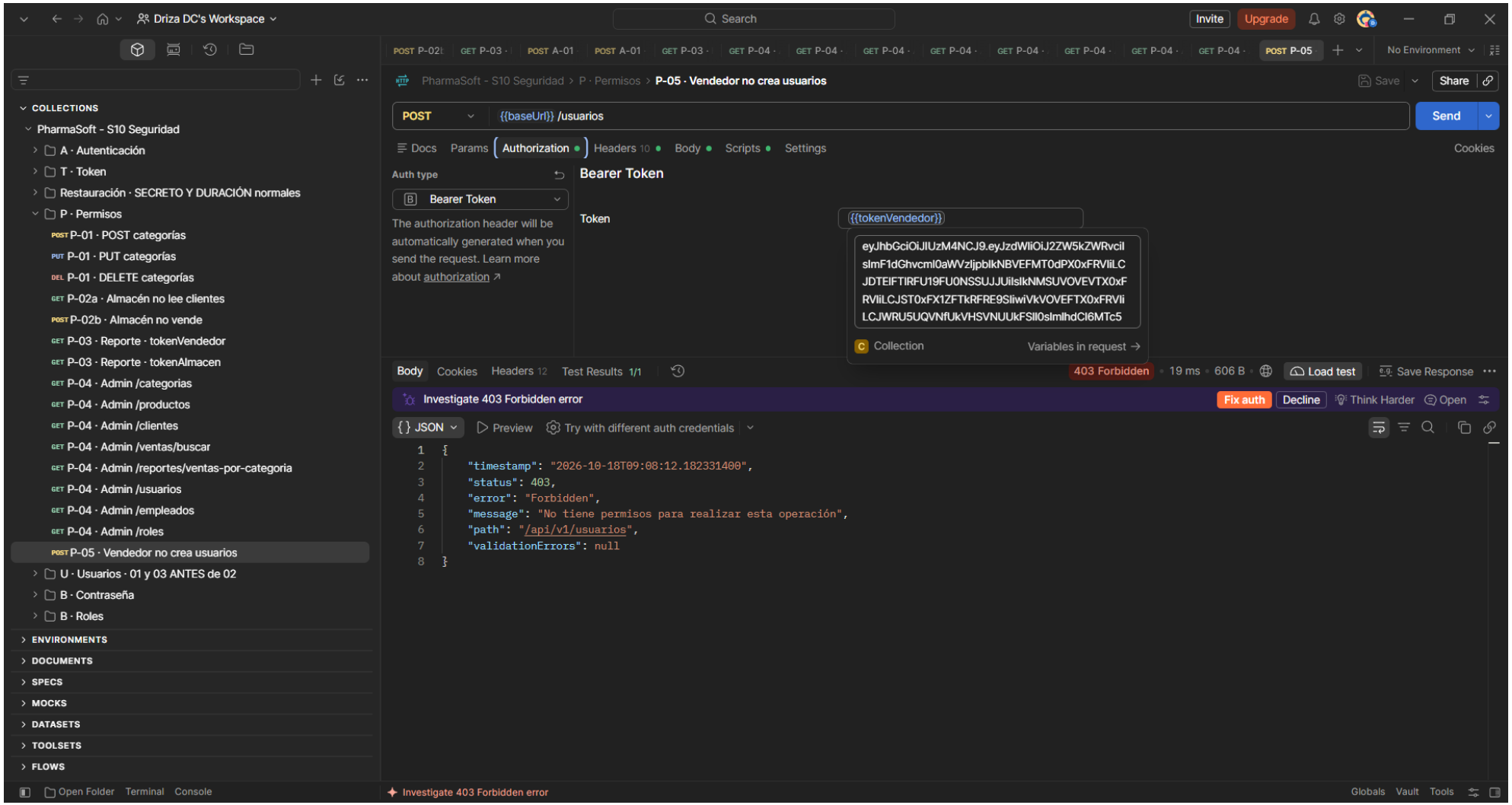
200; roles y permisos disponibles.



Permisos por rol

E041 · P-05 · Vendedor intenta crear usuarios

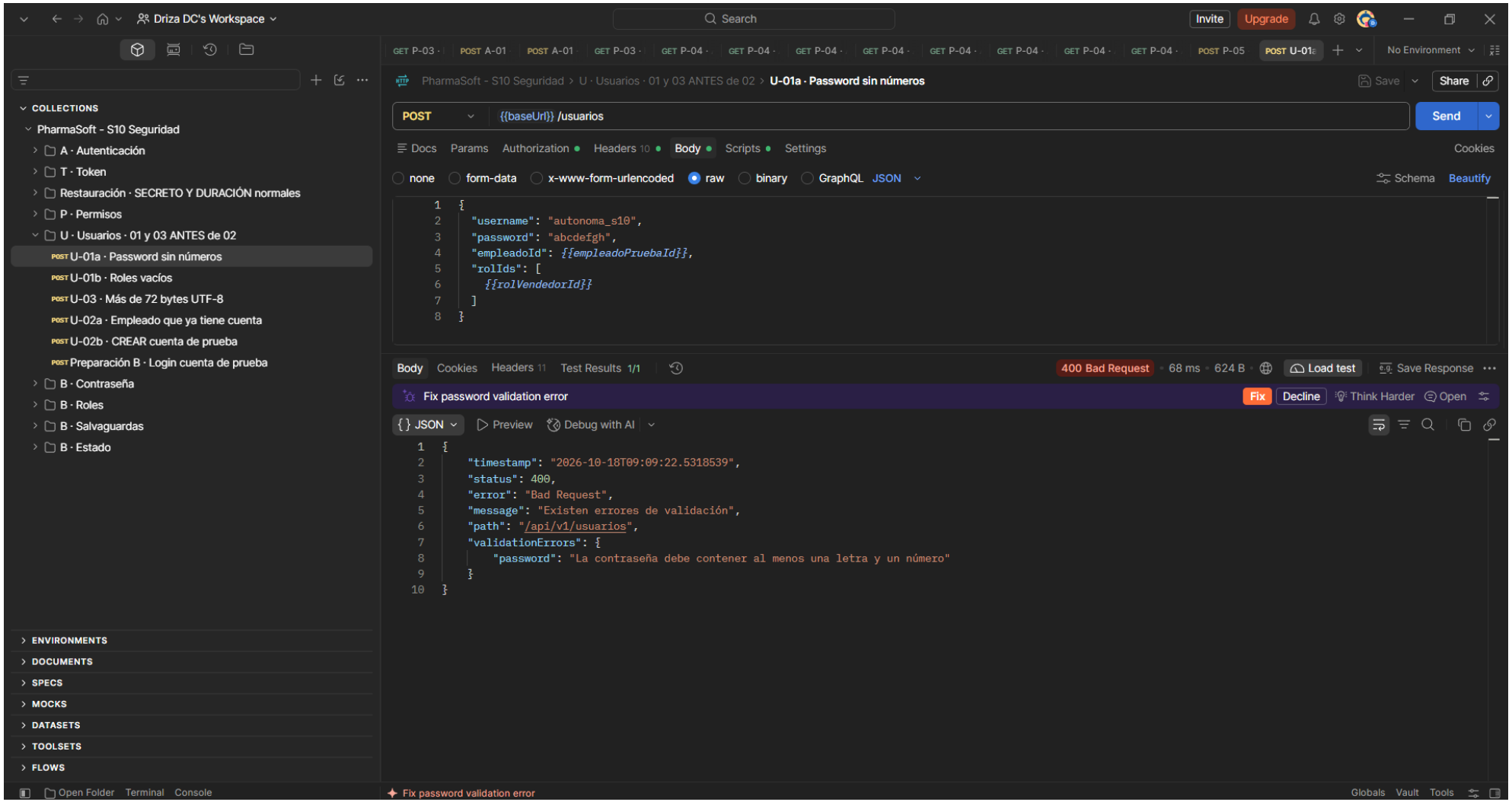
403; solo el permiso administrativo autoriza el alta.



Creación y validación de usuarios

E042 · U-01 · Contraseña sin números

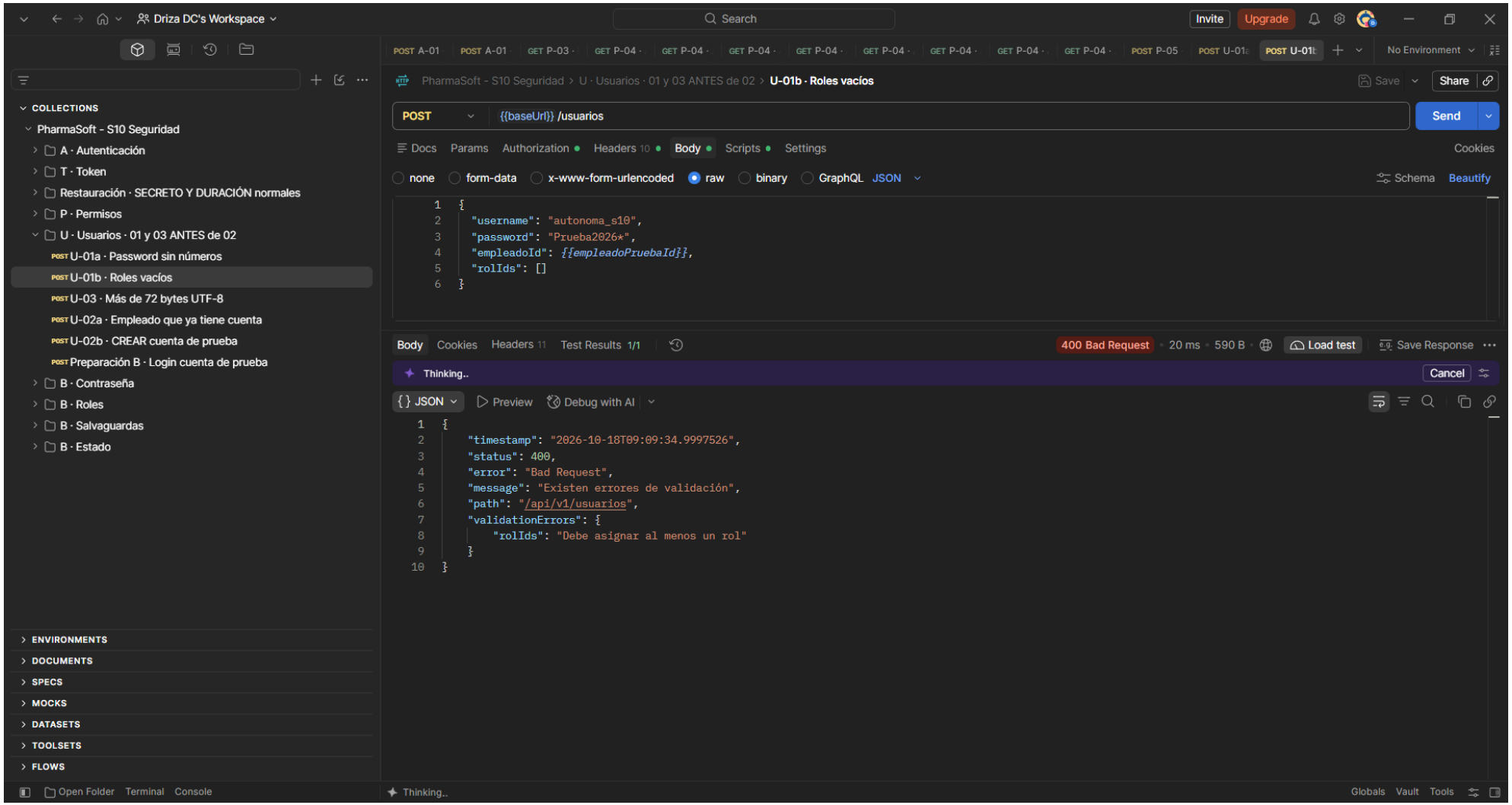
400; validationErrors.password informa la regla de letra y número.



Creación y validación de usuarios

E043 · U-01 · Alta sin roles

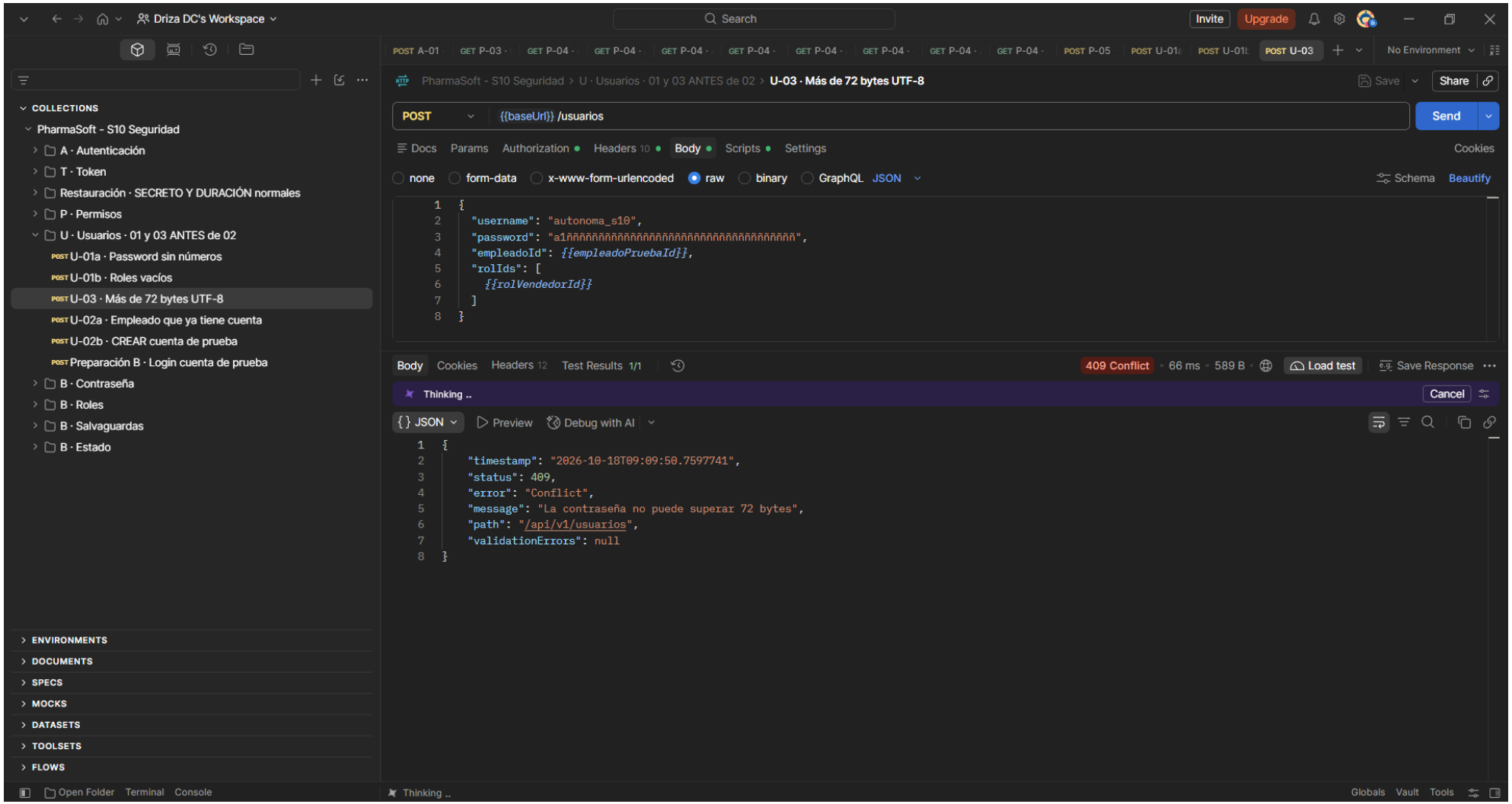
400; validationErrors.rolIds exige al menos un rol.



Creación y validación de usuarios

E044 · U-03 · Contraseña multibyte extensa

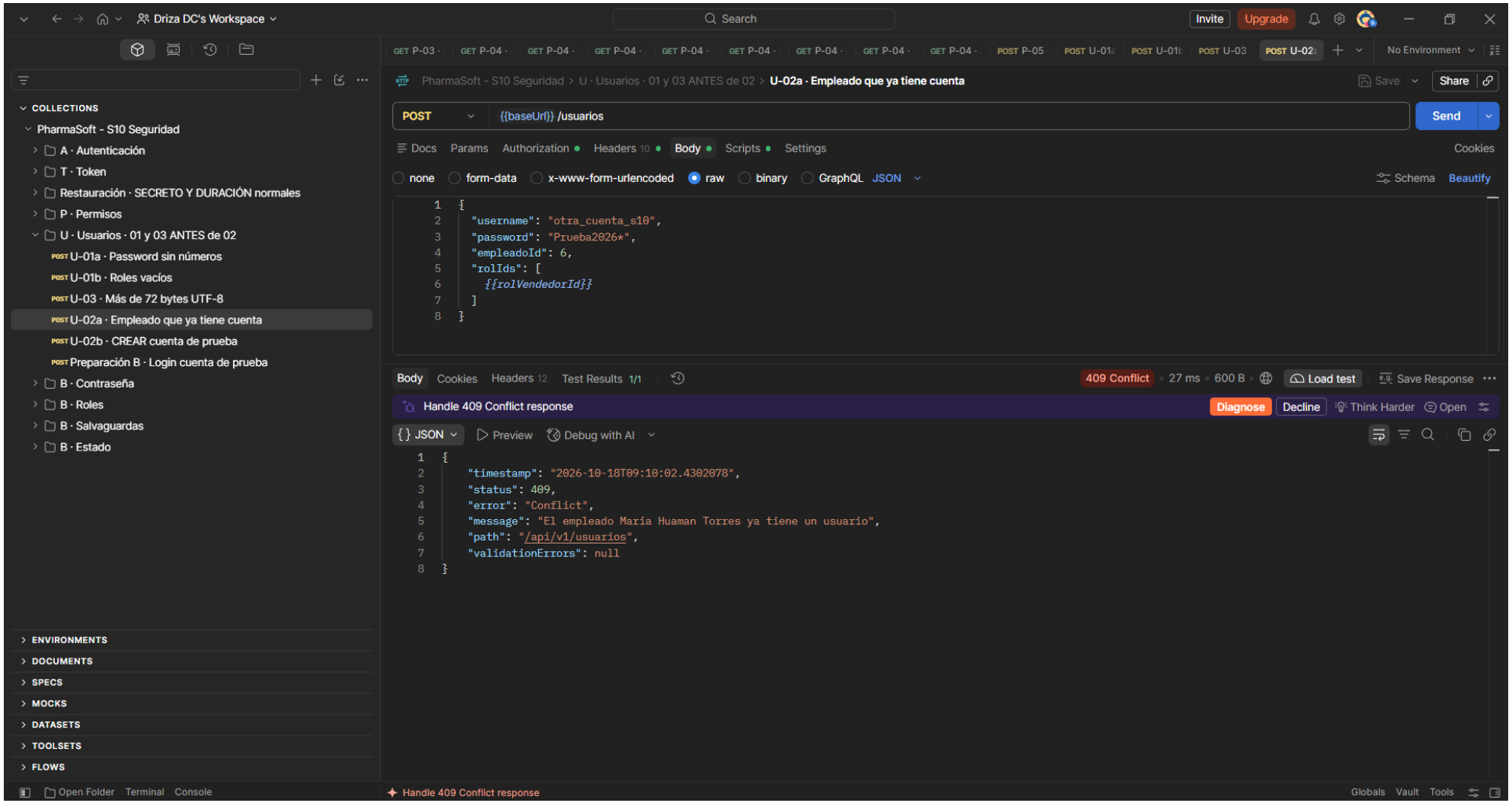
409; La contraseña no puede superar 72 bytes.



Creación y validación de usuarios

E045 · U-02 · Empleado con cuenta existente

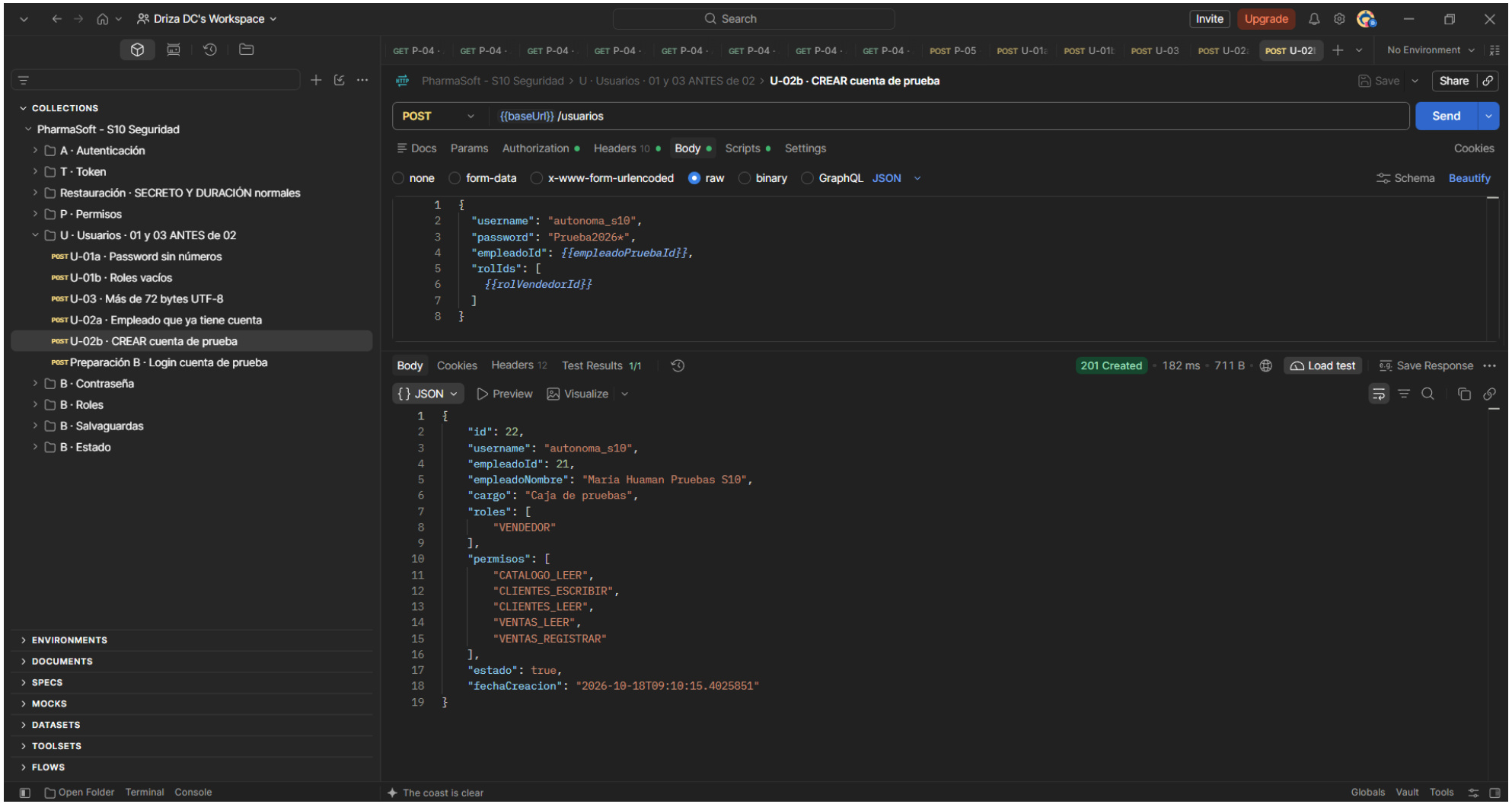
409; se protege la relación uno a uno entre empleado y usuario.



Creación y validación de usuarios

E046 · U-02 · Creación de la cuenta de prueba

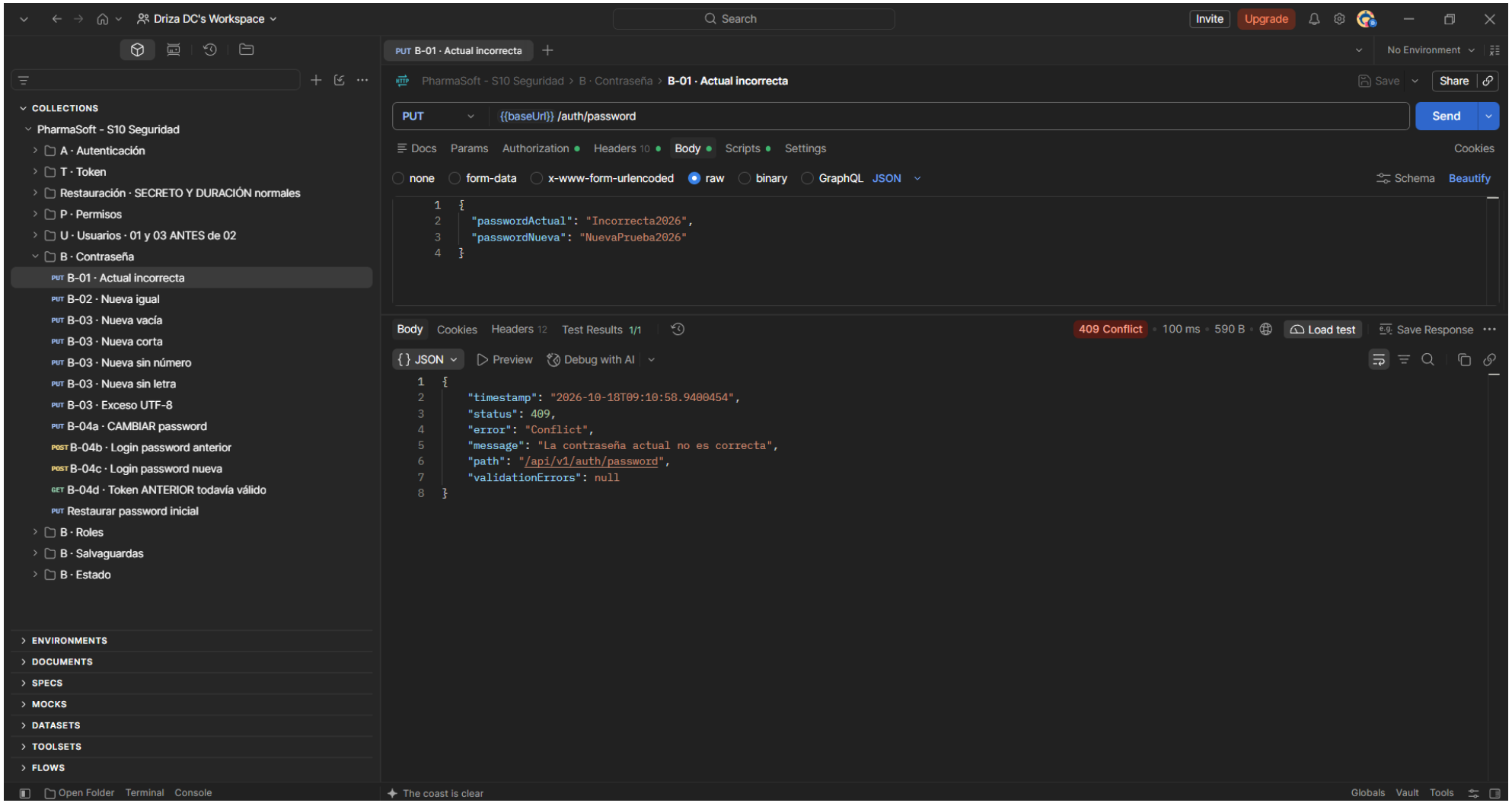
201; autonoma_s10, usuario 22, empleado 21, VENDEDOR, sin password en la respuesta.



Cambio de contraseña

E048 · B-01 · Contraseña actual incorrecta

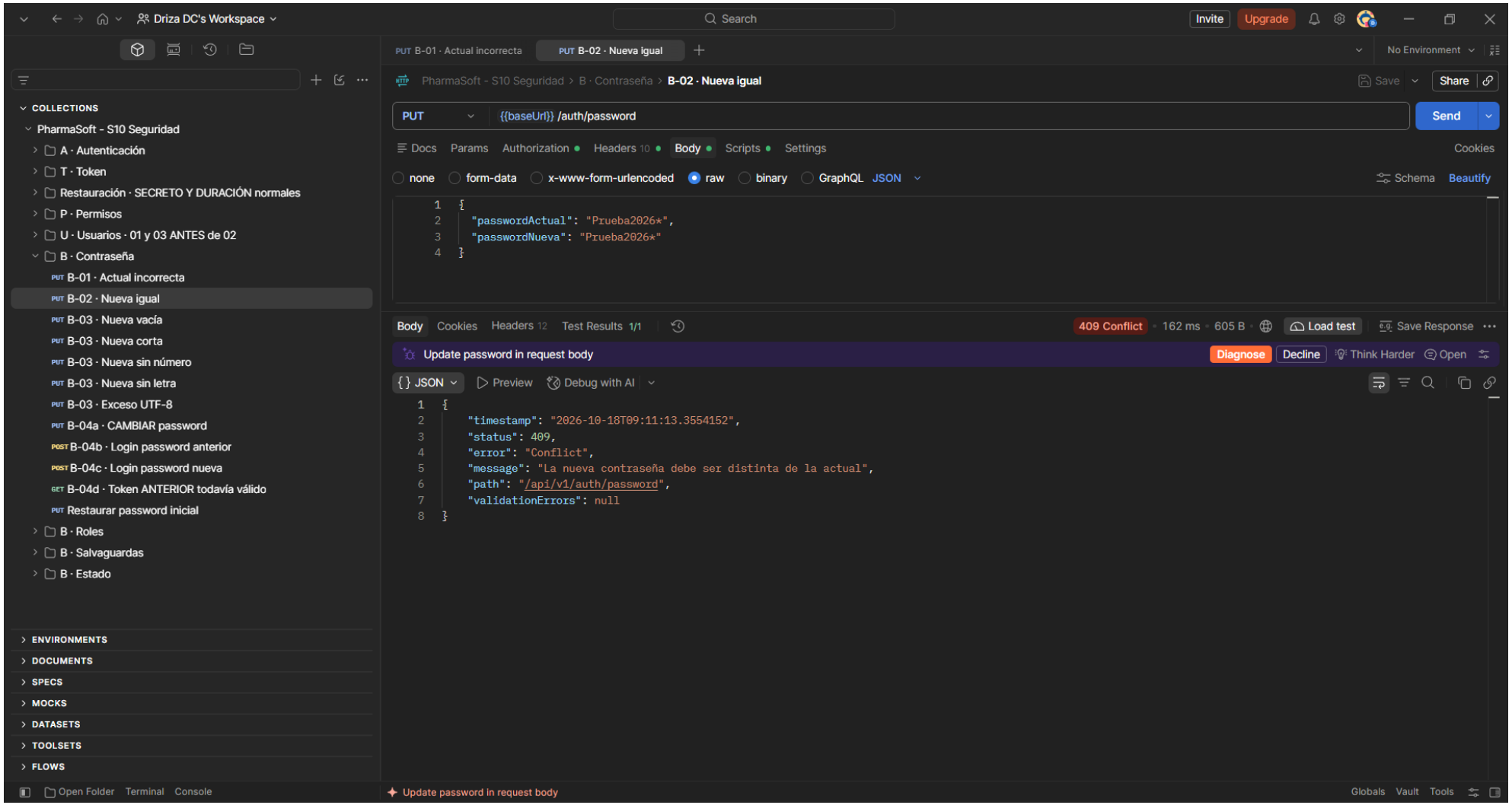
409; La contraseña actual no es correcta.



Cambio de contraseña

E049 · B-02 · Nueva contraseña igual a la actual

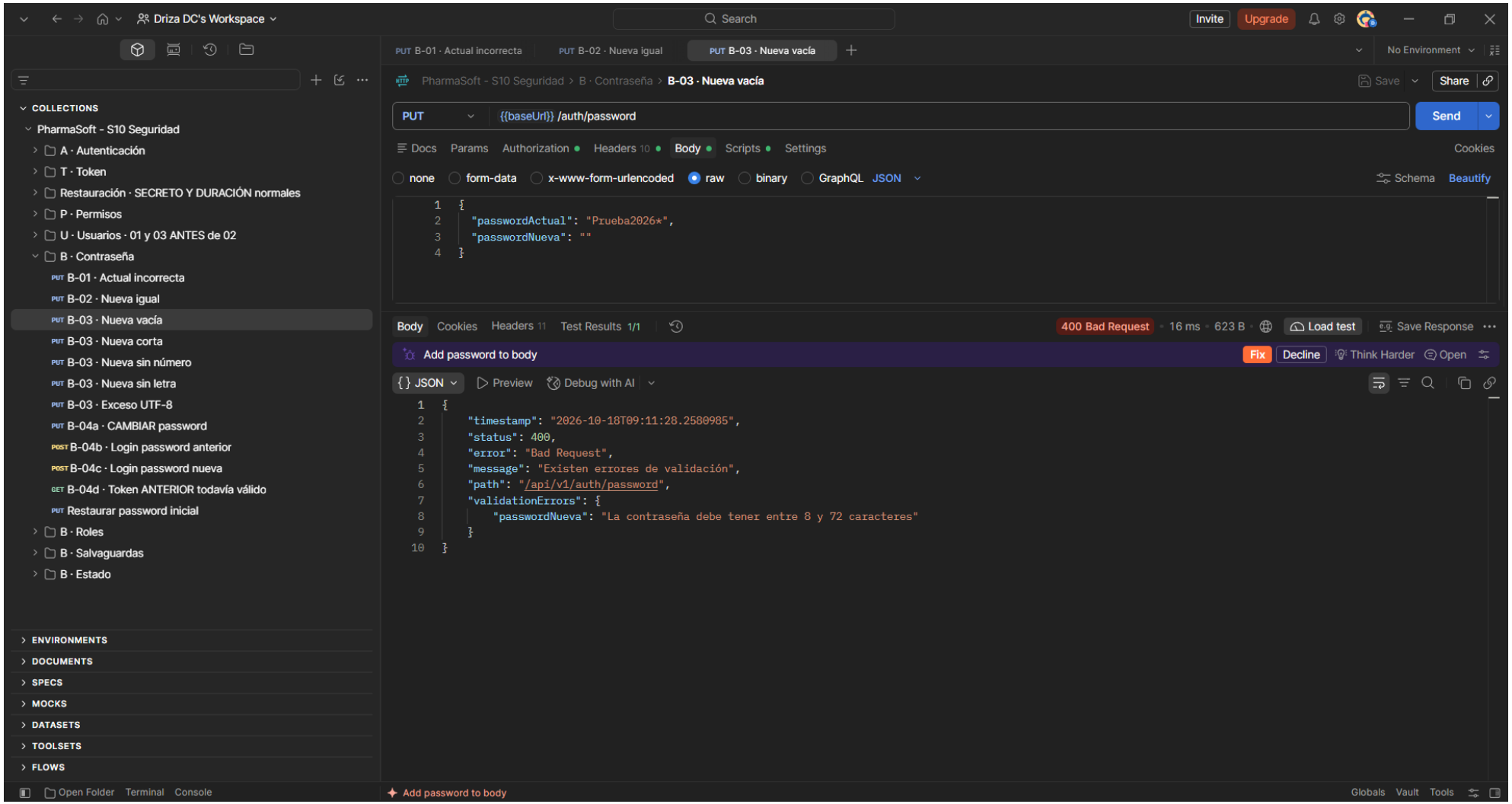
409; La nueva contraseña debe ser distinta de la actual.



Cambio de contraseña

E050 · B-03 · Nueva contraseña vacía

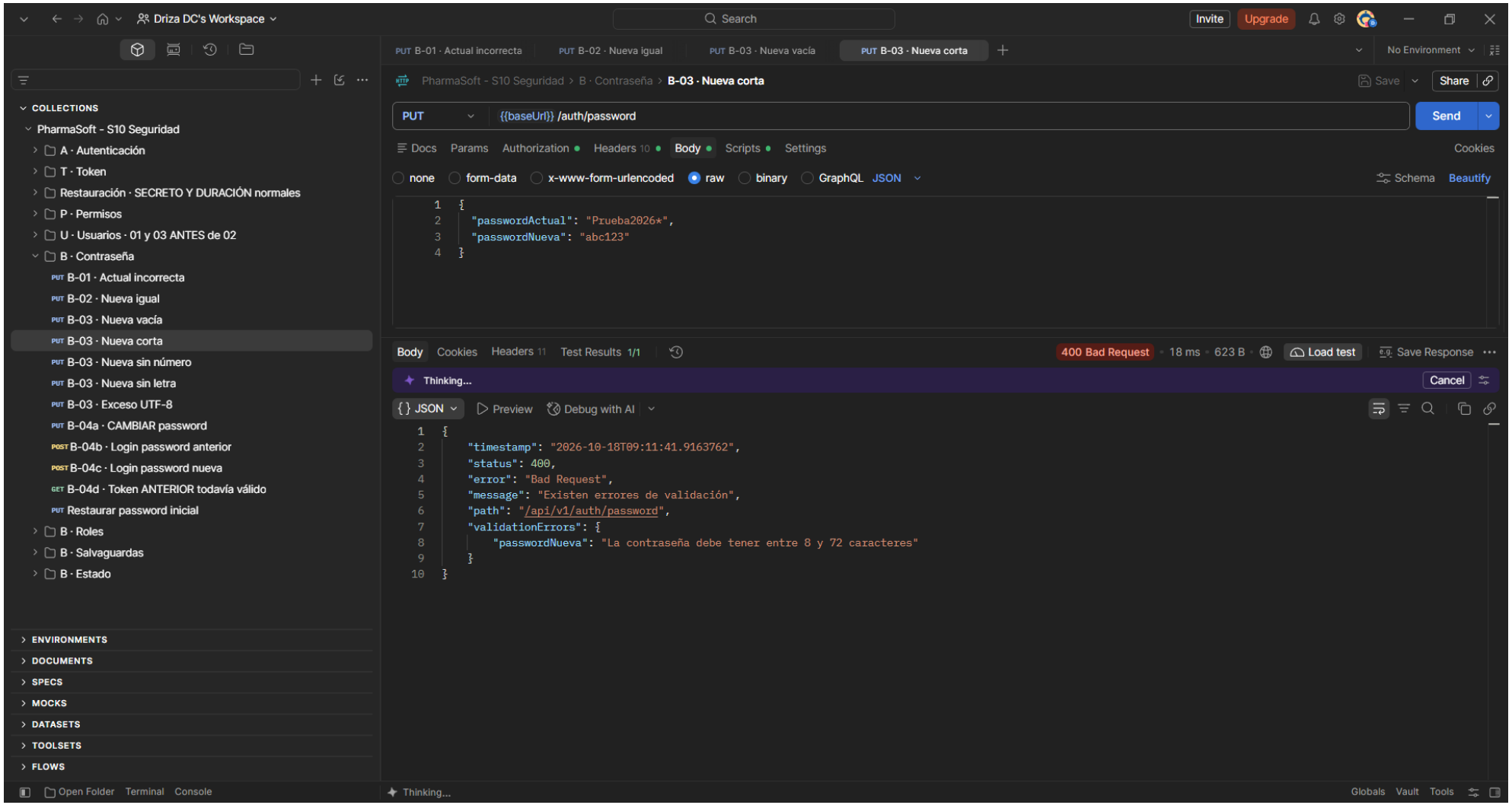
400; validación de passwordNueva.



Cambio de contraseña

E051 · B-03 · Nueva contraseña corta

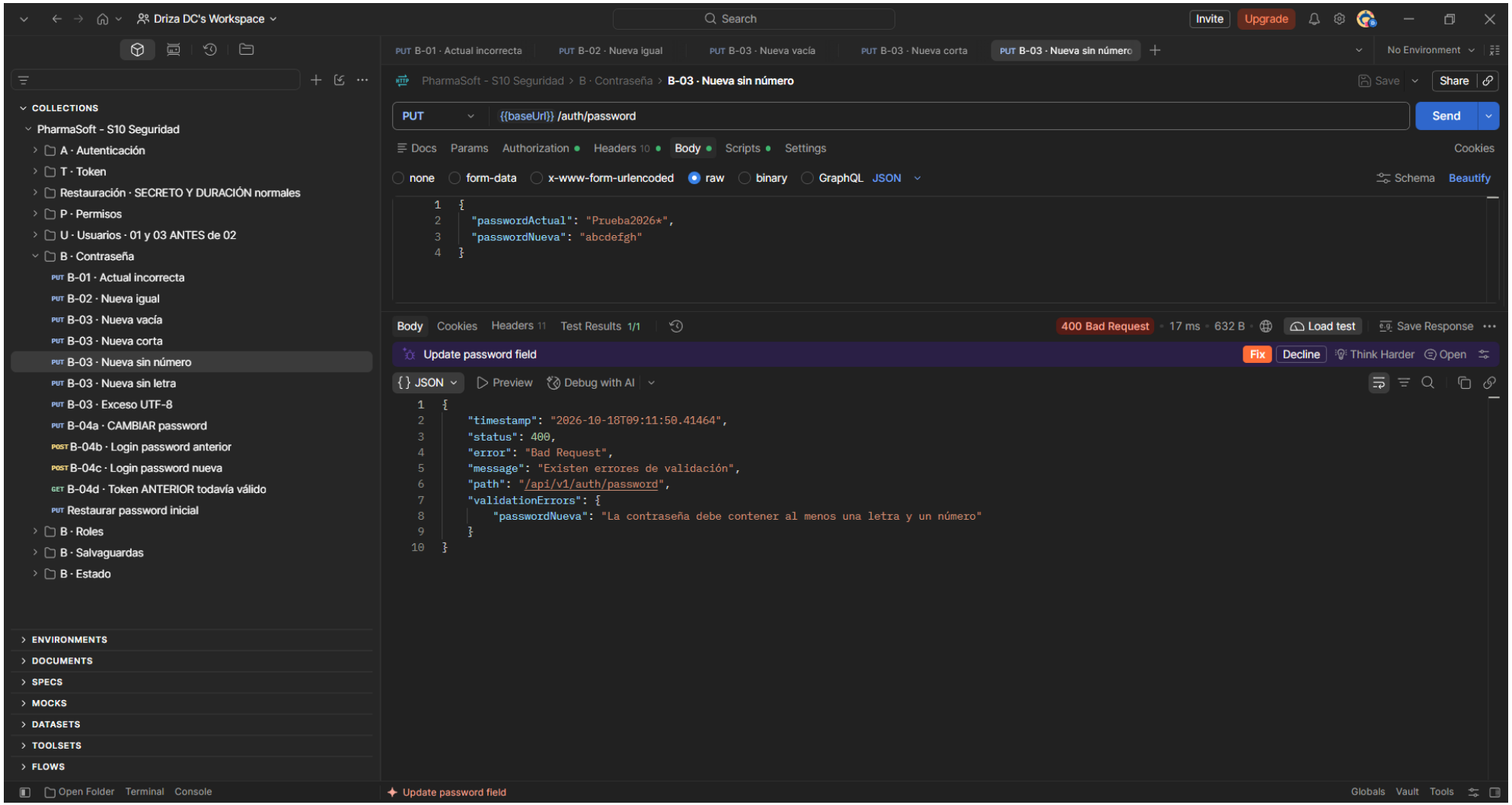
400; tamaño mínimo y reglas de complejidad.



Cambio de contraseña

E052 · B-03 · Nueva contraseña sin números

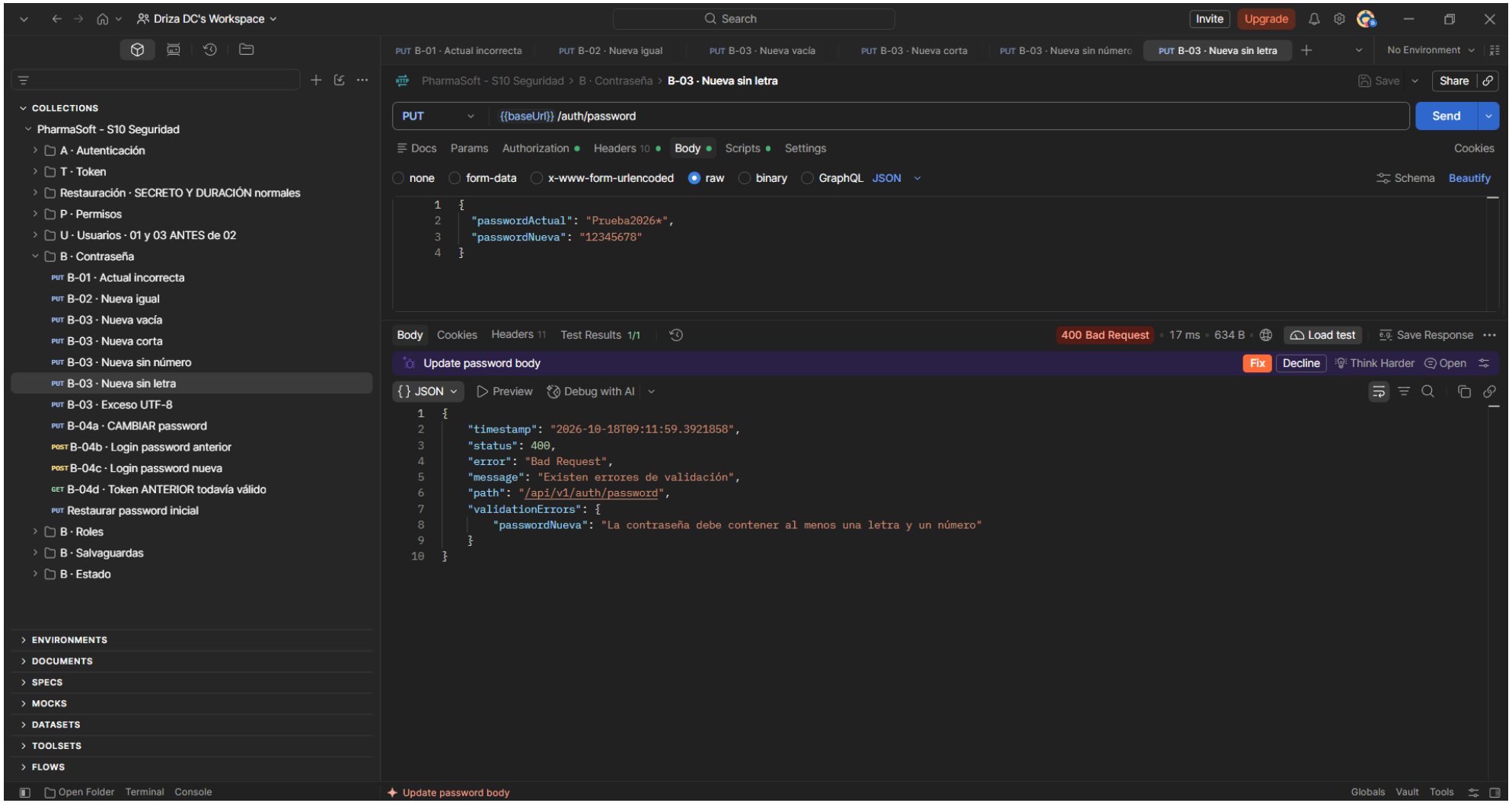
400; debe incluir al menos una letra y un número.



Cambio de contraseña

E053 · B-03 · Nueva contraseña sin letras

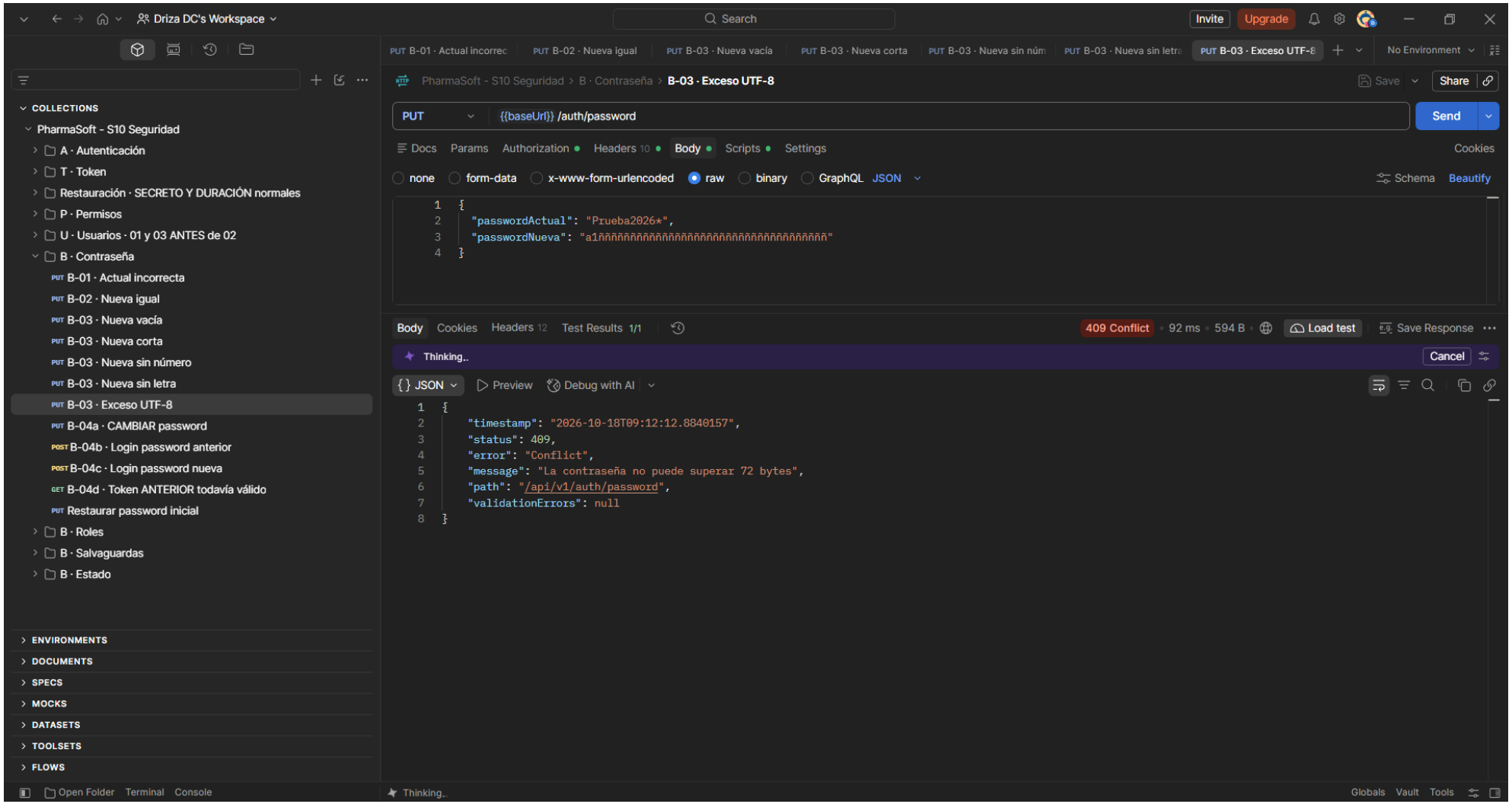
400; debe incluir al menos una letra y un número.



Cambio de contraseña

E054 · B-03 · Nueva contraseña excede 72 bytes

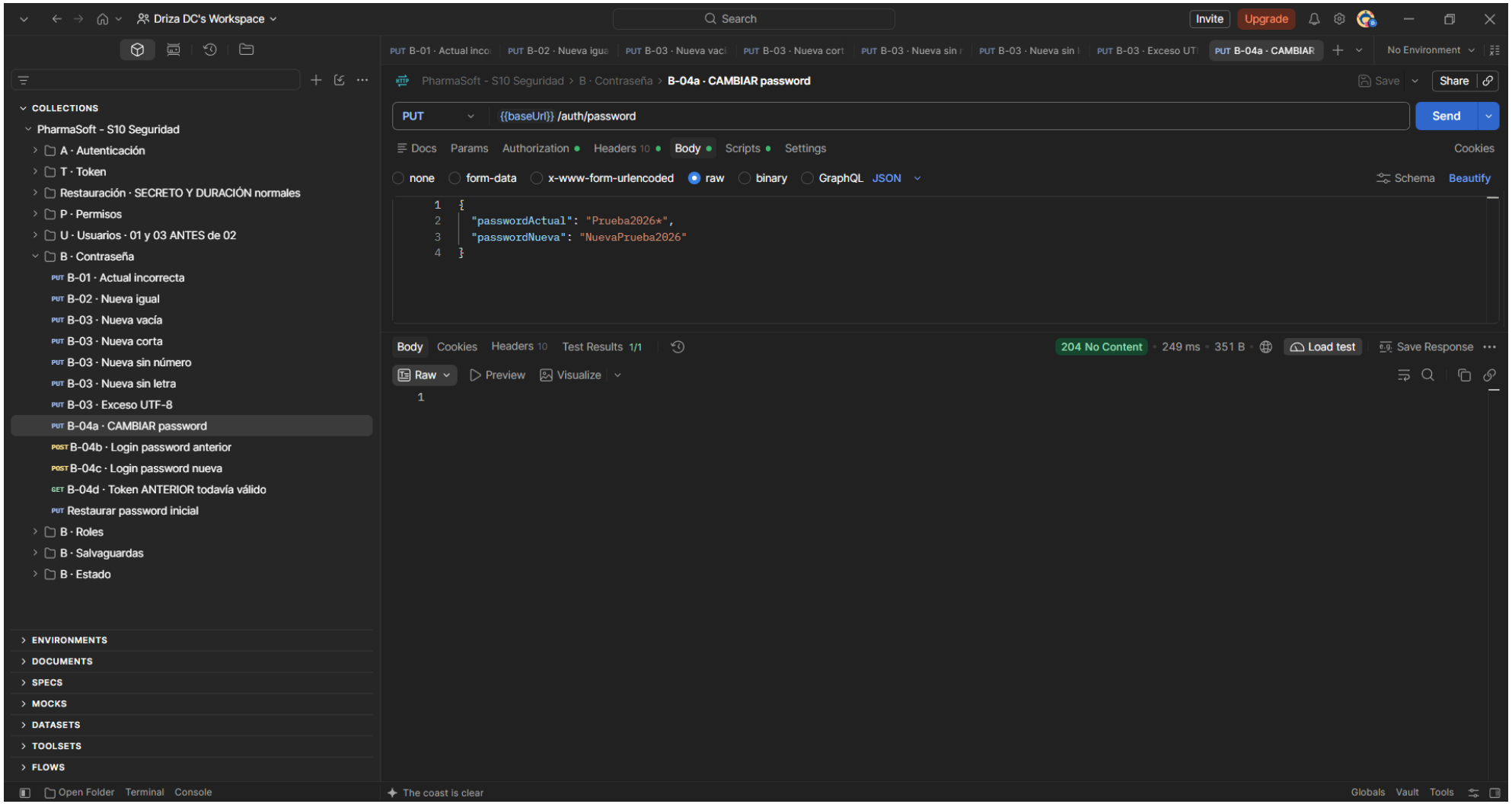
409; se aplica el límite de entrada de BCrypt en UTF-8.



Cambio de contraseña

E055 · B-04 · Cambio de contraseña válido

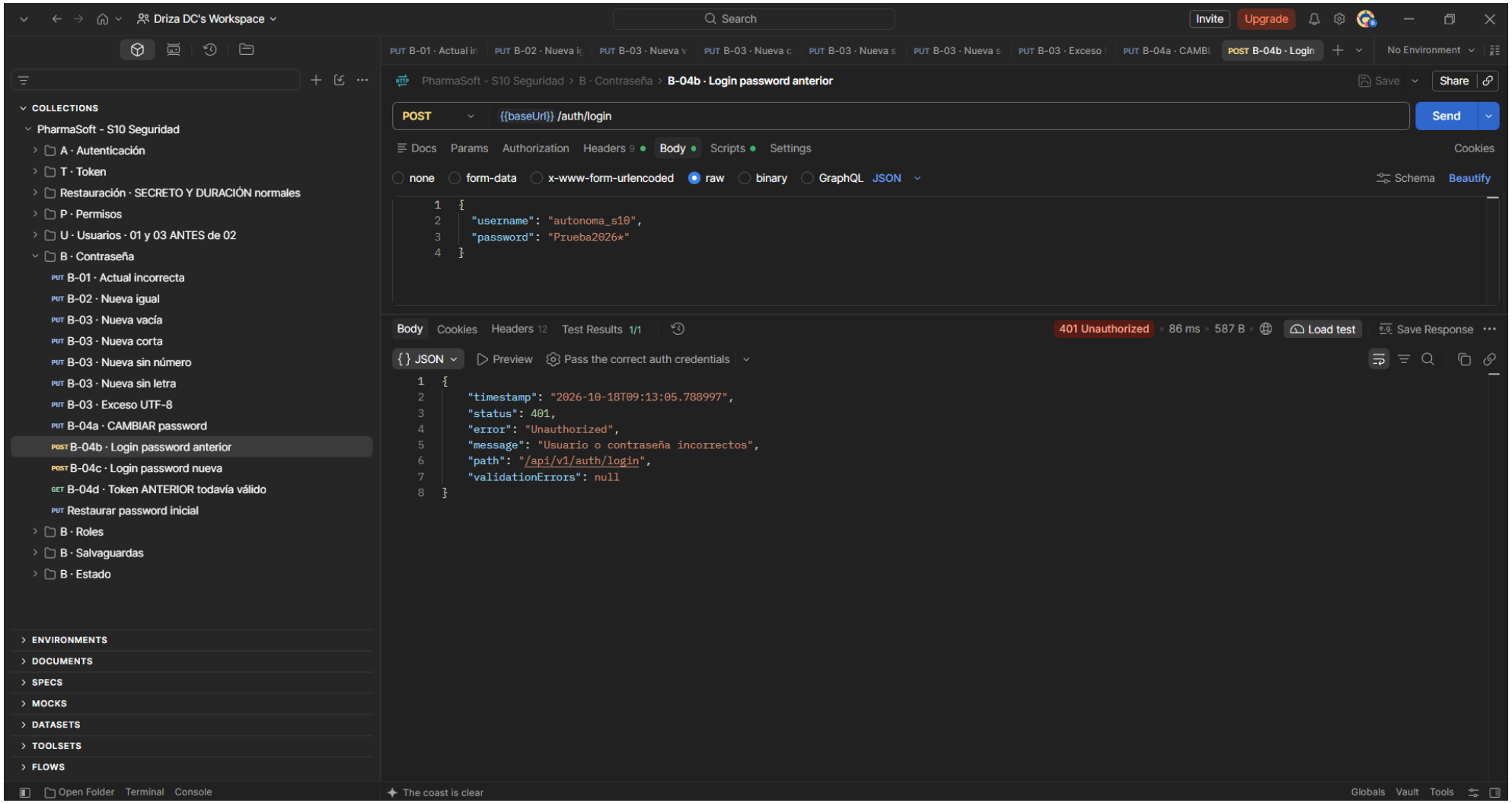
204 No Content; operación sobre la identidad autenticada.



Cambio de contraseña

E056 · B-04 · Login con la contraseña anterior

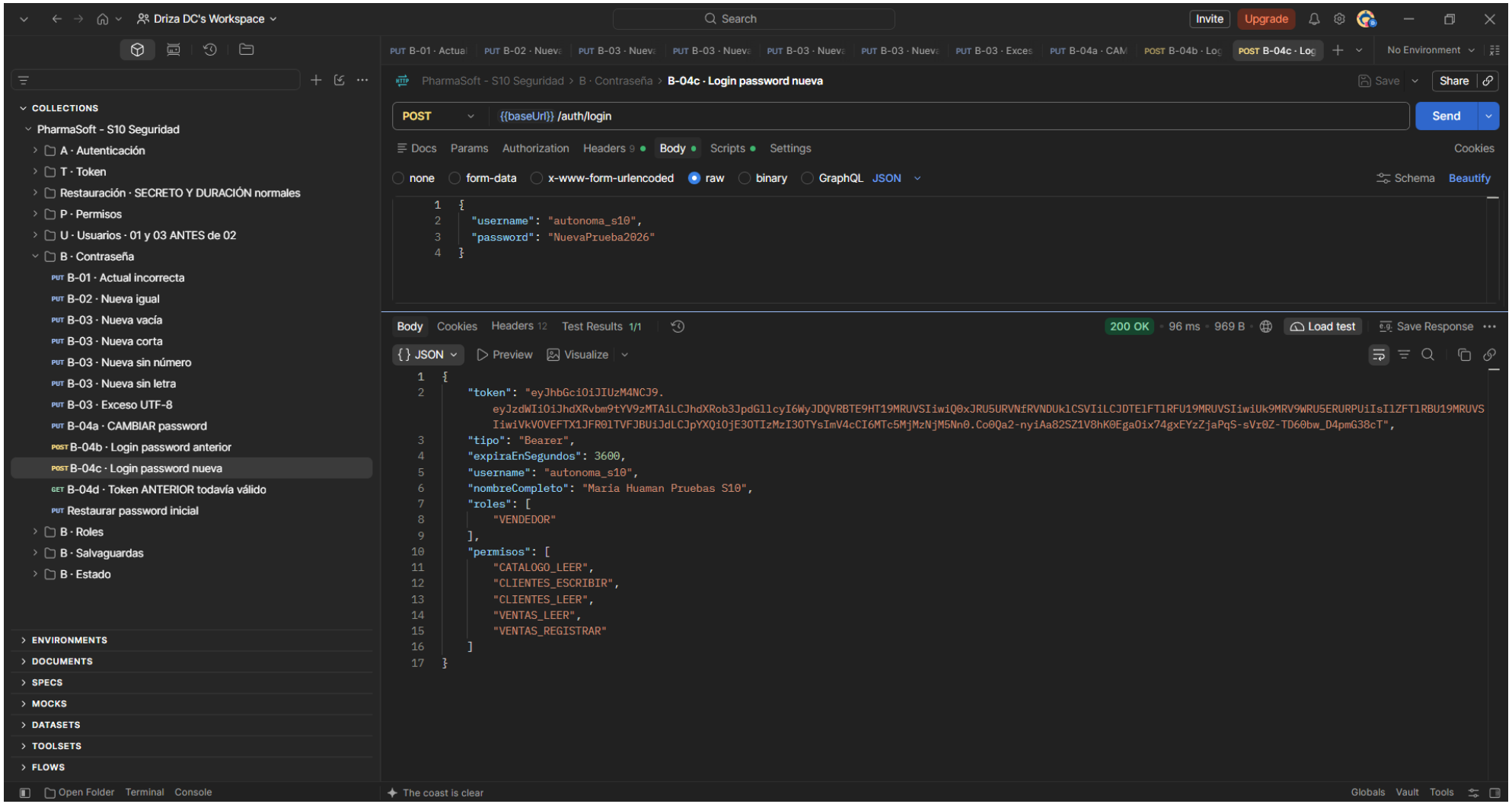
401; la contraseña anterior deja de autenticar.



Cambio de contraseña

E057 · B-04 · Login con la contraseña nueva

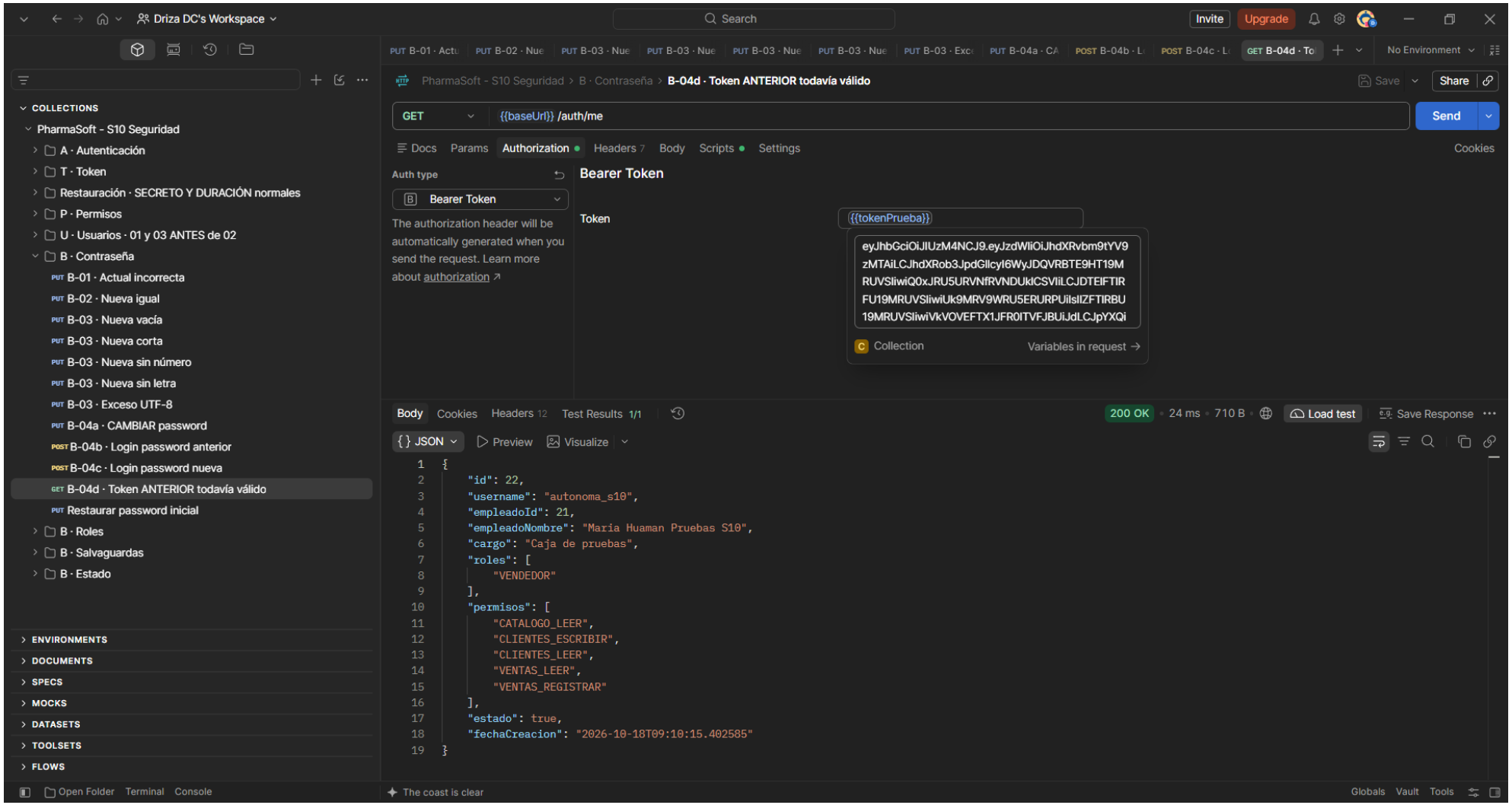
200; la nueva contraseña autentica correctamente.



Cambio de contraseña

E058 · B-04 · JWT anterior al cambio sigue válido

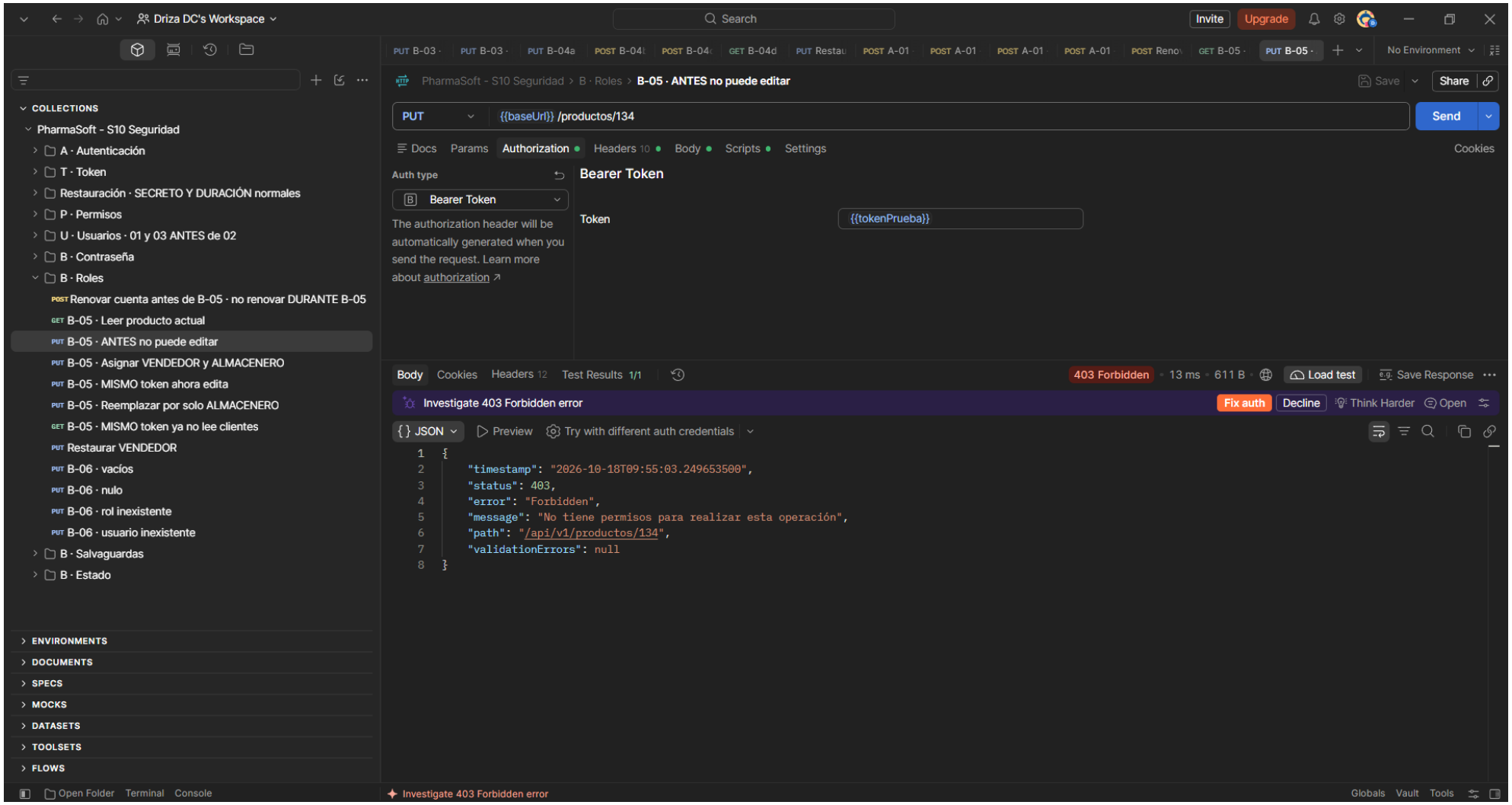
200 en auth/me con el token emitido antes del cambio.



Asignación y reemplazo de roles

E061 · B-05 · Sin permiso de edición antes del cambio

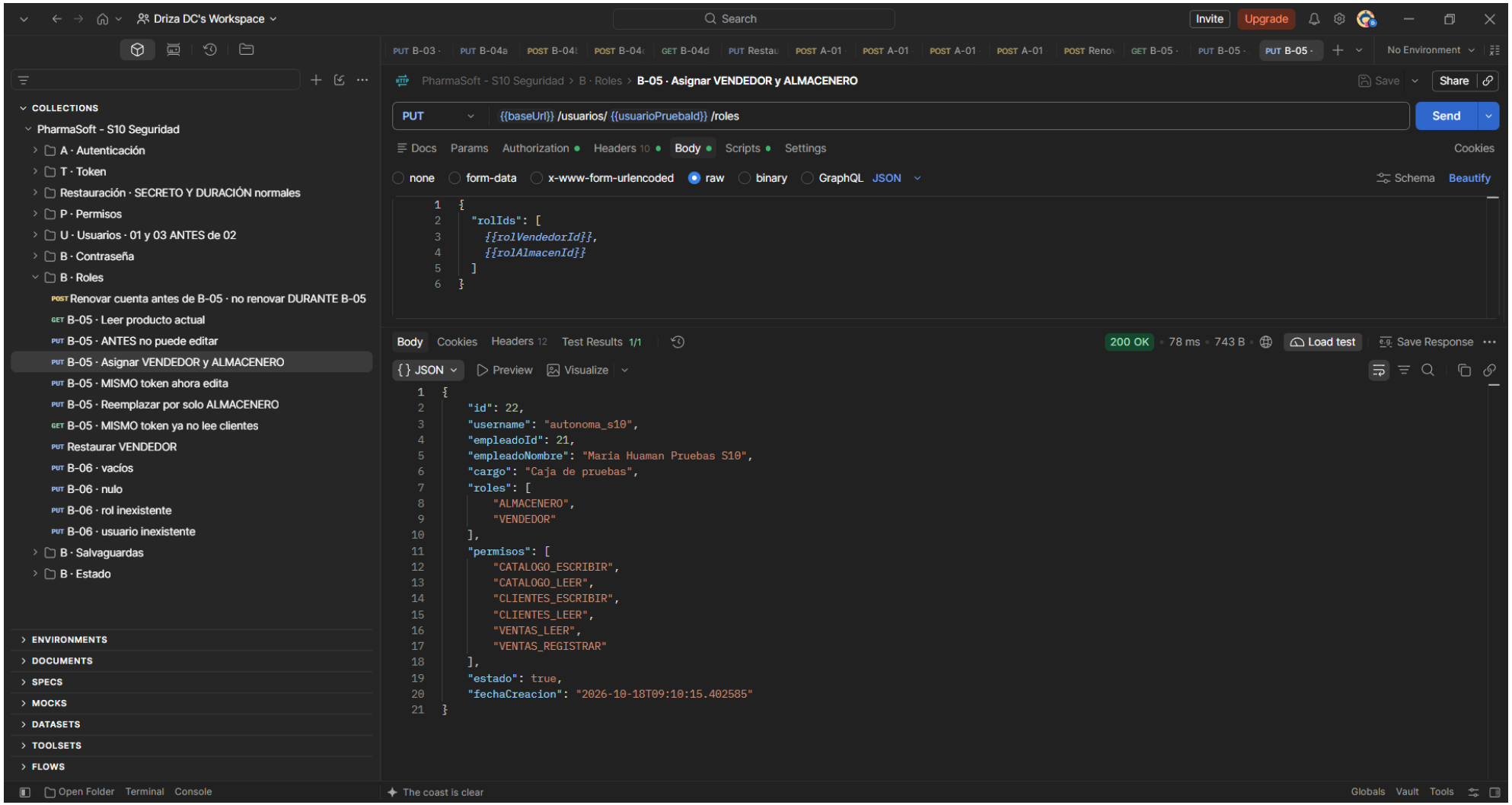
403; la cuenta VENDEDOR no puede editar productos.



Asignación y reemplazo de roles

E062 · B-05 · Asignación de dos roles

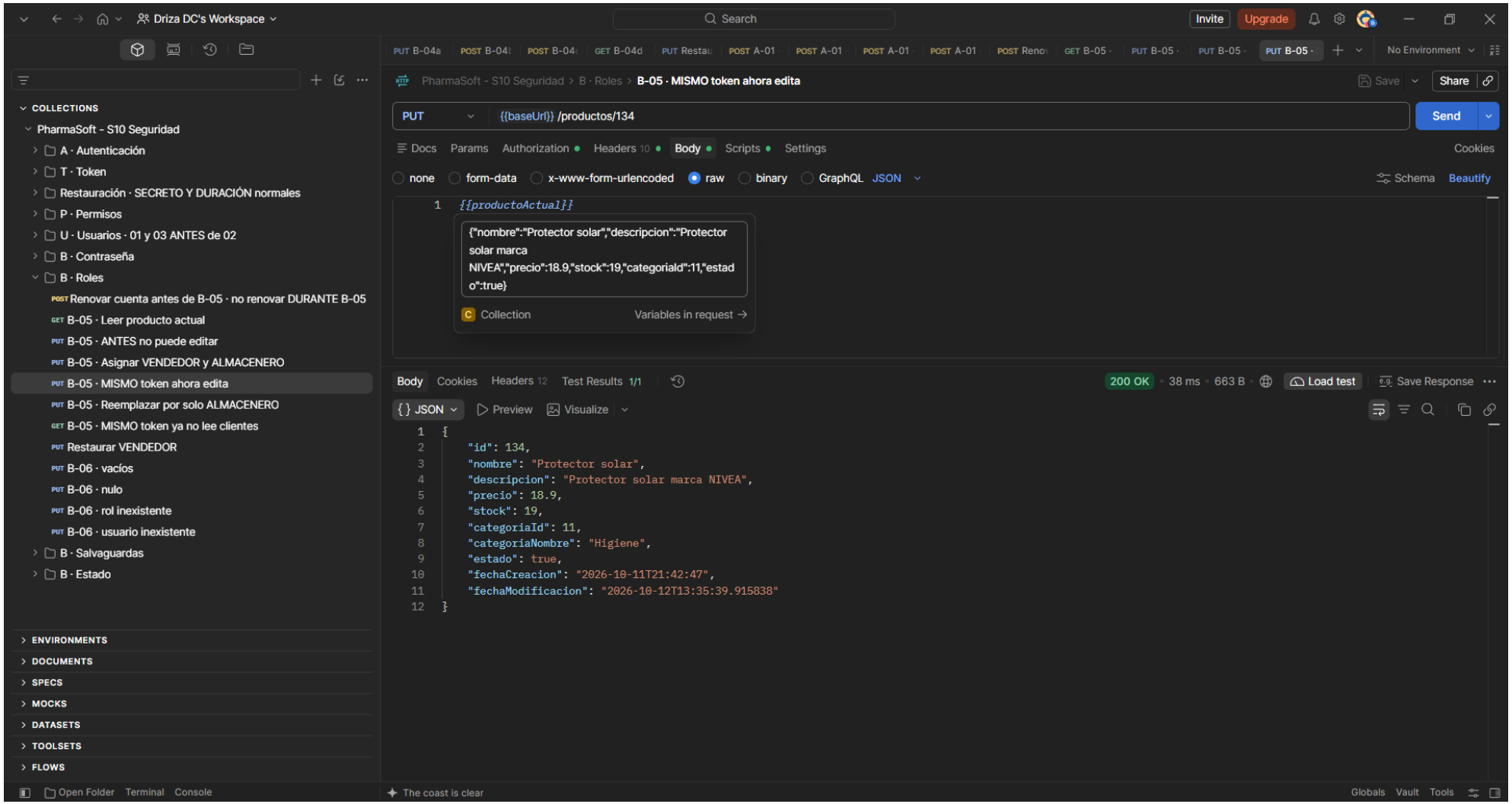
200; respuesta con ALMACENERO y VENDEDOR y sus permisos.



Asignación y reemplazo de roles

E063 · B-05 · Edición con el mismo token

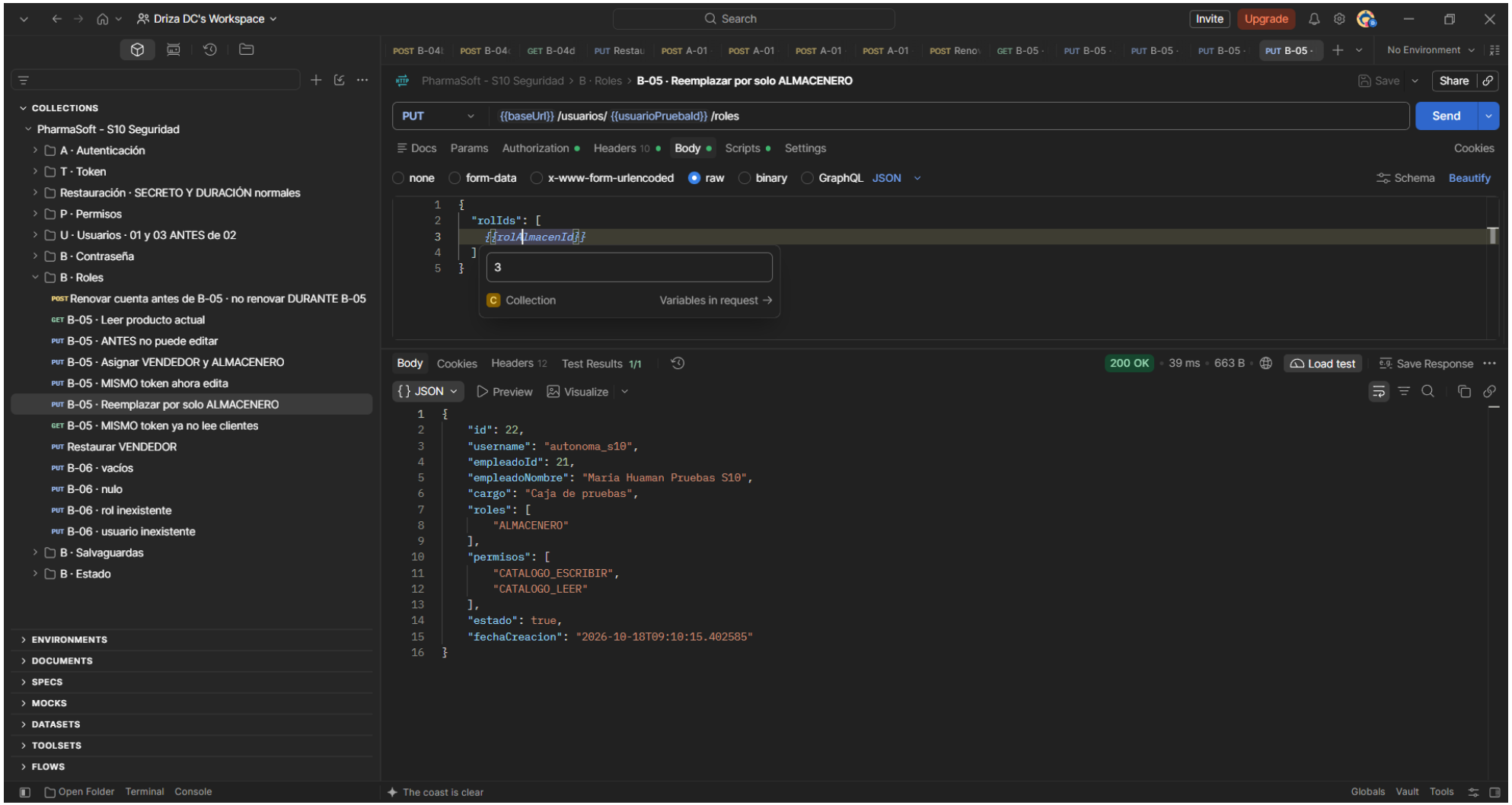
200; el permiso nuevo se aplica sin un nuevo login.



Asignación y reemplazo de roles

E064 · B-05 · Reemplazo por solo almacén

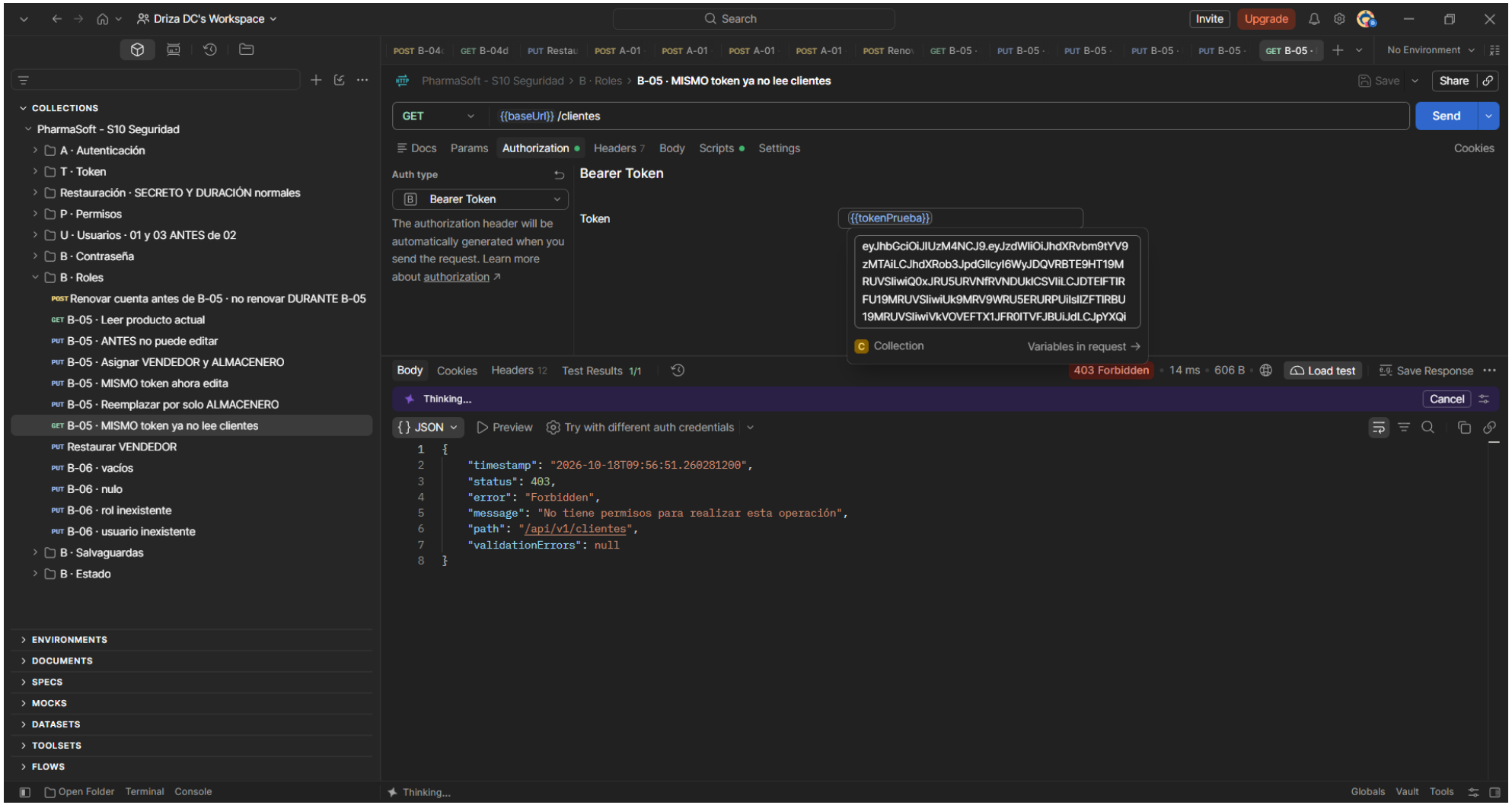
200; el conjunto de roles queda únicamente en ALMACENERO.



Asignación y reemplazo de roles

E065 · B-05 · Pérdida de lectura de clientes

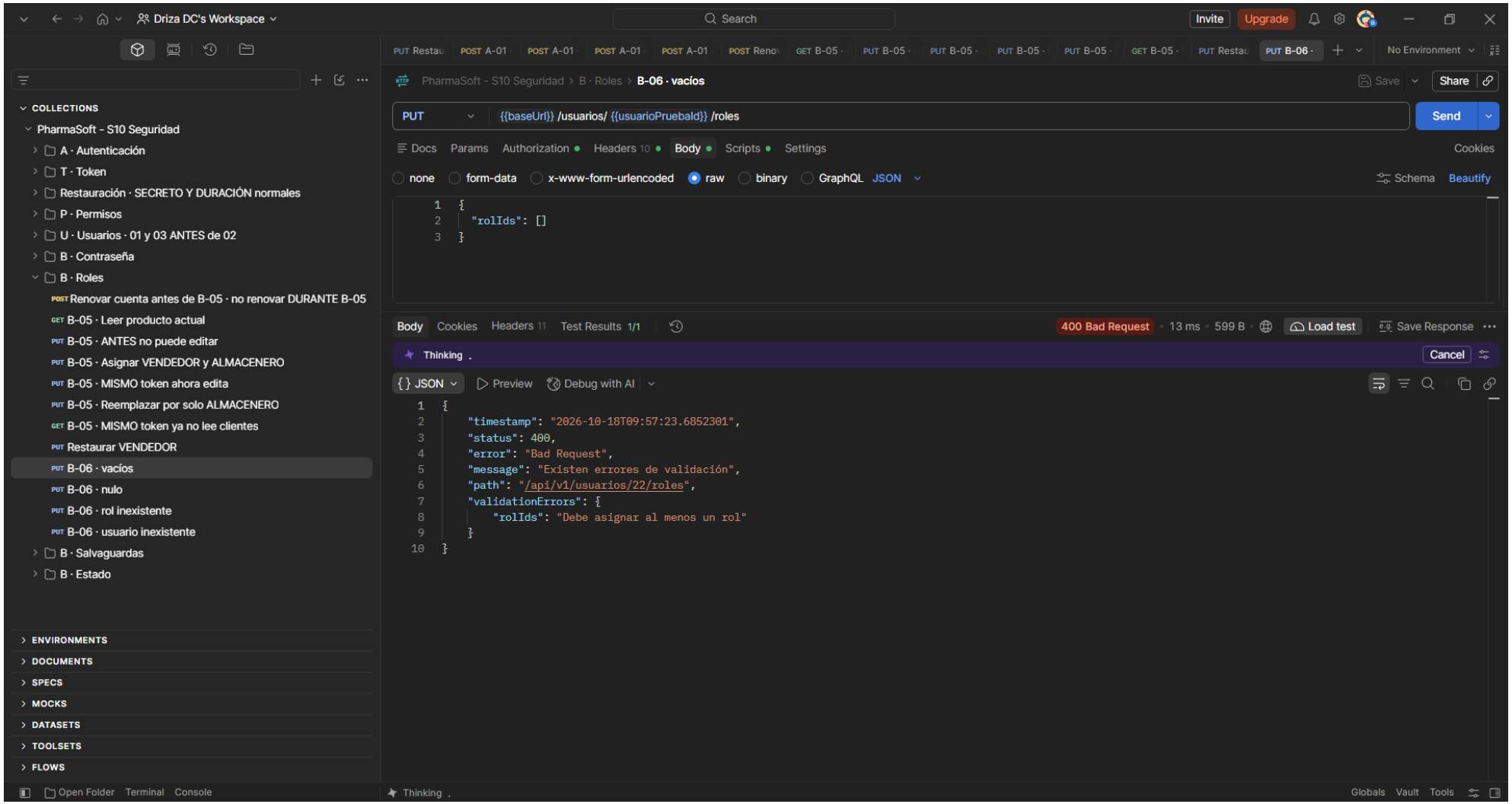
403 con el mismo token tras retirar VENDEDOR.



Asignación y reemplazo de roles

E067 · B-06 · Conjunto de roles vacío

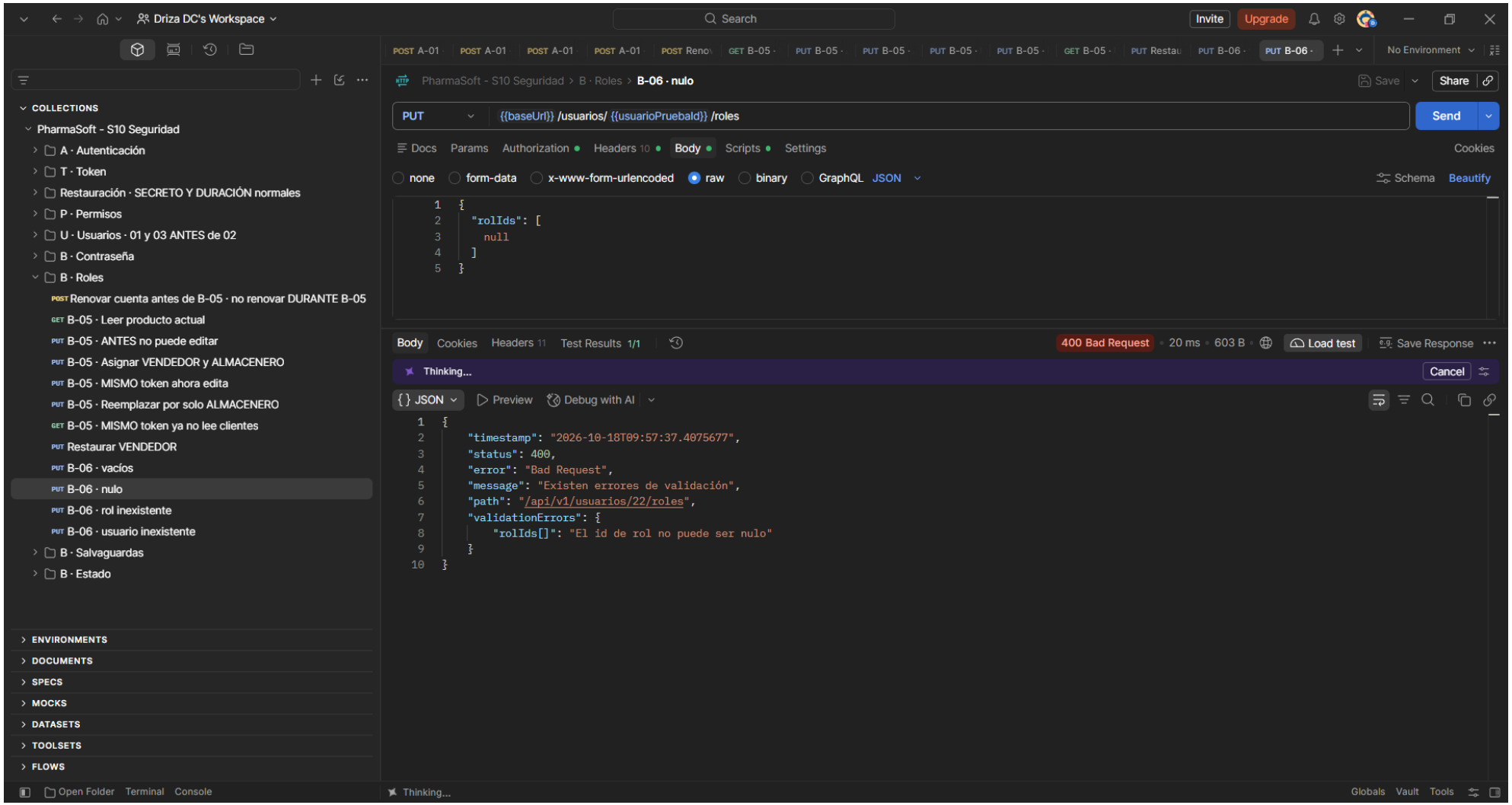
400; rollds debe contener al menos un rol.



Asignación y reemplazo de roles

E068 · B-06 · Elemento nulo en roles

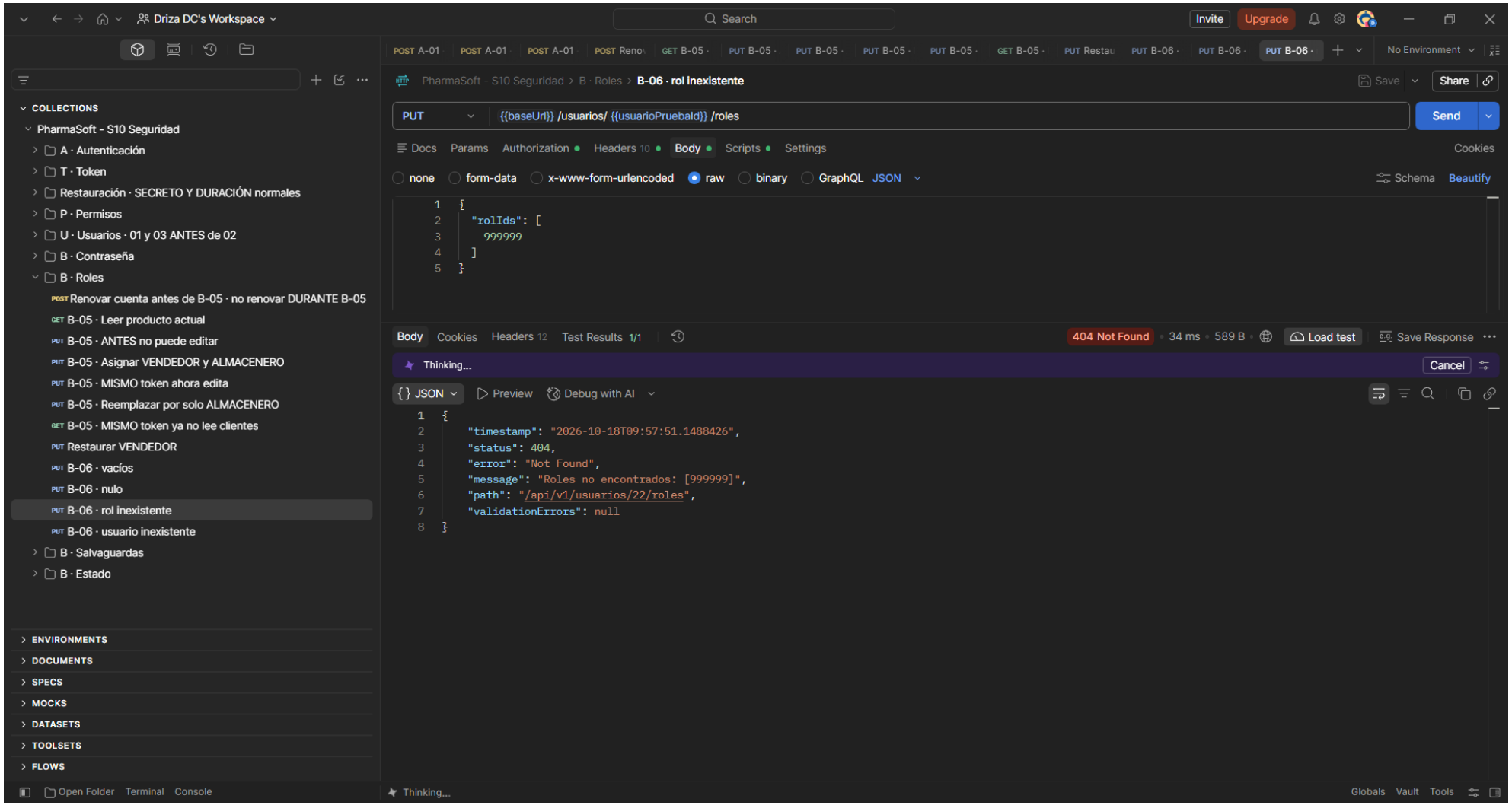
400; validación del elemento de rollds.



Asignación y reemplazo de roles

E069 · B-06 · Rol inexistente

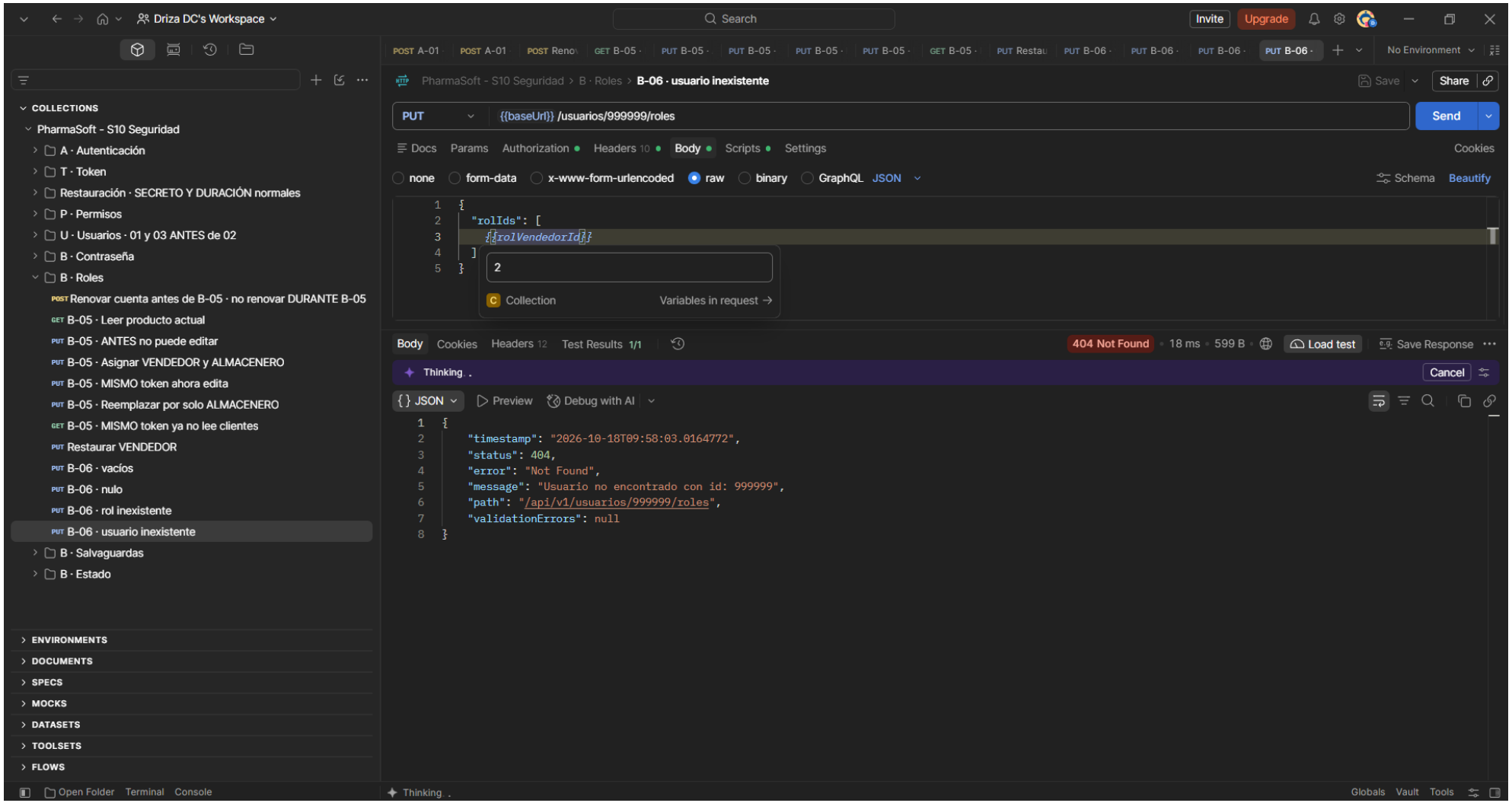
404; Roles no encontrados: [999999].



Asignación y reemplazo de roles

E070 · B-06 · Usuario inexistente al asignar roles

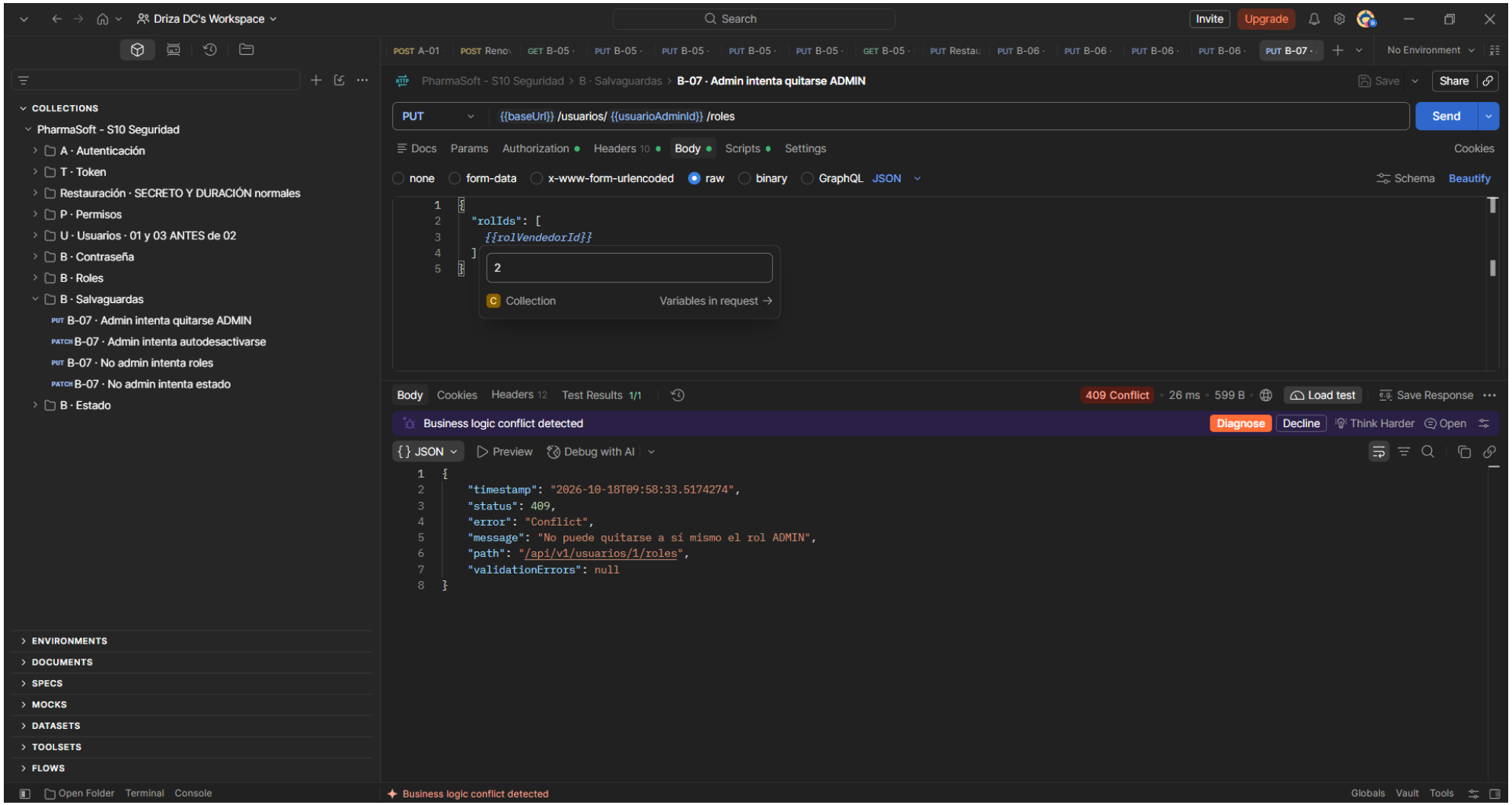
404; Usuario no encontrado con id: 999999.



Salvaguardas administrativas

E071 · B-07 · Administrador intenta quitarse ADMIN

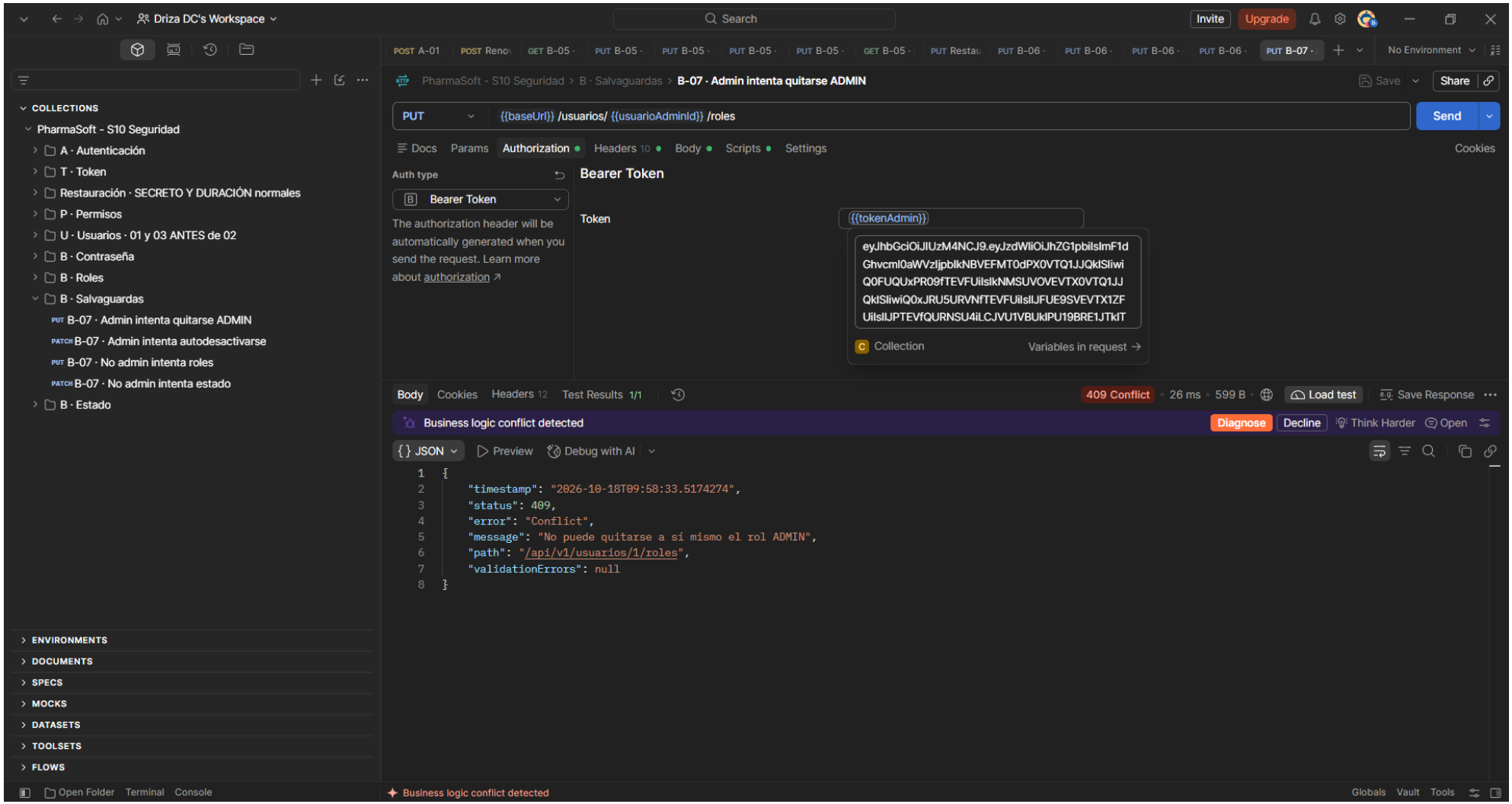
409; No puede quitarse a sí mismo el rol ADMIN.



Salvaguardas administrativas

E072 · B-07 · Autoeliminación de ADMIN: autorización

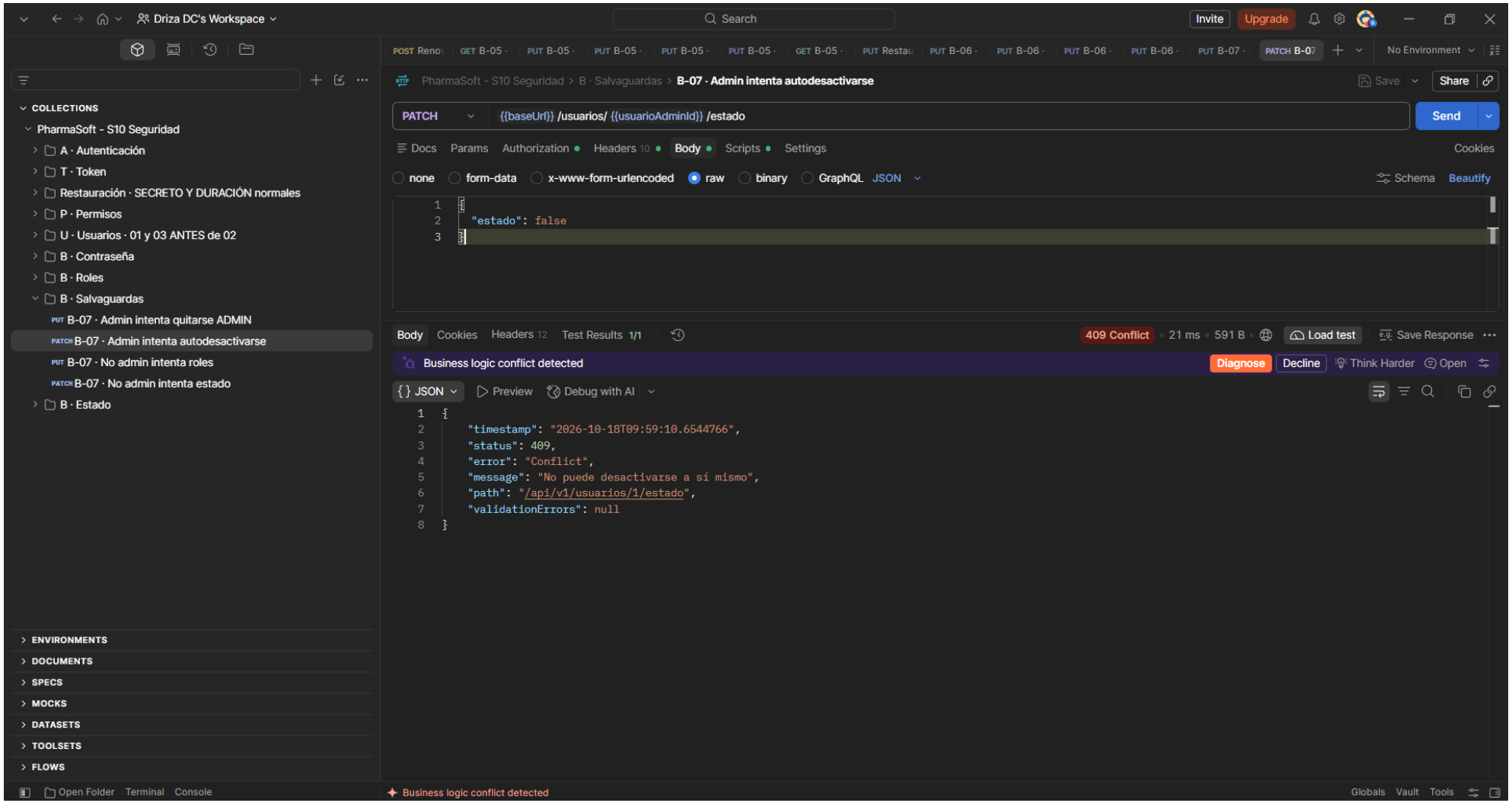
Vista del token administrador y el mismo rechazo 409.



Salvaguardas administrativas

E073 · B-07 · Administrador intenta autodesactivarse

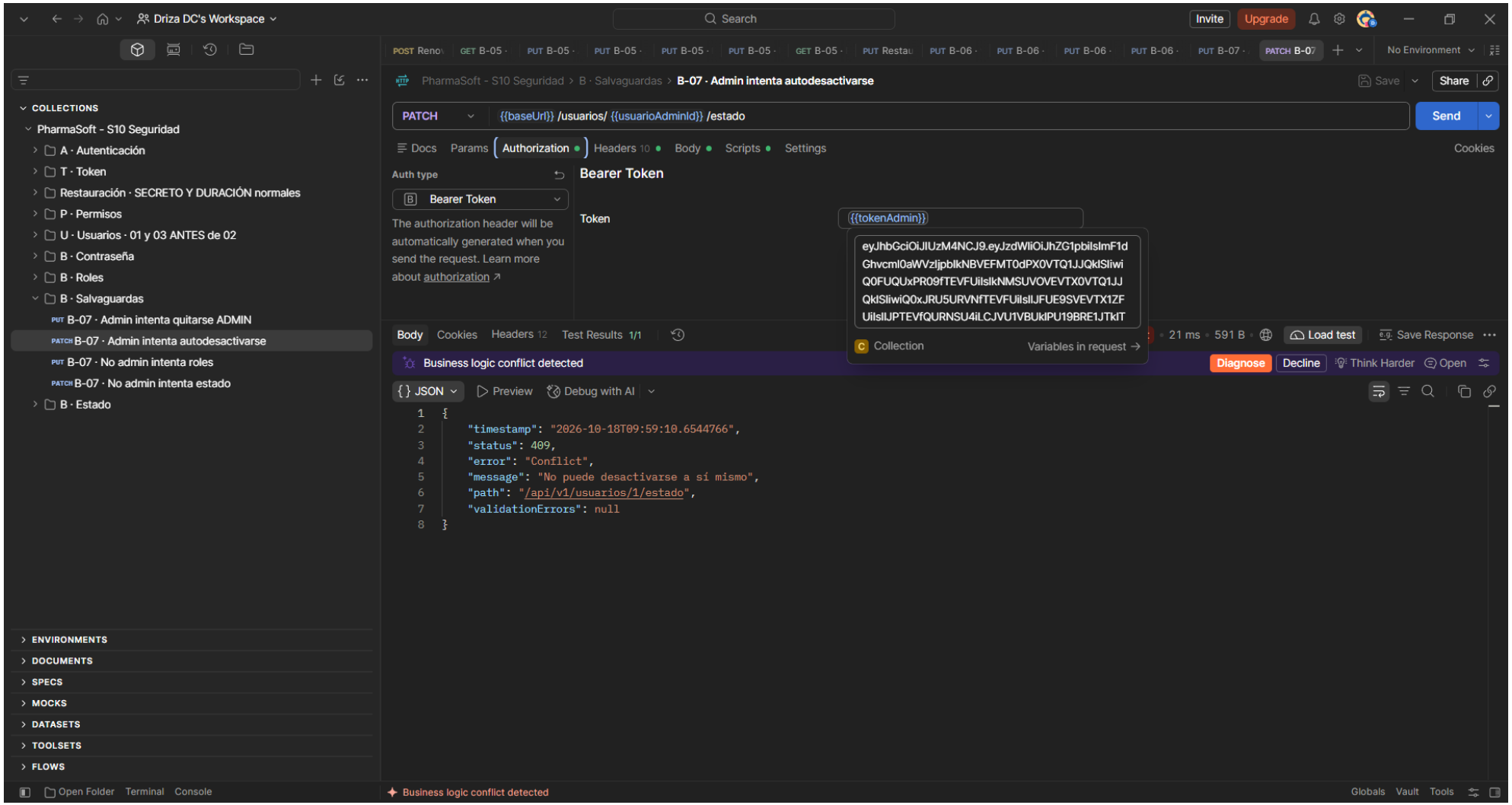
409; No puede desactivarse a sí mismo.



Salvaguardas administrativas

E074 · B-07 · Autodesactivación: autorización

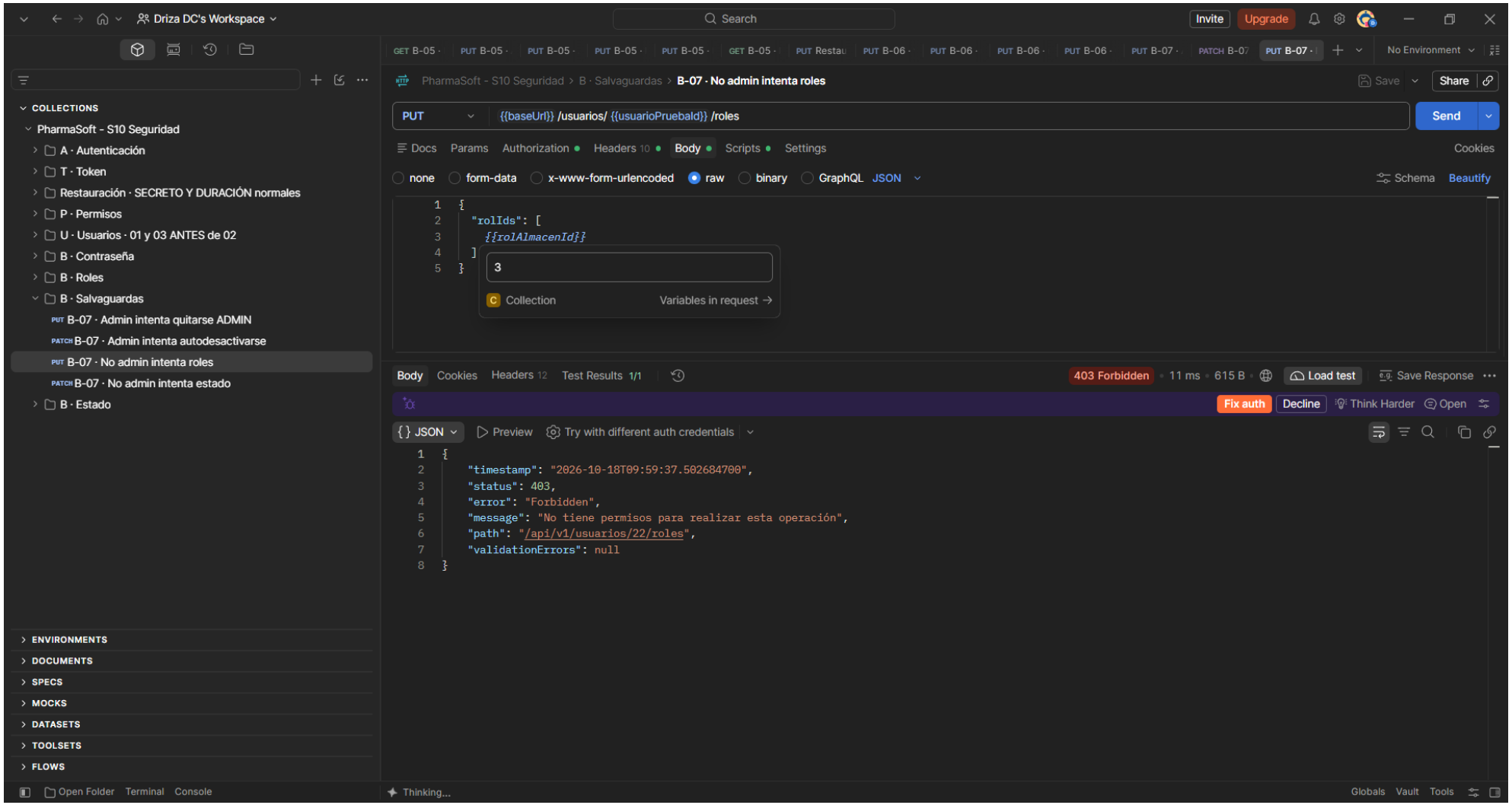
Vista del token administrador y el rechazo 409.



Salvaguardas administrativas

E075 · B-07 · No administrador intenta cambiar roles

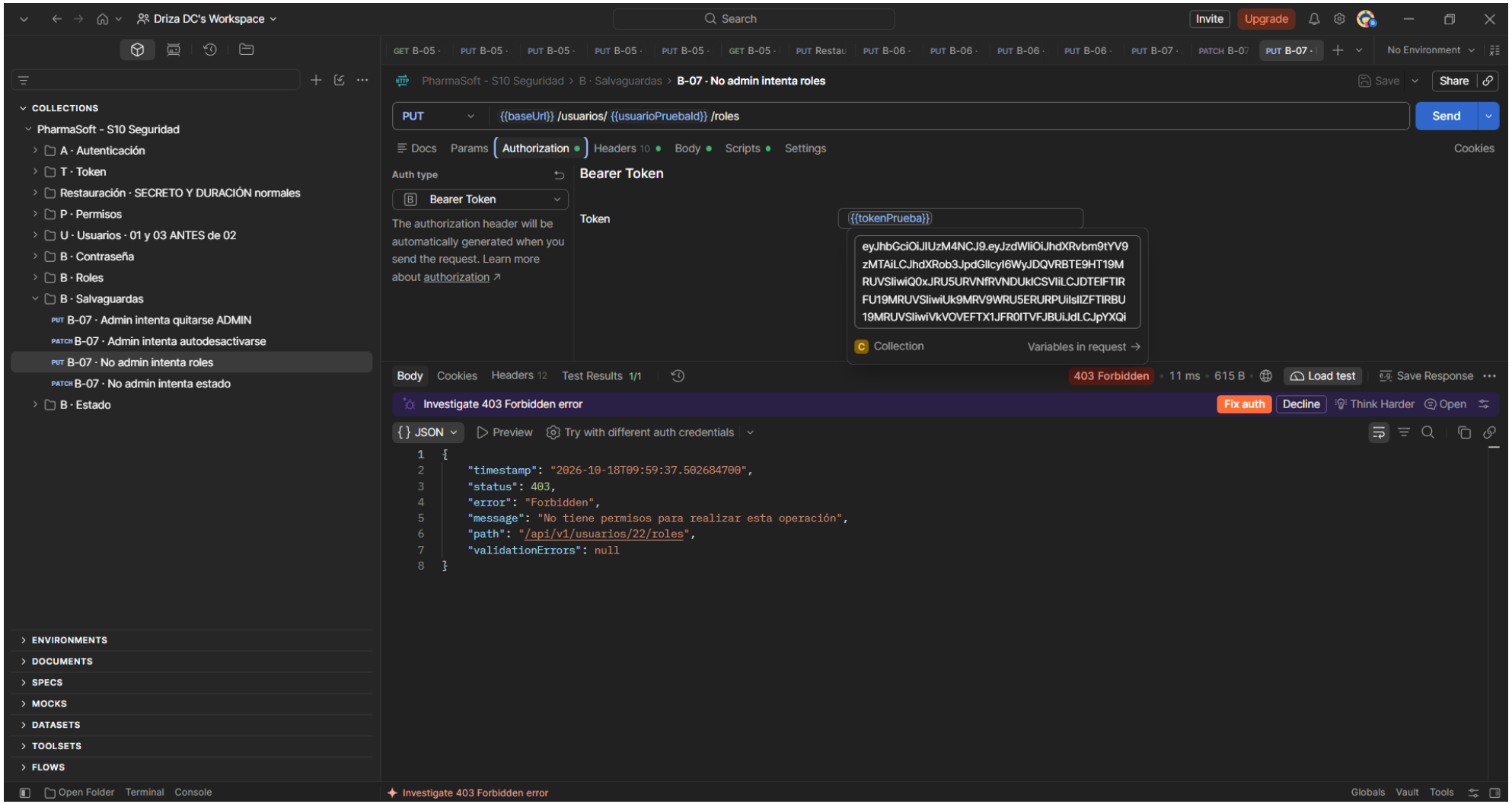
403; falta USUARIOS_ADMINISTRAR.



Salvaguardas administrativas

E076 · B-07 · Cambio de roles no autorizado: token

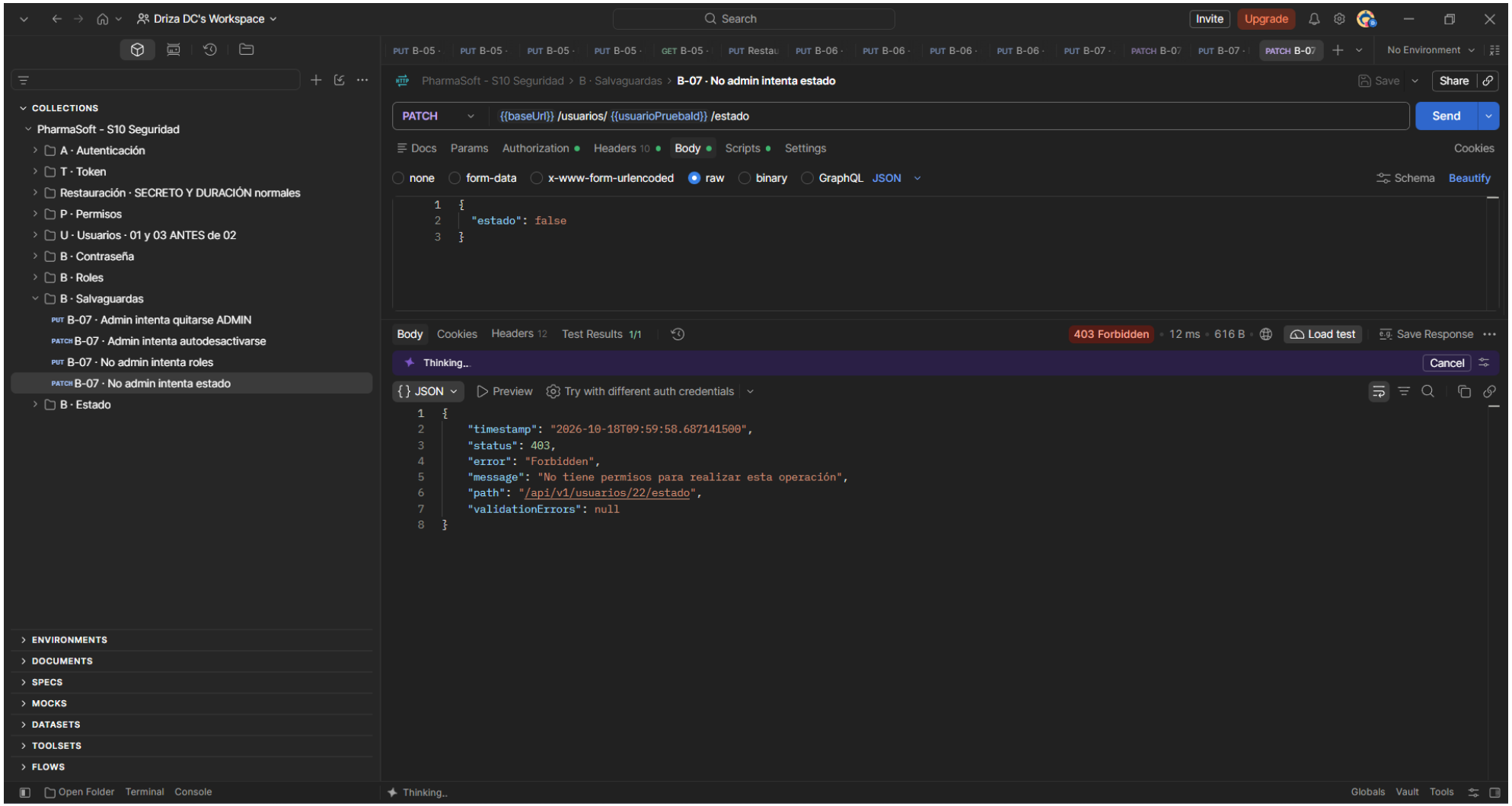
Se confirma 403 con el token de la cuenta de prueba.



Salvaguardas administrativas

E077 · B-07 · No administrador intenta cambiar estado

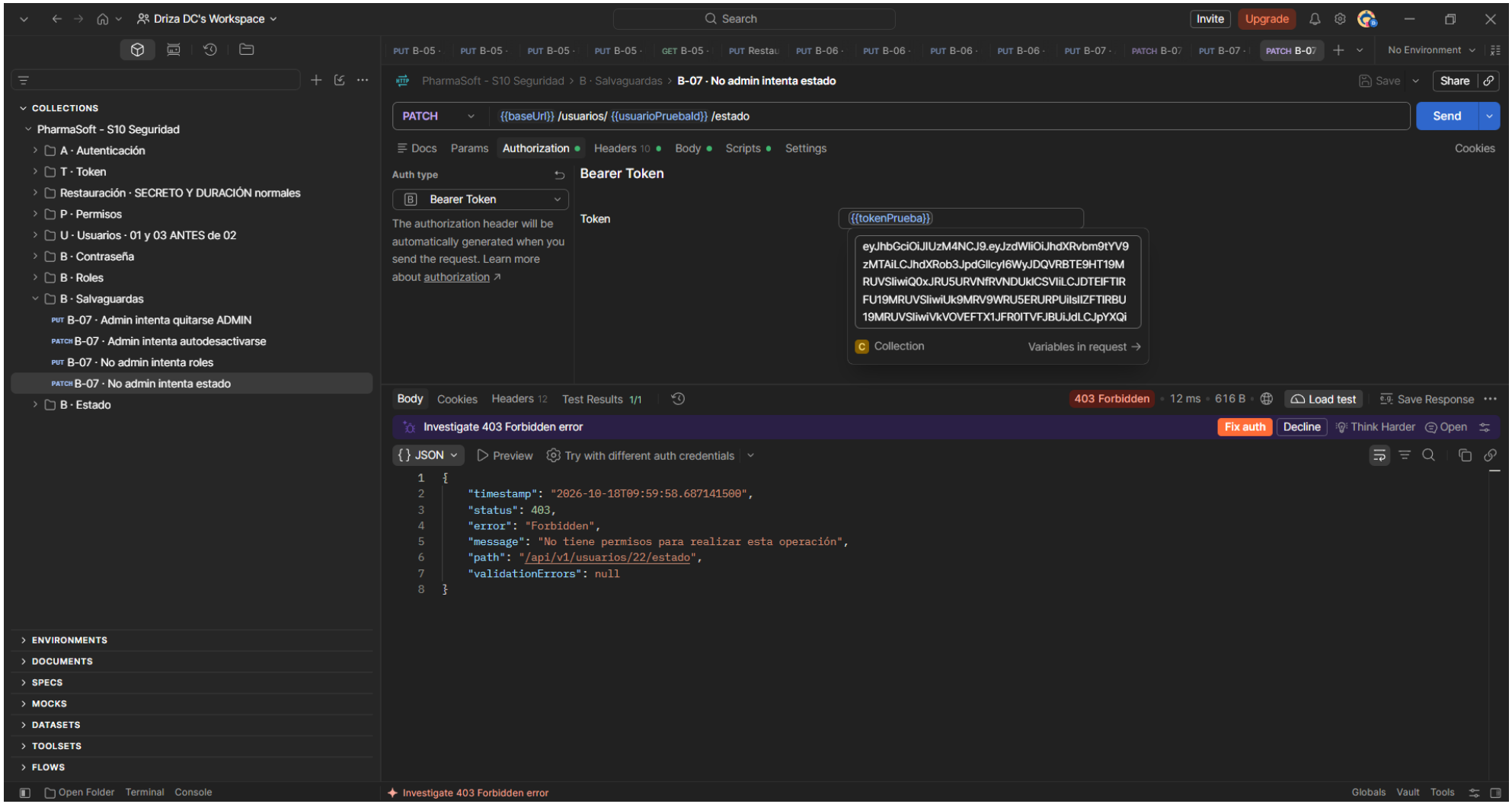
403; falta USUARIOS_ADMINISTRAR.



Salvaguardas administrativas

E078 · B-07 · Cambio de estado no autorizado: token

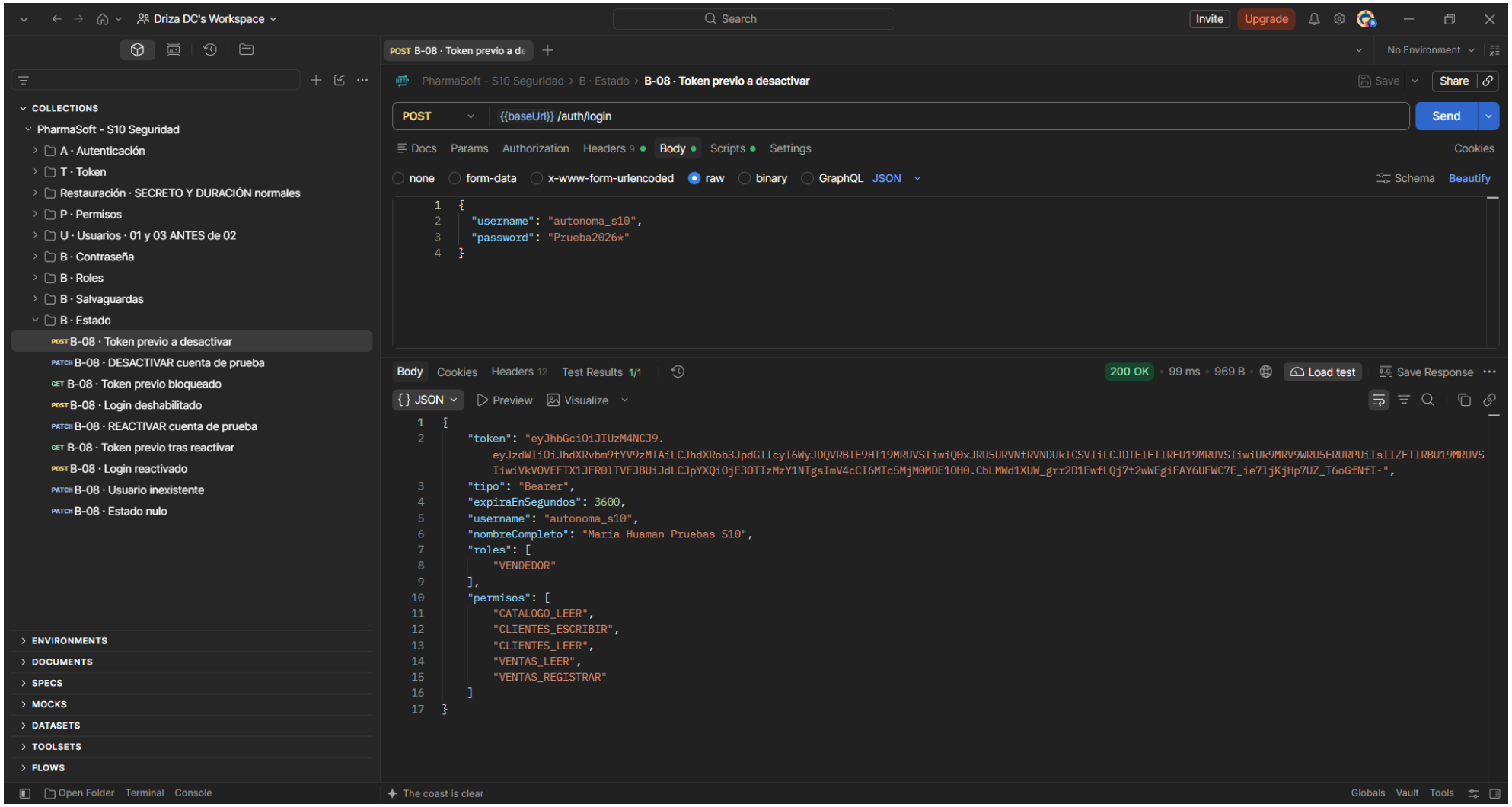
Se confirma el rechazo 403 a la cuenta no administradora.



Activación y desactivación de cuentas

E079 · B-08 · Token previo a desactivar

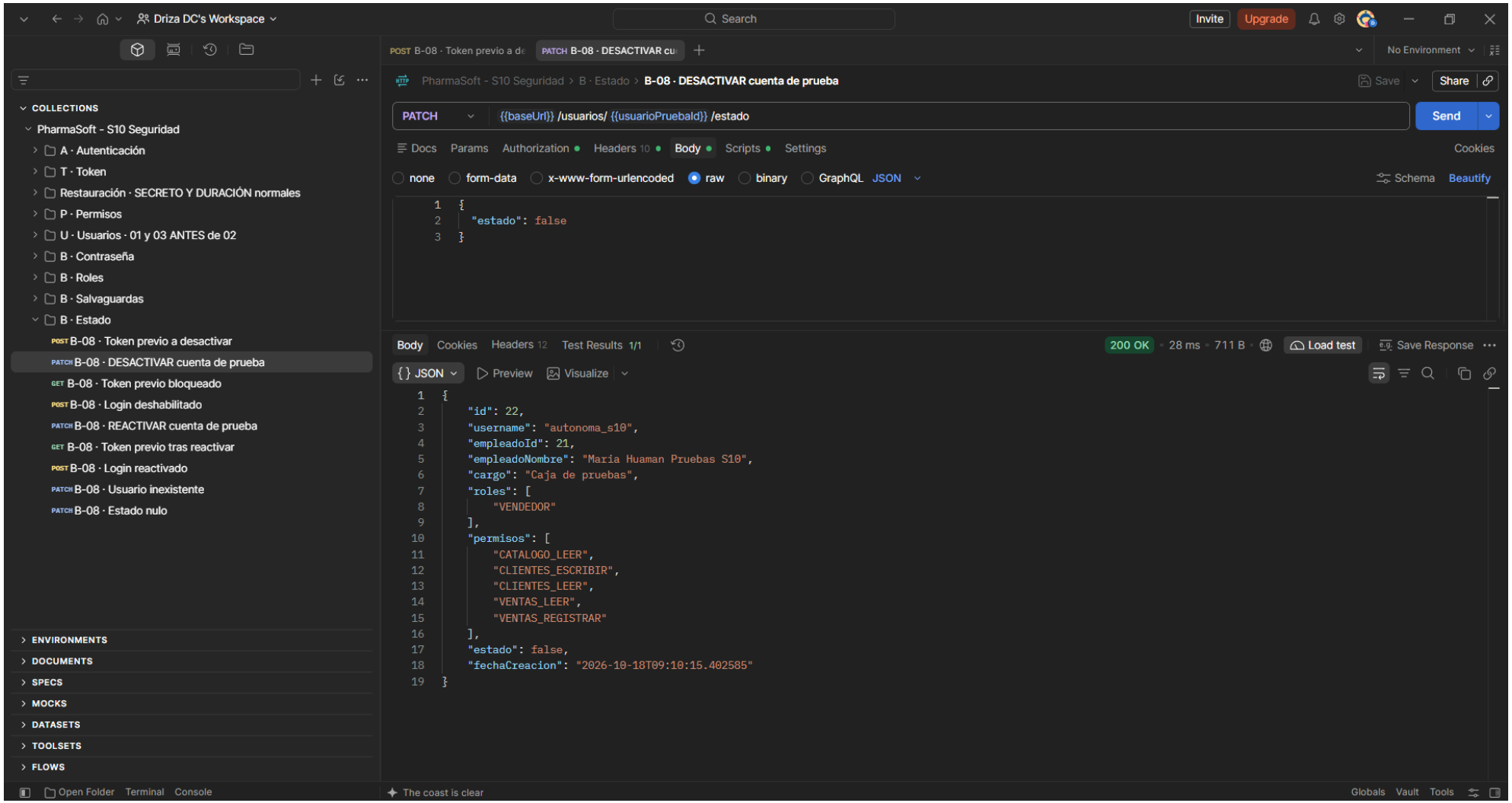
200; login y emisión del token que se conserva durante la prueba.



Activación y desactivación de cuentas

E080 · B-08 · Desactivación de la cuenta

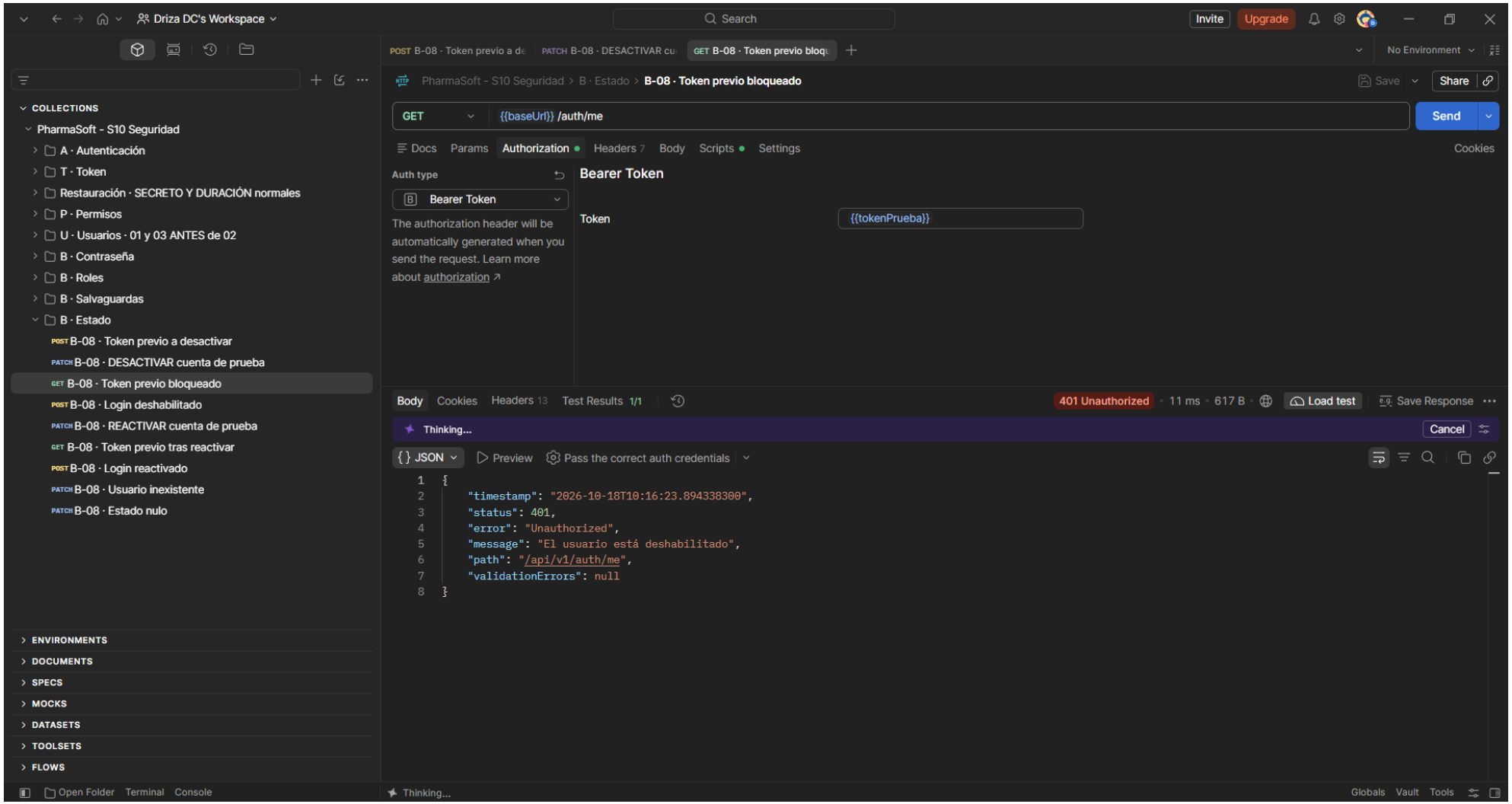
200; estado false en el perfil de autonoma_s10.



Activación y desactivación de cuentas

E081 · B-08 · Acceso con token de cuenta desactivada

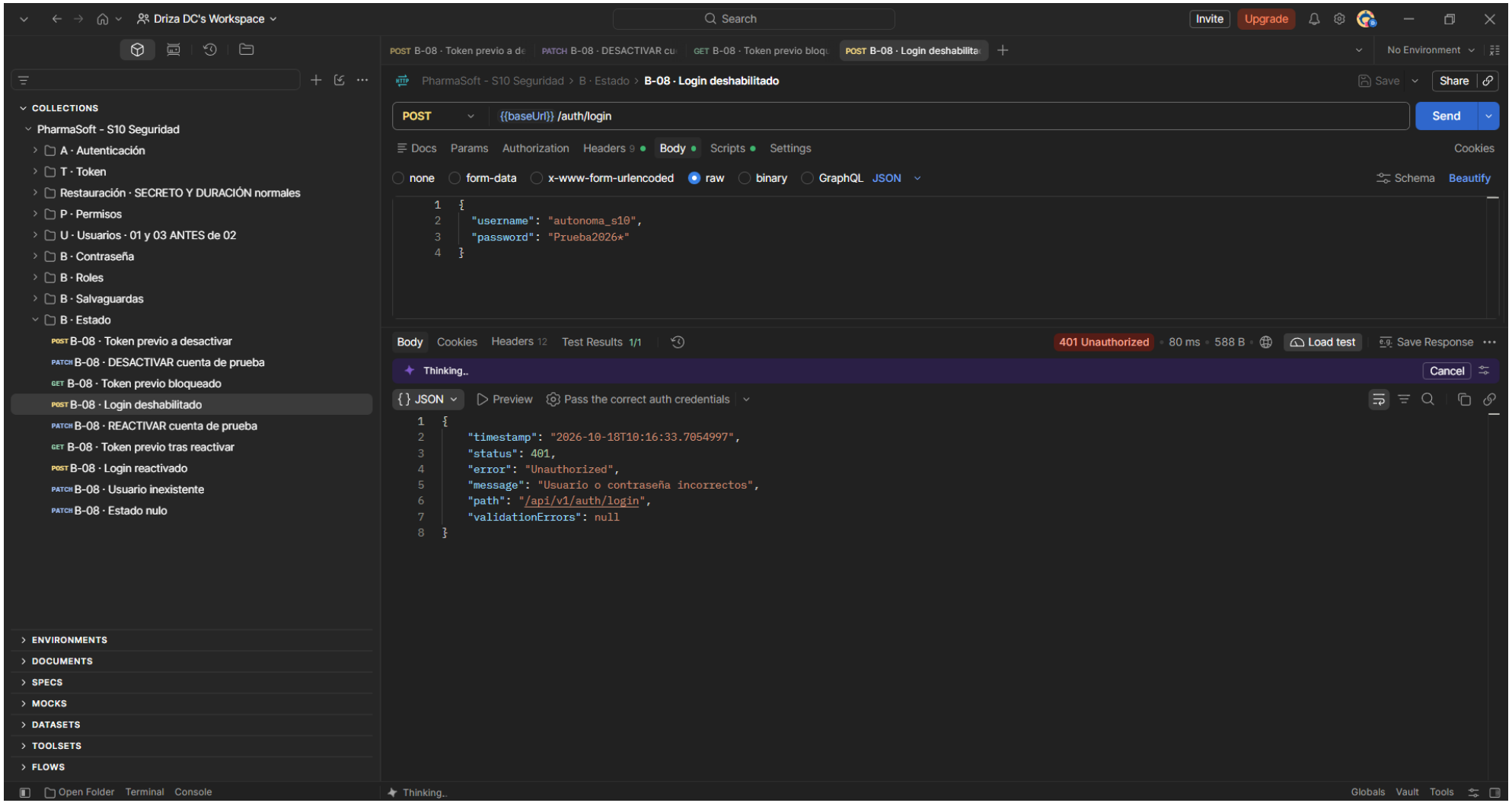
401; El usuario está deshabilitado.



Activación y desactivación de cuentas

E082 · B-08 · Login de cuenta desactivada

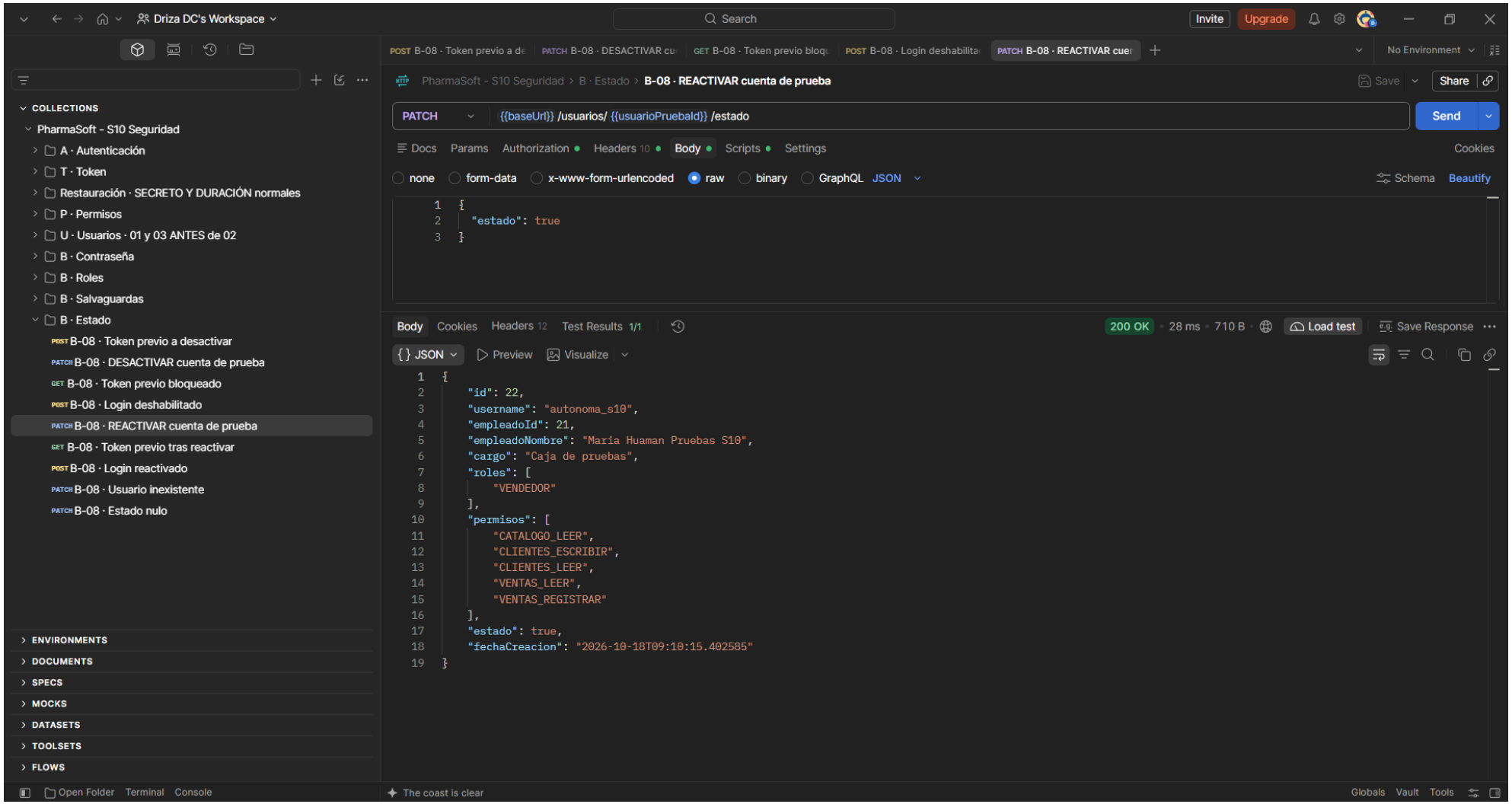
401; Usuario o contraseña incorrectos.



Activación y desactivación de cuentas

E083 · B-08 · Reactivación de la cuenta

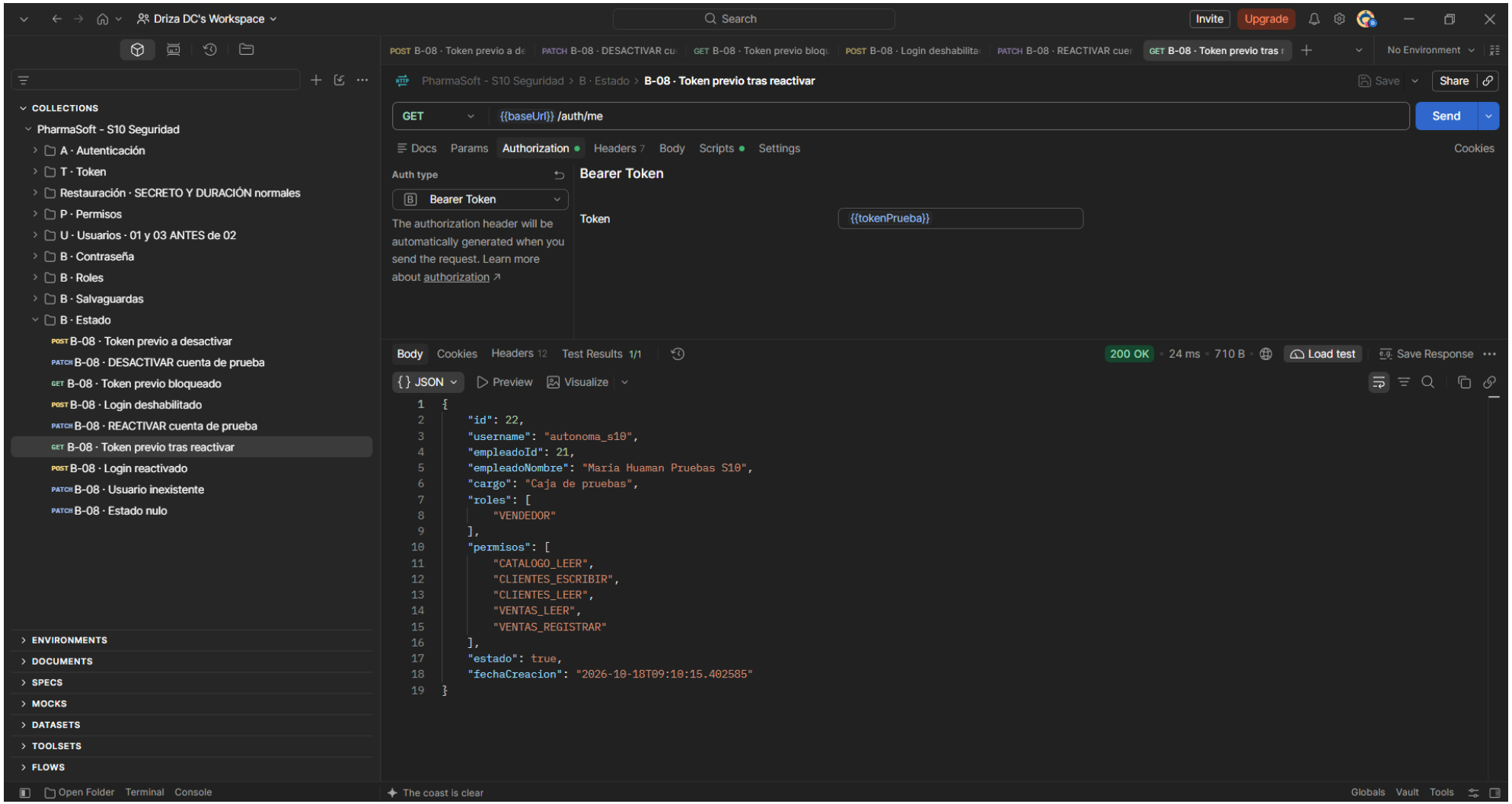
200; estado true.



Activación y desactivación de cuentas

E084 · B-08 · Token previo después de reactivar

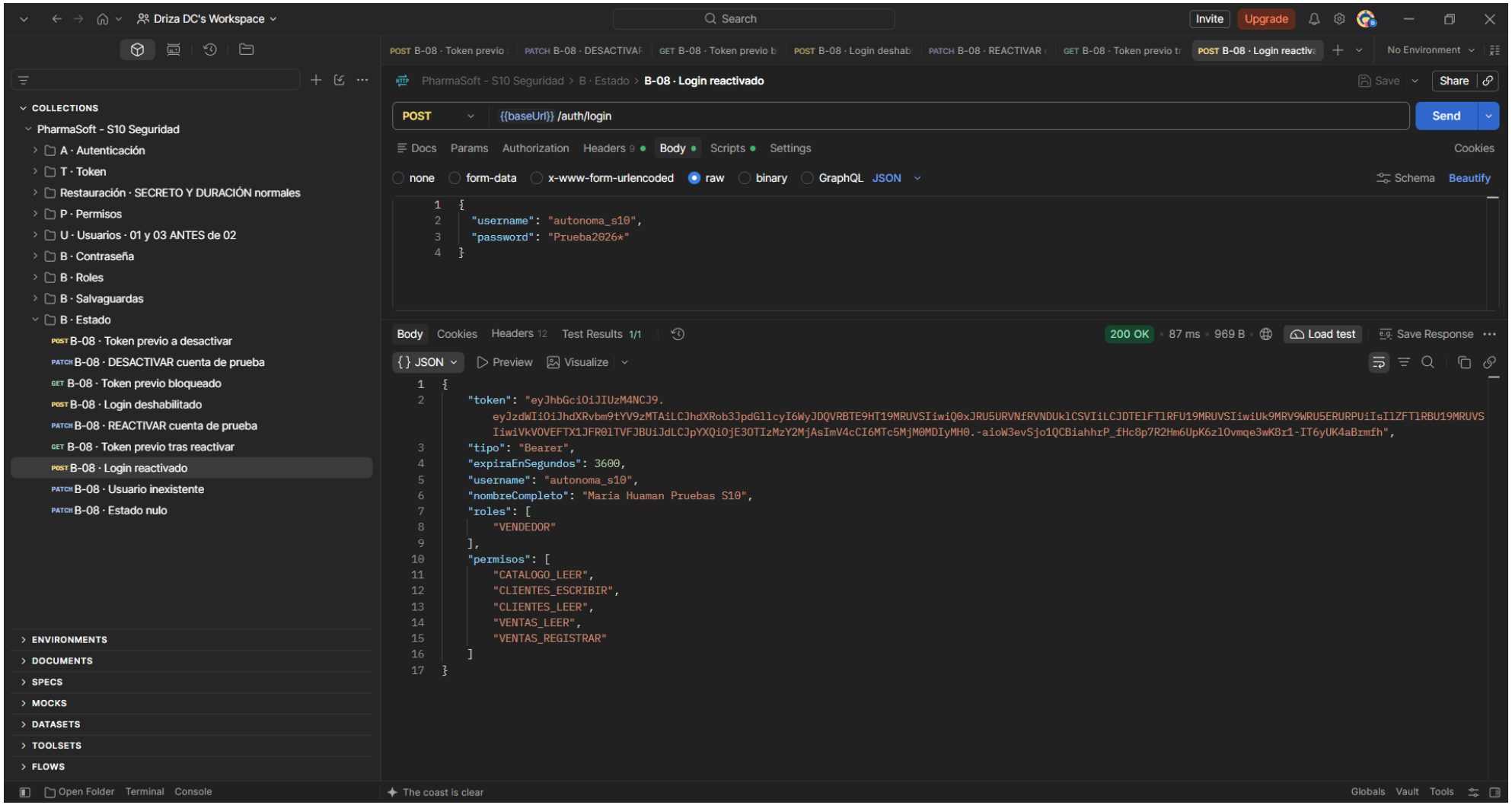
200; vuelve a funcionar mientras conserva firma y vigencia.



Activación y desactivación de cuentas

E085 · B-08 · Login después de reactivar

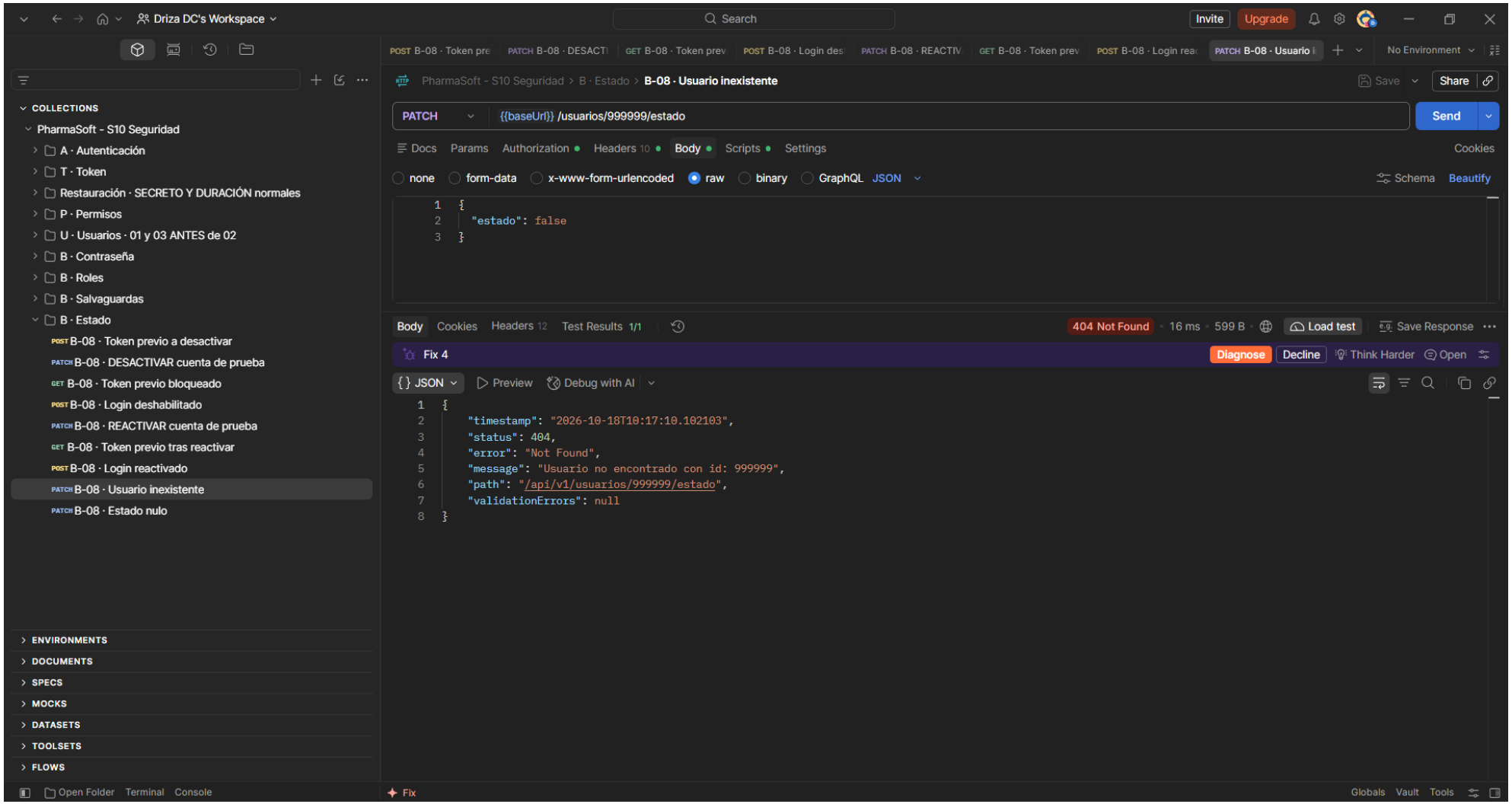
200; autenticación nuevamente permitida.



Activación y desactivación de cuentas

E086 · B-08 · Estado de un usuario inexistente

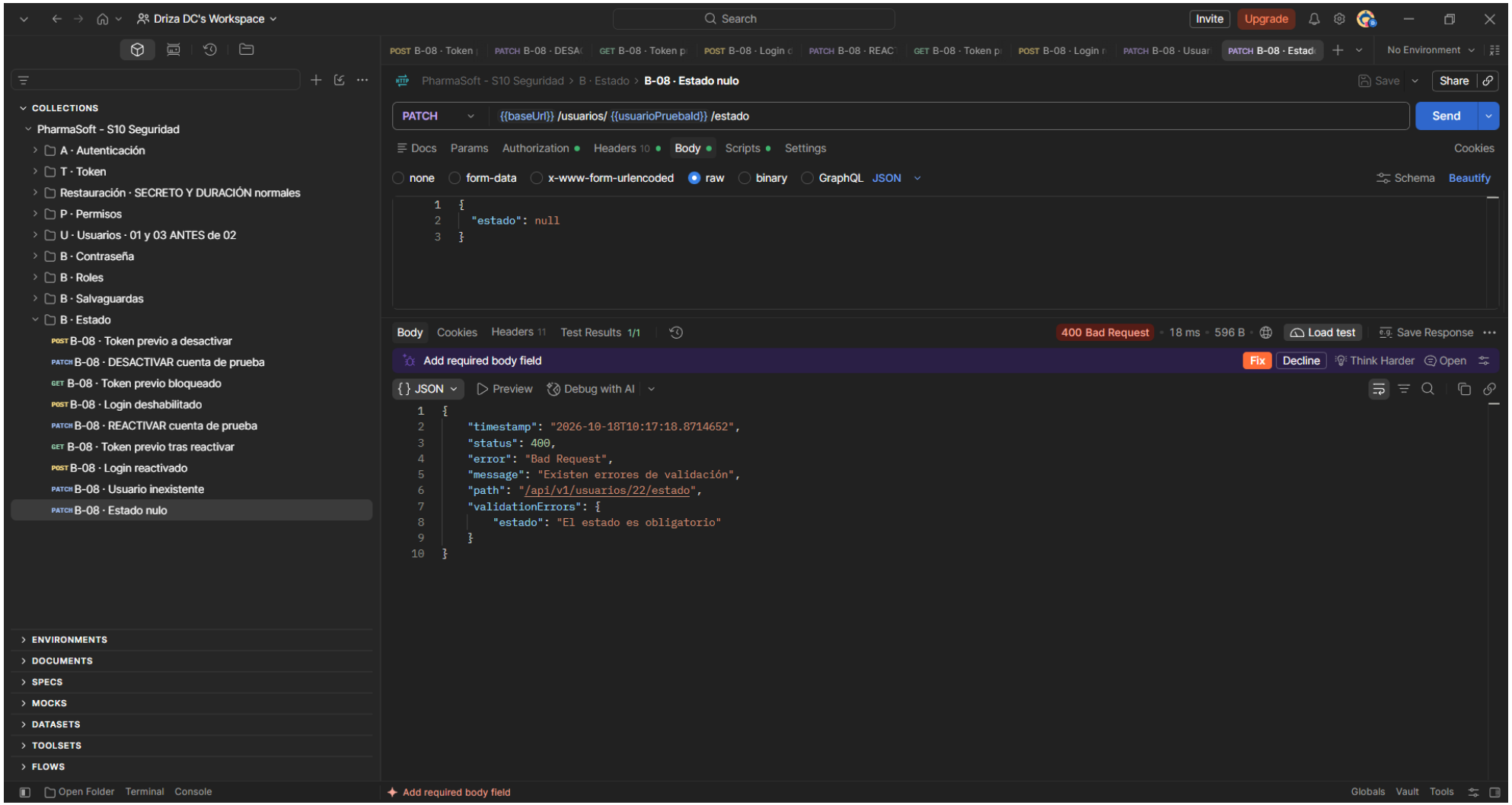
404; Usuario no encontrado con id: 999999.



Activación y desactivación de cuentas

E087 · B-08 · Estado nulo

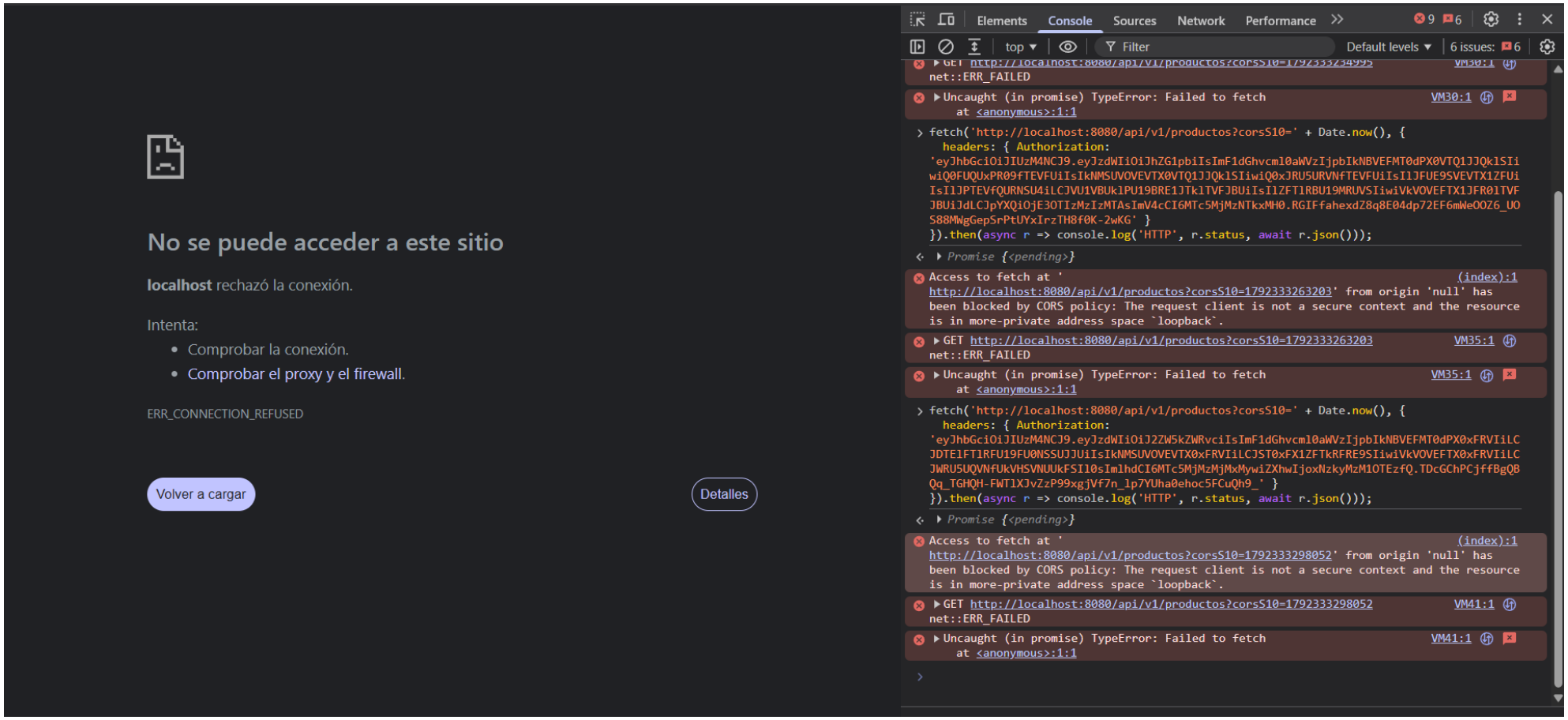
400; validationErrors.estado indica que el estado es obligatorio.



CORS y acceso desde la SPA

E060 · PREP · Preparación del entorno del navegador

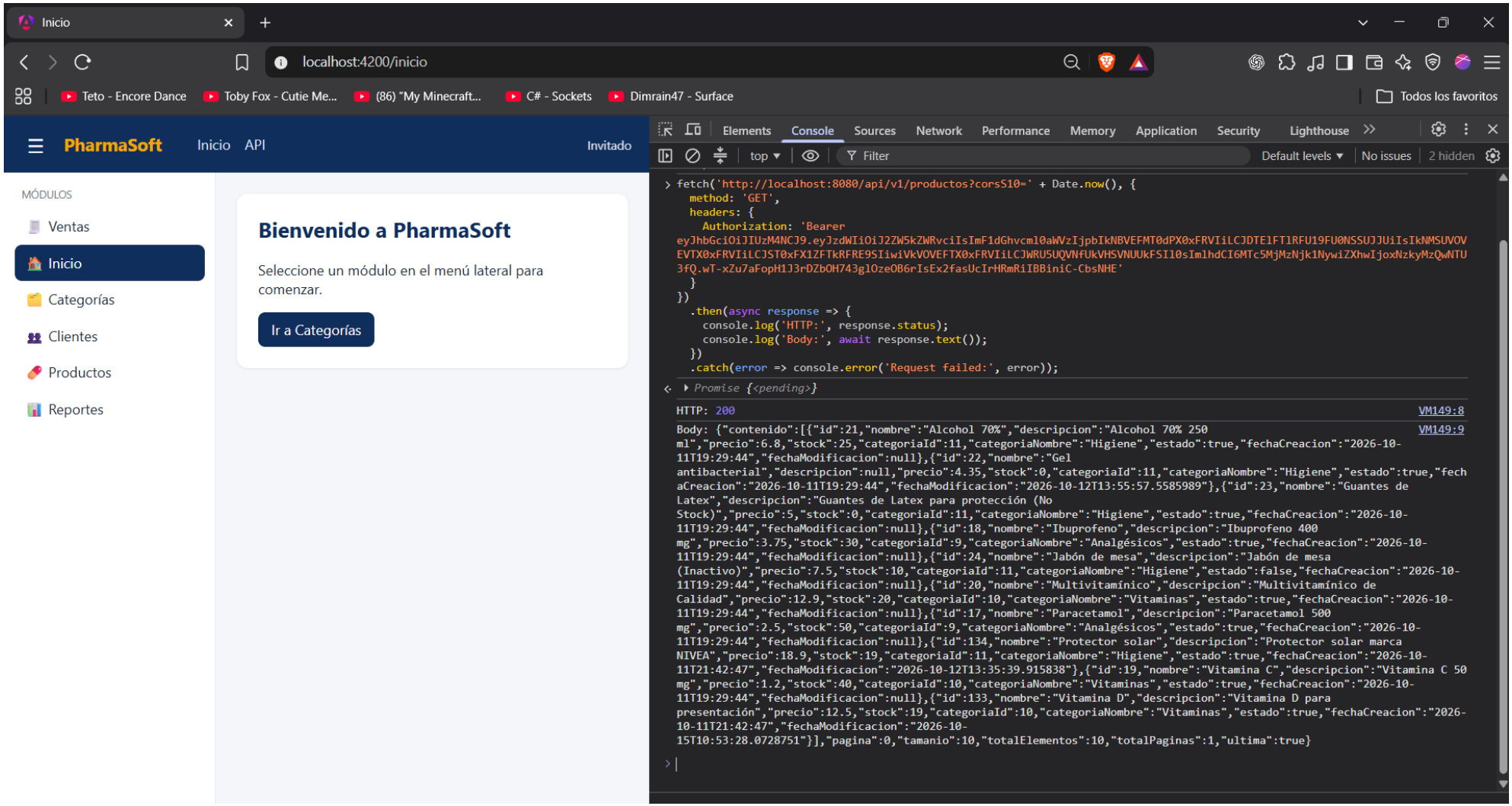
Intento inicial con localhost sin el frontend iniciado; se repite correctamente desde la SPA en C-01.



CORS y acceso desde la SPA

E088 · C-01 · Consulta desde la SPA

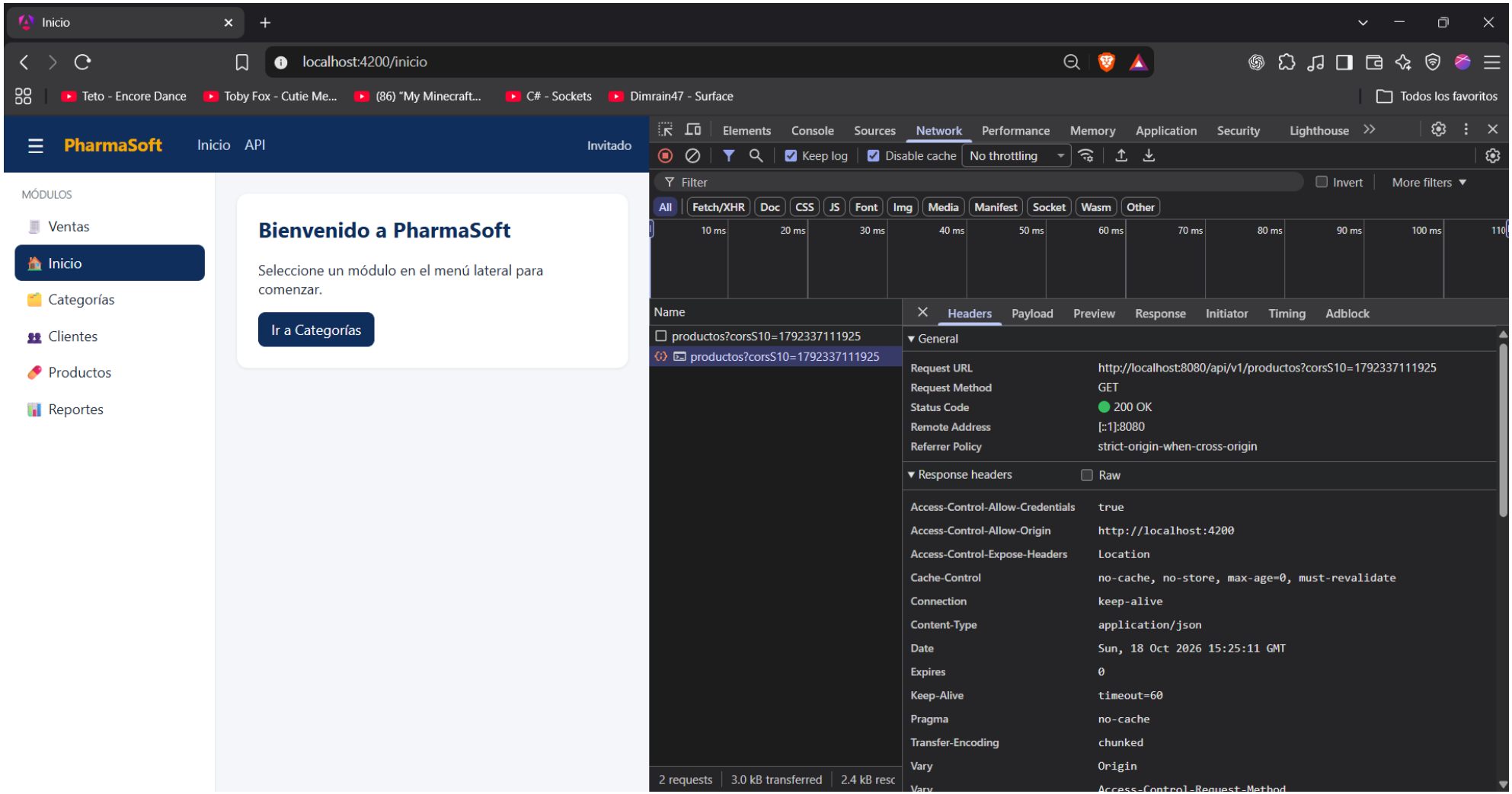
Consola de localhost:4200: HTTP 200 y JSON de productos.



CORS y acceso desde la SPA

E089 · C-01 · GET autorizado por CORS

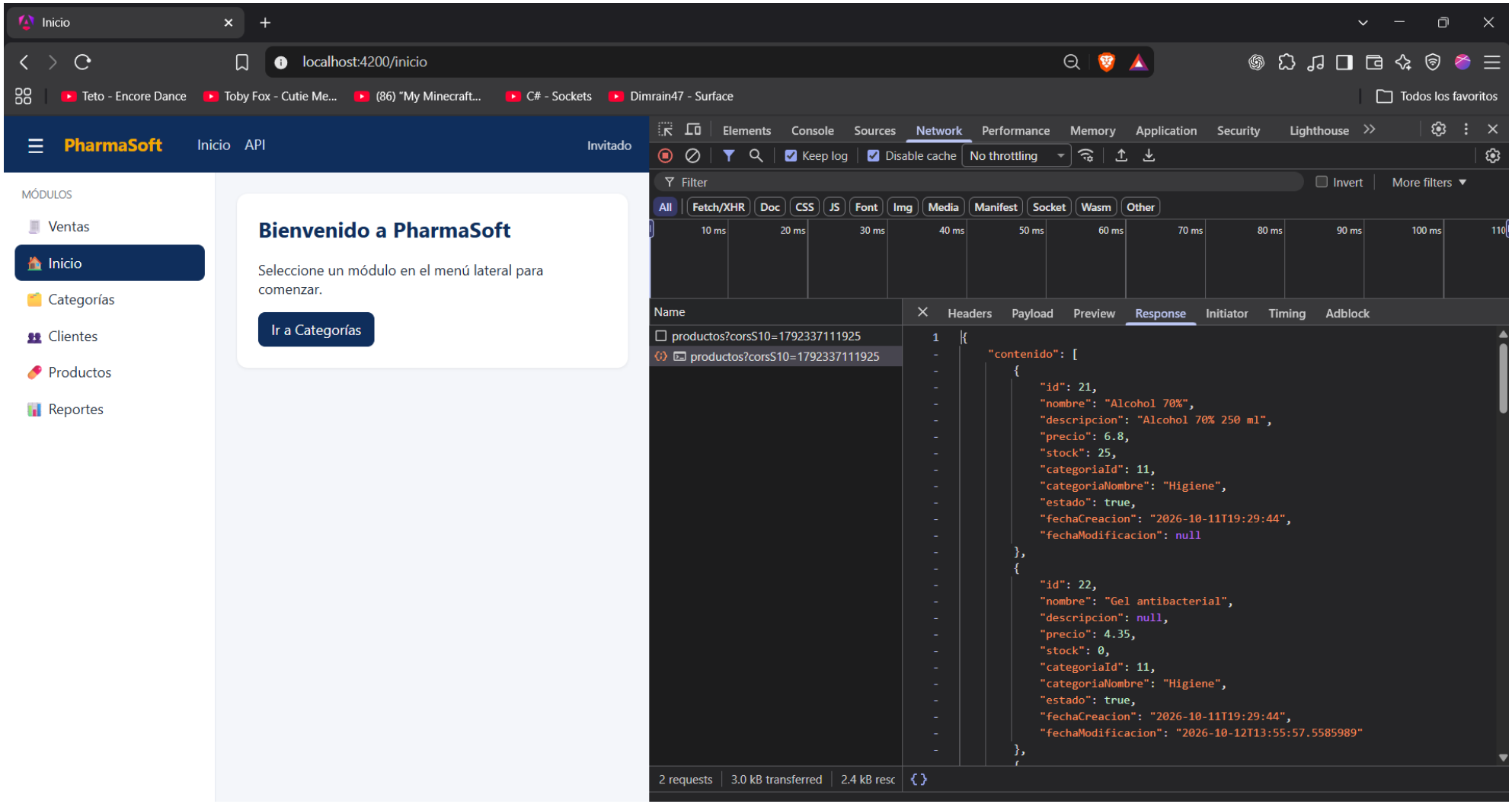
GET 200; Access-Control-Allow-Origin igual a http://localhost:4200.



CORS y acceso desde la SPA

E090 · C-01 · Respuesta JSON accesible

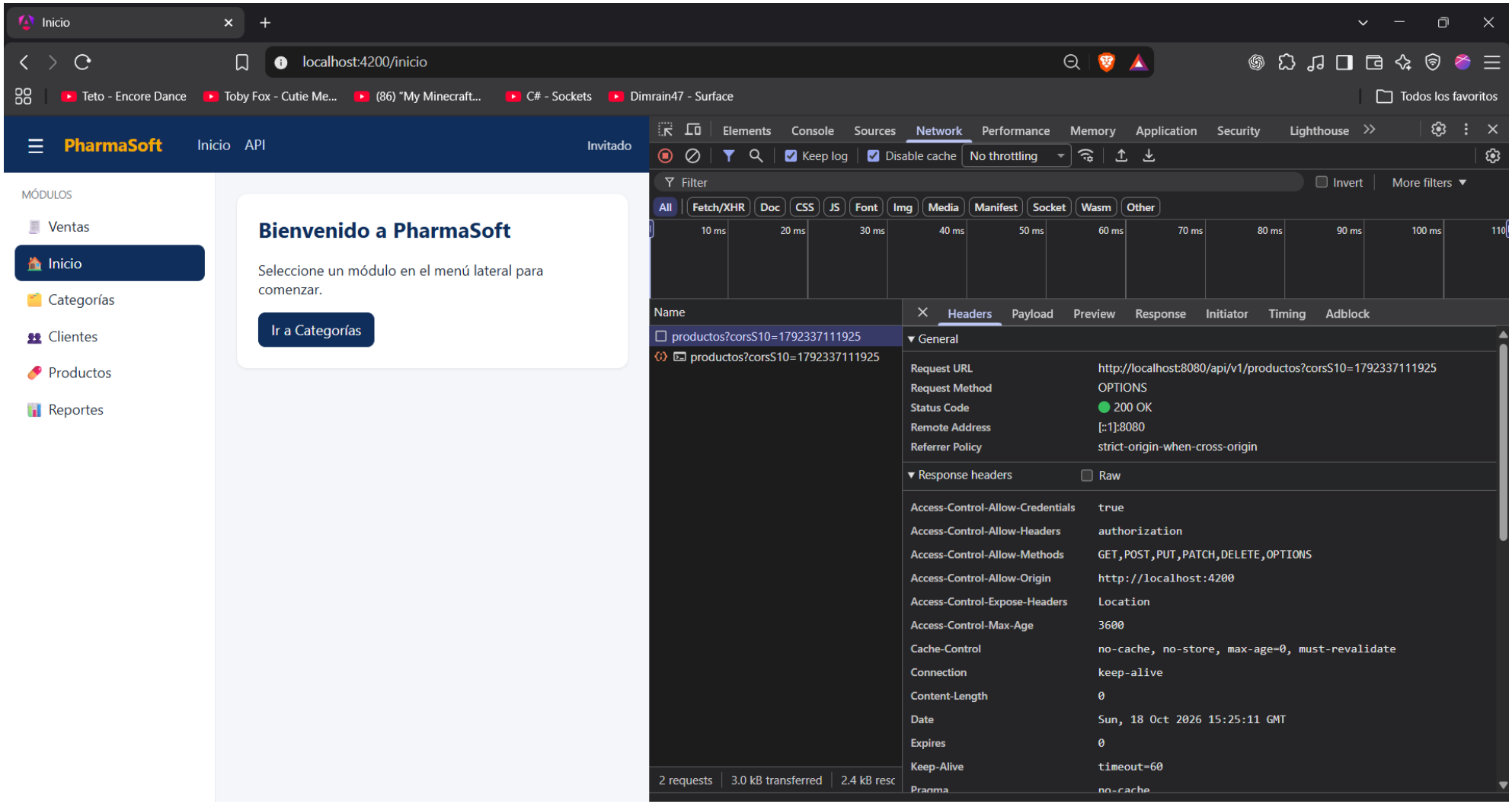
El navegador muestra el contenido de productos en Response.



CORS y acceso desde la SPA

E091 · C-01 · Preflight OPTIONS

OPTIONS 200; origen localhost:4200, authorization permitido y métodos autorizados.



CORS y acceso desde la SPA

E092 · C-01 · Cabeceras completas del preflight

HTTP 200; Allow-Origin, Allow-Methods, Allow-Headers y Max-Age en vista Raw.

